

AI for IT Security Professionals



Security Administration
ICT-OUS-3012-1.1
TGS-2023039344

UEN 201200696W | 6 September 2026

Original worked example; supplied references



Copyright and use of references

COURSE MATERIAL

Original explanations and synthetic cases are provided for enrolled learners.

REFERENCE LIBRARY

The supplied ebooks remain reference-only.
Public labs contain original datasets and scripts.

Tertiary Infotech Academy

PROVIDER

Tertiary Infotech Academy Pte Ltd
UEN 201200696W

COURSE DELIVERY

Four days: 30 hours learning and practice plus 2 hours assessment.

About the Trainer



Your Trainer

Trainer completes before delivery

NAME

ROLE

EXPERIENCE

CONTACT

Original worked example; supplied references

About the Trainer



Dr Alfred Ang

Principal Trainer

ORGANISATION

Tertiary Infotech Academy

FOCUS

AI, automation and cloud learning

DELIVERY

Applied technical training

CONTACT

Via the course LMS

Original worked example; supplied references

Attendance and course feedback

ATTENDANCE

Use the provider-issued attendance link and registered learner identity at the required checkpoints.

TRAQOM

Complete the SSG course feedback survey when prompted by the provider. Follow the current trainer-issued links.

Working agreements

CLASSROOM

Return from breaks on time. Discuss evidence respectfully. Keep personal data out of shared prompts.

LAB SCOPE

Use synthetic fixtures and the assigned sandbox. Label simulated, verified and blocked outcomes accurately.

Learner introductions

YOUR CONTEXT

Share your role and one recurring security-administration problem.

YOUR EVIDENCE

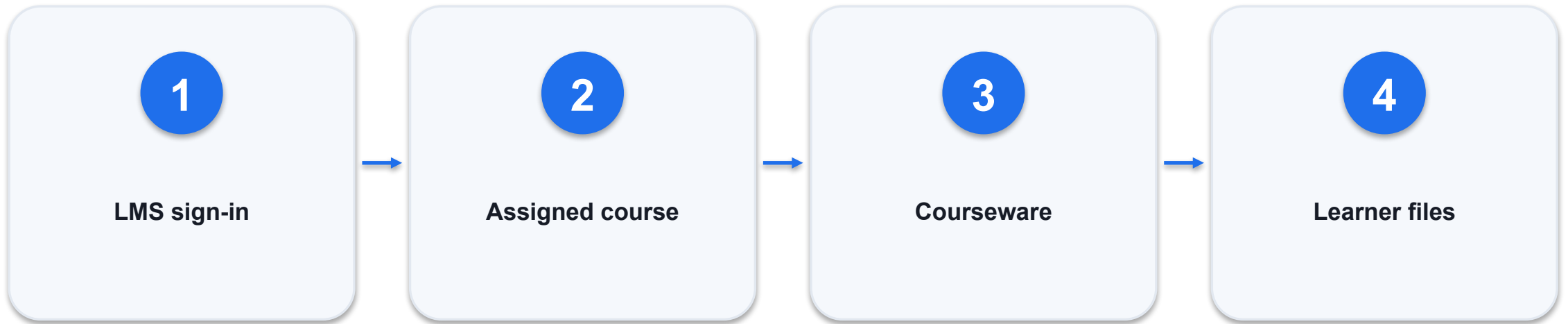
Name one control or log artifact you want to learn to inspect during the course.

Learning outcomes and evidence

Outcome	Observable evidence
LO1	Administer security programmes and analyze the impact of system updates.
LO2	Perform system administration and configure network device security features.
LO3	Perform troubleshooting of security software and assist users in defining access rights.
LO4	Coordinate access control rights and investigate unauthorized access incidents.

Original worked example; supplied references

Download course material



MECHANISM

Access through lms-tms.tertiaryinfotech.com. This is a navigation schematic; the detailed procedure is in the Learner Guide.

Briefing for assessment

WRITTEN | 60 MIN

Nine open-ended questions, K1–K9. Explain mechanisms and support decisions with evidence.

PRACTICAL | 60 MIN

Three tasks, A1–A6. Submit the requested identity, network/data and operations evidence.

Optional practice resources

COURSE PORTAL

Related Microsoft security practice:
exams.tertiaryinfotech.com/practice-exams/microsoft. A dedicated exam for the renamed course was not found.

ASSESSMENT STANDARD

Practice resources do not replace the nine-question written paper or the three practical tasks.

Four-day learning plan

Day	Teaching and practice	Assessment
1	Risk, evidence and identity Labs 1–4	None
2	Network, compute and data Labs 5–8	None
3	Posture, detection and investigation Labs 9–12	None
4	Agent controls and response Labs 13–16	WA 60 min + PP 60 min

Original worked example; supplied references

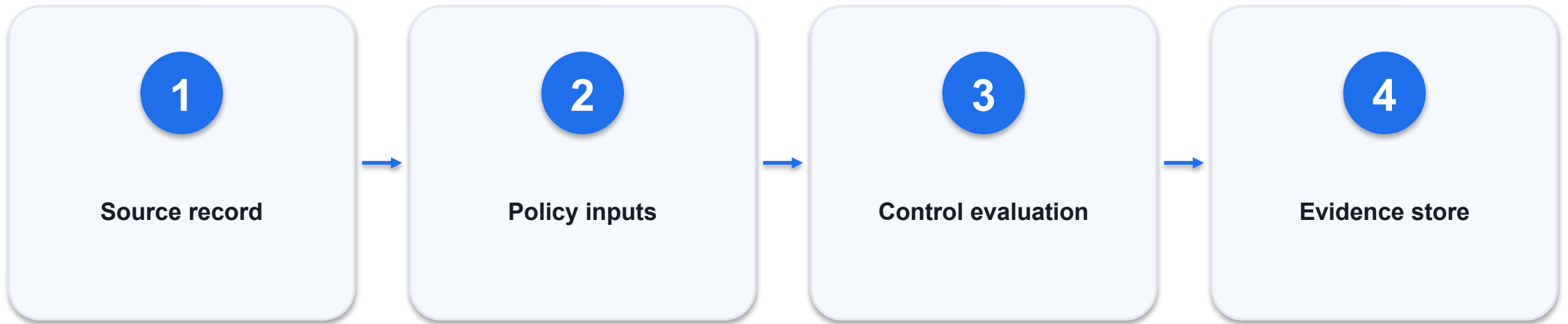


DAY 1

Risk and identity control

Technical mechanisms, evidence and diagnostic cases

Asset ownership



MECHANISM

Join security findings to an owned asset before prioritising remediation.

Asset ownership | field contract

INSPECTABLE ARTIFACT

asset_id

owner

internet_exposed

criticality

INTERPRETATION

srv-pay has owner Priya and criticality 5.

Record inventory version, join key and unmatched row count.

Asset ownership | counterexample

VALID CASE

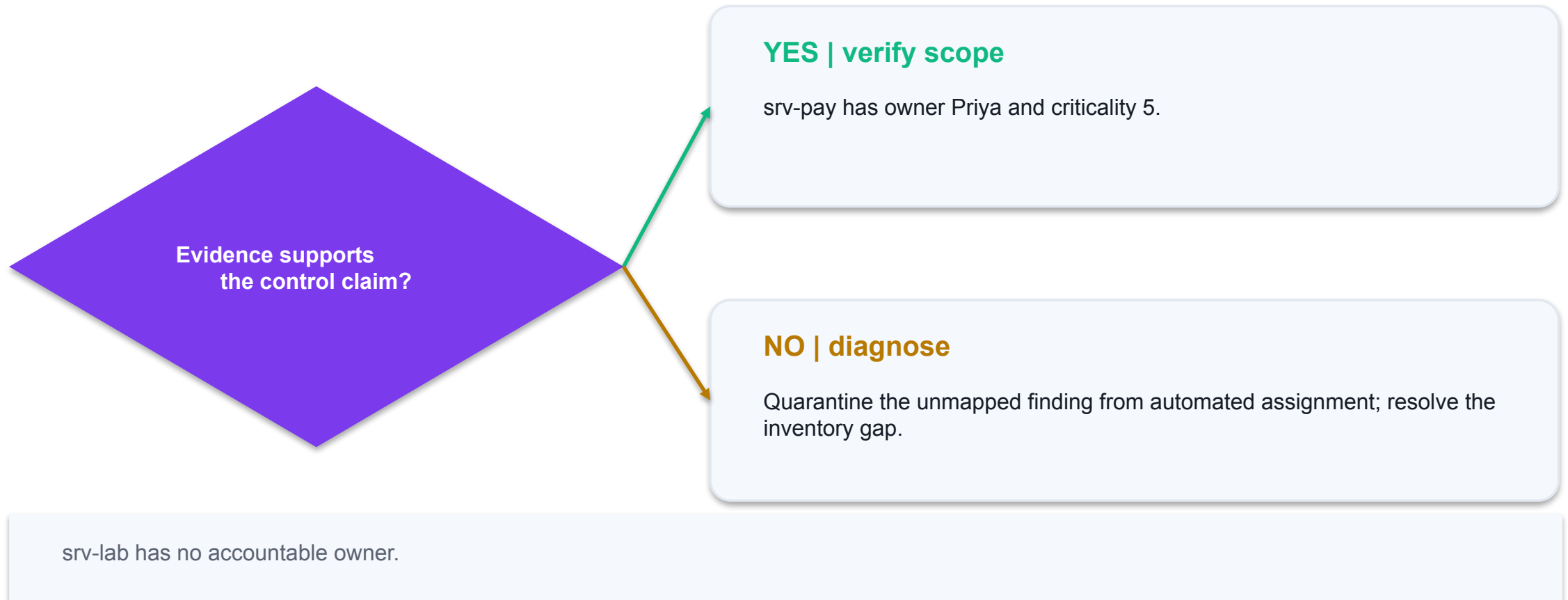
srv-pay has owner Priya and criticality 5.

FAILURE CASE

srv-lab has no accountable owner.

Join security findings to an owned asset before prioritising remediation.

Asset ownership | diagnosis



Original worked example; supplied references

Asset ownership | verification

EVIDENCE TO PRESERVE

Record inventory version, join key and unmatched row count.

ACCEPTANCE BOUNDARY

srv-pay has owner Priya and criticality 5.

Quarantine the unmapped finding from automated assignment; resolve the inventory gap.

Asset ownership | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

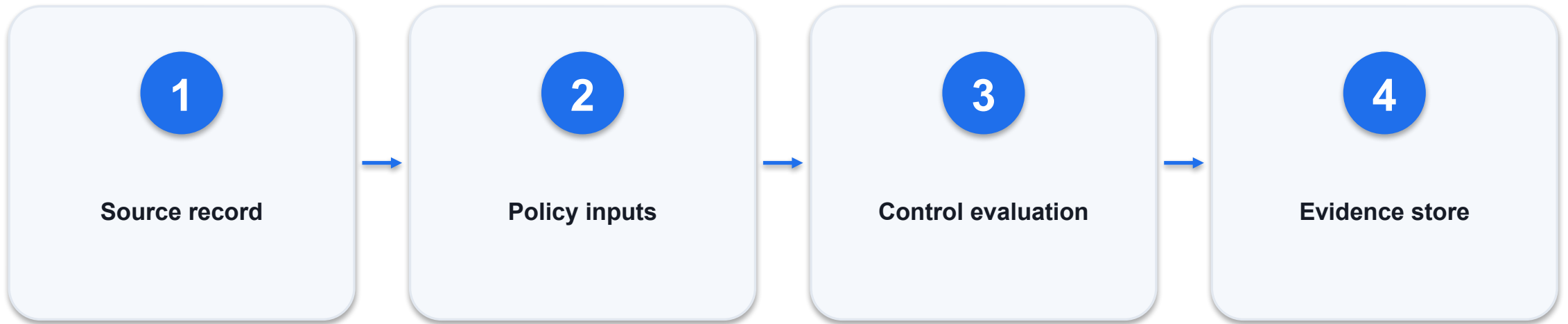
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
srv-lab has no accountable owner.

Resolve it using:
asset_id, owner, internet_exposed,
criticality

Patch prioritisation



MECHANISM

Rank exposed high-impact assets before isolated low-impact assets.

Patch prioritisation | field contract

INSPECTABLE ARTIFACT

$\text{score} = \text{severity} * \text{criticality} * \text{exposure_weight}$

INTERPRETATION

$8 * 5 * 2 = 80$ for internet-facing
srv-pay.

Retain component values and the
final priority order; this is a
classroom heuristic, not CVSS.

Patch prioritisation | counterexample

VALID CASE

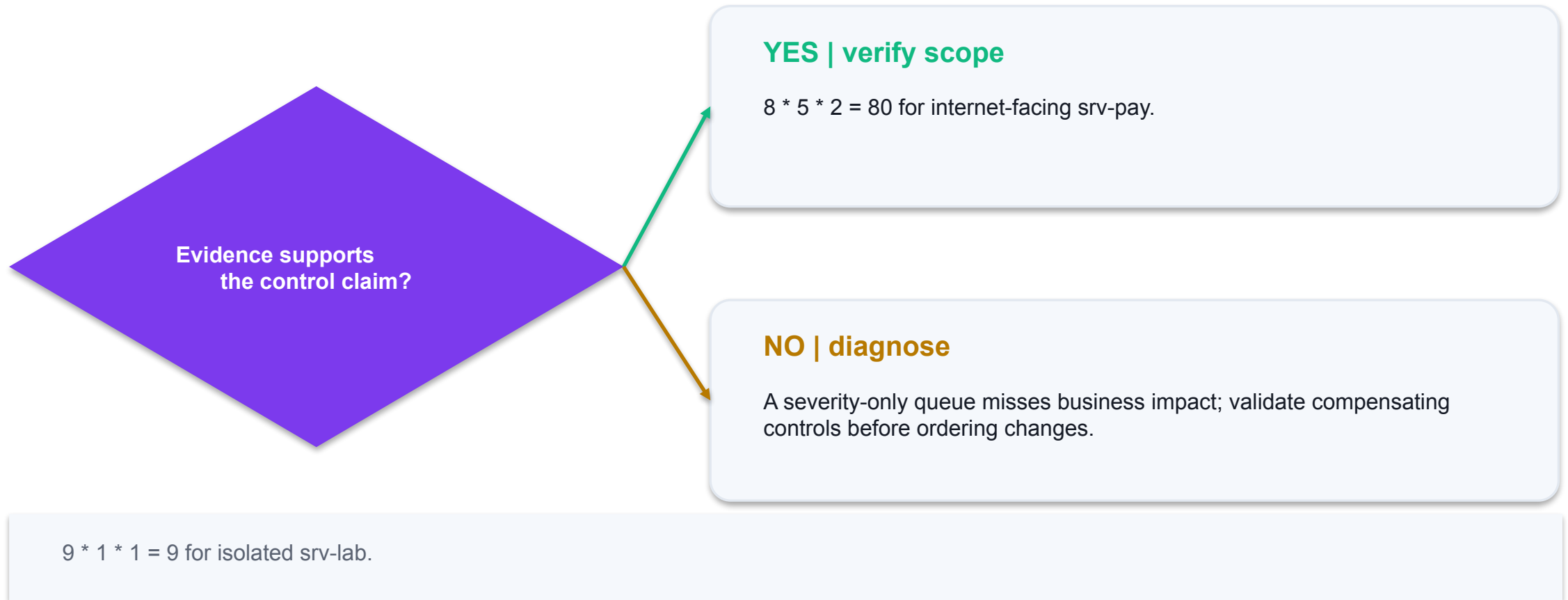
$8 * 5 * 2 = 80$ for internet-facing srv-pay.

FAILURE CASE

$9 * 1 * 1 = 9$ for isolated srv-lab.

Rank exposed high-impact assets before isolated low-impact assets.

Patch prioritisation | diagnosis



Original worked example; supplied references

Patch prioritisation | verification

EVIDENCE TO PRESERVE

Retain component values and the final priority order; this is a classroom heuristic, not CVSS.

ACCEPTANCE BOUNDARY

$8 * 5 * 2 = 80$ for internet-facing srv-pay.

A severity-only queue misses business impact; validate compensating controls before ordering changes.

Patch prioritisation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

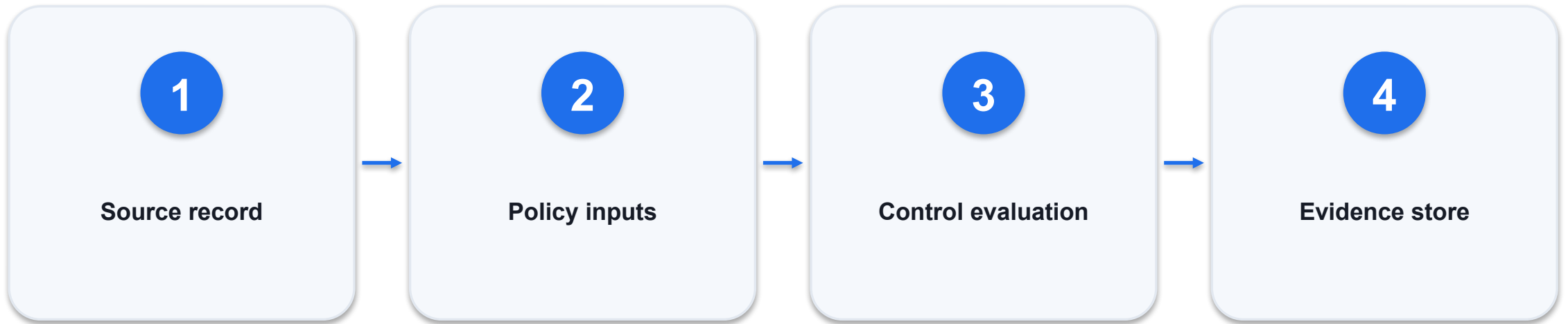
Test this claim:

$9 * 1 * 1 = 9$ for isolated srv-lab.

Resolve it using:

score = severity * criticality *
exposure_weight

Change and rollback gates



MECHANISM

A canary release moves to wider rollout only after error and health checks.

Change and rollback gates | field contract

INSPECTABLE ARTIFACT

change_id

baseline_error_rate

canary_error_rate

rollback_owner

INTERPRETATION

0.5% baseline and 0.6% canary meet a 1 percentage-point guard.

Capture pre/post health evidence and approval state for CHG-104.

Change and rollback gates | counterexample

VALID CASE

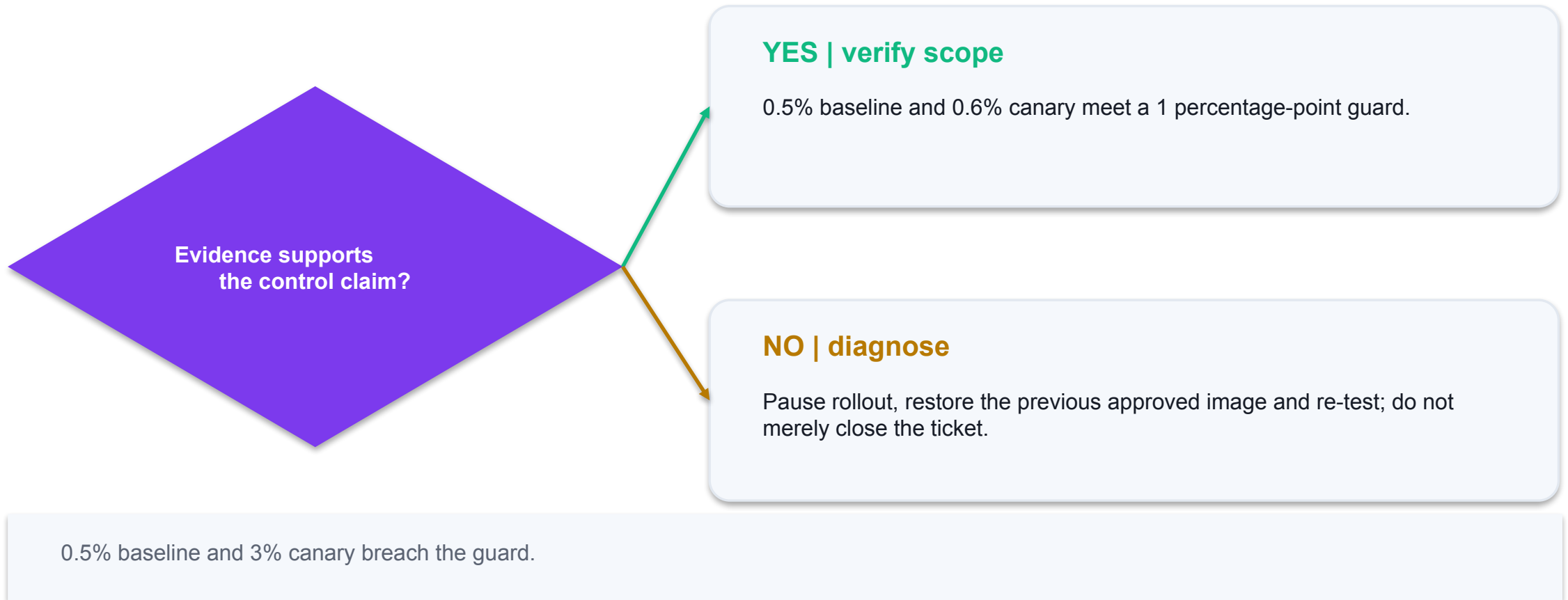
0.5% baseline and 0.6% canary meet a 1 percentage-point guard.

FAILURE CASE

0.5% baseline and 3% canary breach the guard.

A canary release moves to wider rollout only after error and health checks.

Change and rollback gates | diagnosis



Original worked example; supplied references

Change and rollback gates | verification

EVIDENCE TO PRESERVE

Capture pre/post health evidence and approval state for CHG-104.

ACCEPTANCE BOUNDARY

0.5% baseline and 0.6% canary meet a 1 percentage-point guard.

Pause rollout, restore the previous approved image and re-test; do not merely close the ticket.

Change and rollback gates | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
0.5% baseline and 3% canary
breach the guard.

Resolve it using:
change_id, baseline_error_rate,
canary_error_rate, rollback_owner

Lab 1 | input schema

INSPECTABLE ARTIFACT

id: srv-pay
severity: 8
criticality: 5
exposure: 2
owner: Priya
baseline: 0.5
canary: 3.0

INTERPRETATION

Synthetic fixture record.

Ranked risk register and canary decision.

The full dataset and instructions are in this lab's own folder.

Lab 1 | decision logic

```
for r in rows:
    score=r['severity']*r['criticality']*r['exposure']
    out.append({'id':r['id'],'score':score,'decision':('ROLLBACK'
    if r['canary']-r['baseline']>1 else 'CONTINUE')})
out.sort(key=lambda r:r['score'],reverse=True)
```

READ THE CODE

Actual excerpt from
analyse.py.

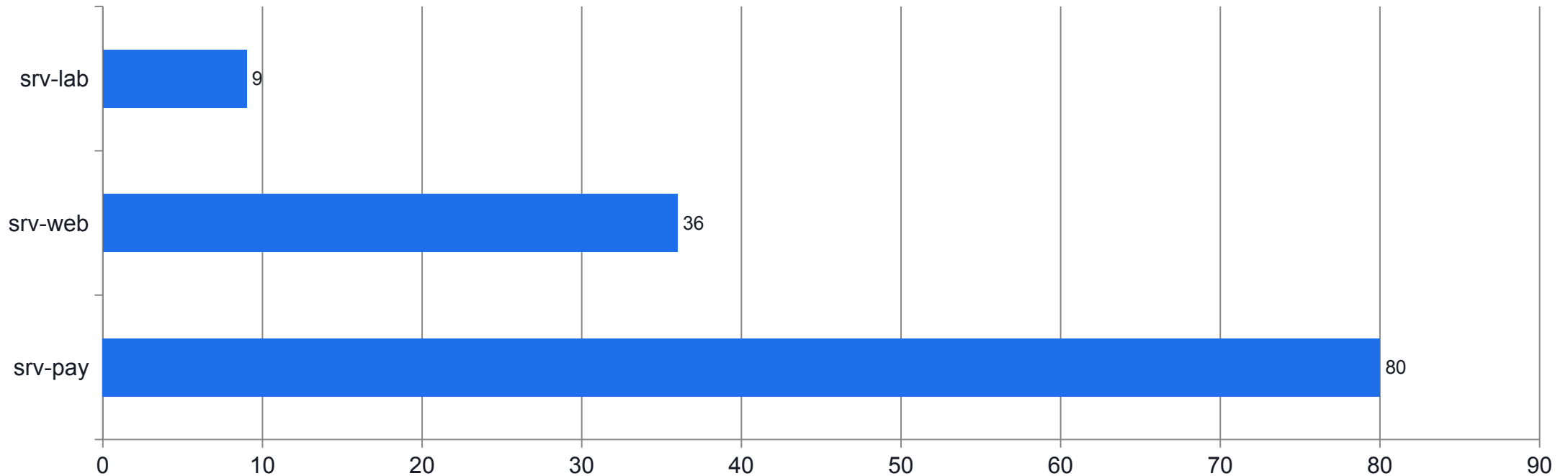
Python standard library
only.

Offline rule model; AI
review is separate.

Lab 1 | computed decisions

Record	Observed decision
srv-pay	ROLLBACK
srv-web	CONTINUE
srv-lab	CONTINUE

Lab 1 | evidence distribution



WHAT THE DATA SHOWS

Synthetic risk scores: srv-pay 80, srv-web 36, srv-lab 9. Business criticality and exposure alter severity-only ordering.

Lab 1 | test a changed condition

CONTROLLED CHANGE

Change srv-pay canary from 3.0 to 0.6. Its decision must change from ROLLBACK to CONTINUE while its risk score remains 80.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 1 | operational verification

DELIVERABLE

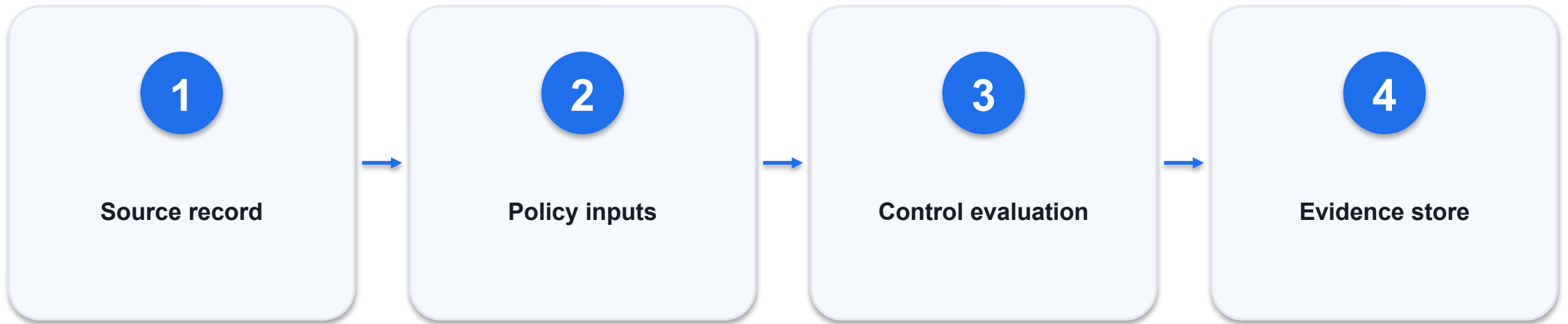
Ranked risk register and canary decision.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Evidence classification



MECHANISM

Classify a finding as observed, inferred or unsupported before accepting an AI summary.

Evidence classification | field contract

INSPECTABLE ARTIFACT

claim_id

evidence_ids

conclusion

confidence

INTERPRETATION

Claim C1 cites event E17 with a matching field.

Record the missing evidence identifier and corrected wording.

Evidence classification | counterexample

VALID CASE

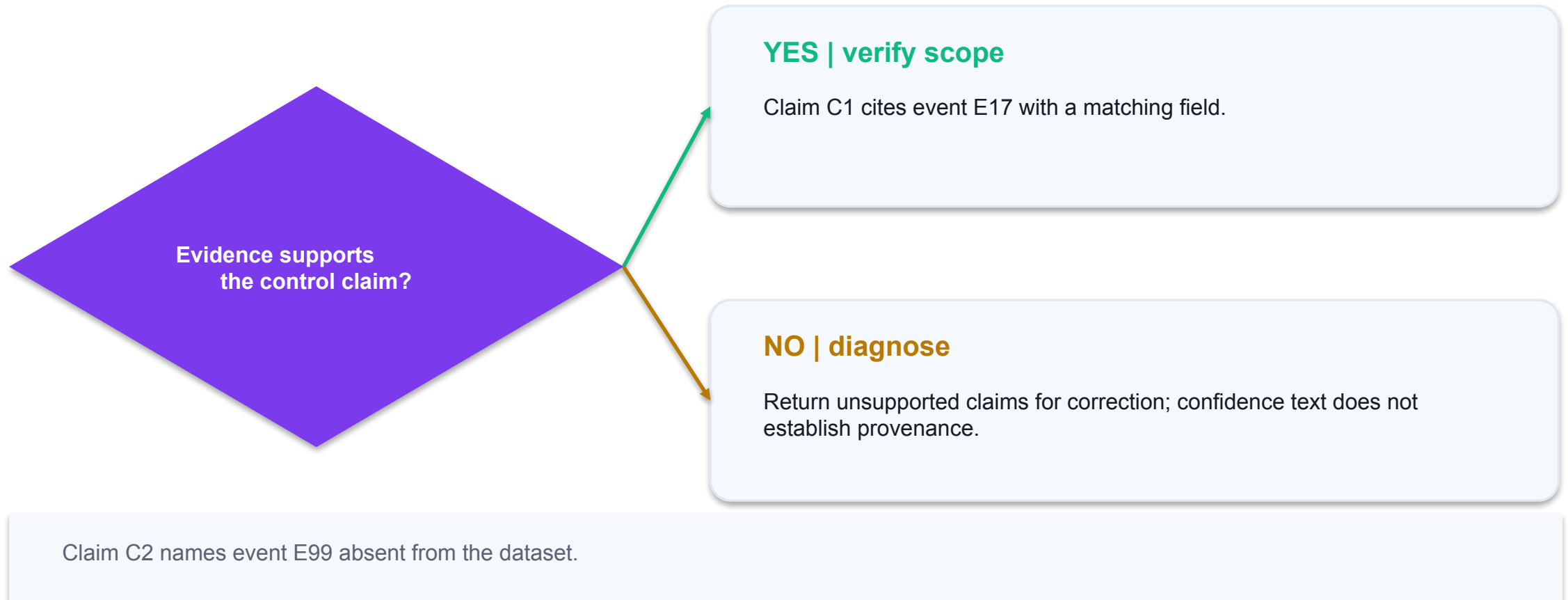
Claim C1 cites event E17 with a matching field.

FAILURE CASE

Claim C2 names event E99 absent from the dataset.

Classify a finding as observed, inferred or unsupported before accepting an AI summary.

Evidence classification | diagnosis



Original worked example; supplied references

Evidence classification | verification

EVIDENCE TO PRESERVE

Record the missing evidence identifier and corrected wording.

ACCEPTANCE BOUNDARY

Claim C1 cites event E17 with a matching field.

Return unsupported claims for correction;
confidence text does not establish provenance.

Evidence classification | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

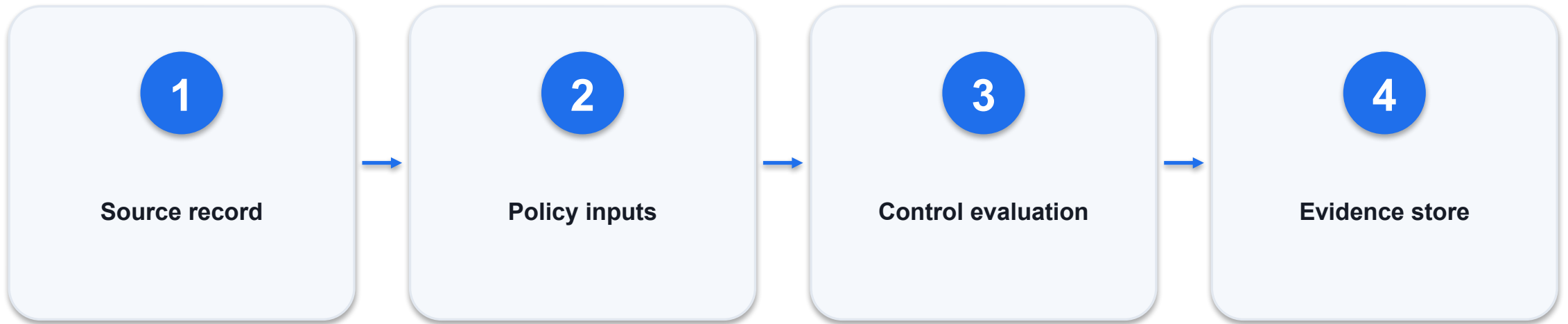
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Claim C2 names event E99 absent
from the dataset.

Resolve it using:
claim_id, evidence_ids, conclusion,
confidence

Telemetry redaction



MECHANISM

Replace personal identifiers before logs leave the approved security boundary.

Telemetry redaction | field contract

INSPECTABLE ARTIFACT

user_id

src_ip

token

tenant_id

INTERPRETATION

user_004 replaces a real address and token is removed.

Keep the redaction rule and a synthetic before/after example.

Telemetry redaction | counterexample

VALID CASE

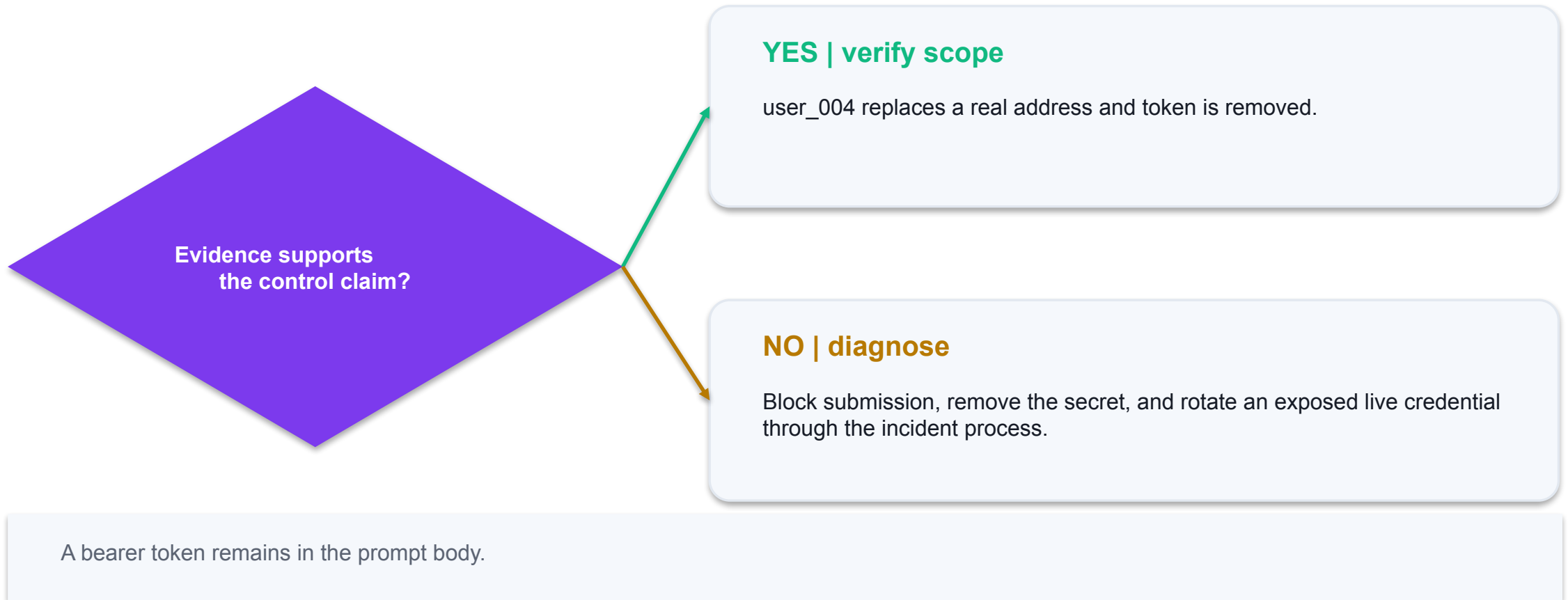
user_004 replaces a real address and token is removed.

FAILURE CASE

A bearer token remains in the prompt body.

Replace personal identifiers before logs leave the approved security boundary.

Telemetry redaction | diagnosis



Original worked example; supplied references

Telemetry redaction | verification

EVIDENCE TO PRESERVE

Keep the redaction rule and a synthetic before/after example.

ACCEPTANCE BOUNDARY

user_004 replaces a real address and token is removed.

Block submission, remove the secret, and rotate an exposed live credential through the incident process.

Telemetry redaction | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

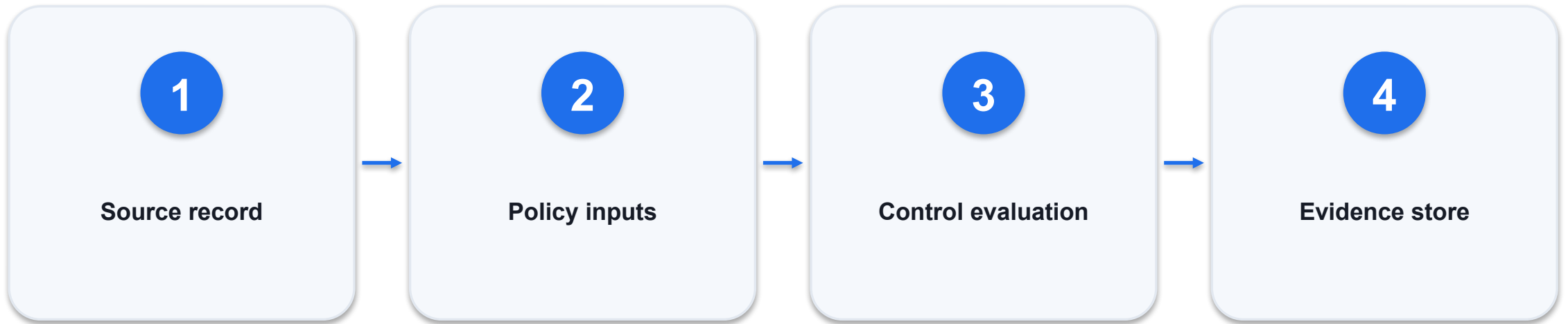
INTERPRETATION

Test this claim:
A bearer token remains in the
prompt body.

Resolve it using:
user_id, src_ip, token, tenant_id

Original worked example; supplied references

Control responsibility



MECHANISM

Assign each cloud control to a named operator and review its implementation evidence.

Control responsibility | field contract

INSPECTABLE ARTIFACT

control_id

accountable

evidence_uri

review_due

INTERPRETATION

CTRL-7 has an owner and a dated access review.

A control register must show evidence date and unresolved exceptions.

Control responsibility | counterexample

VALID CASE

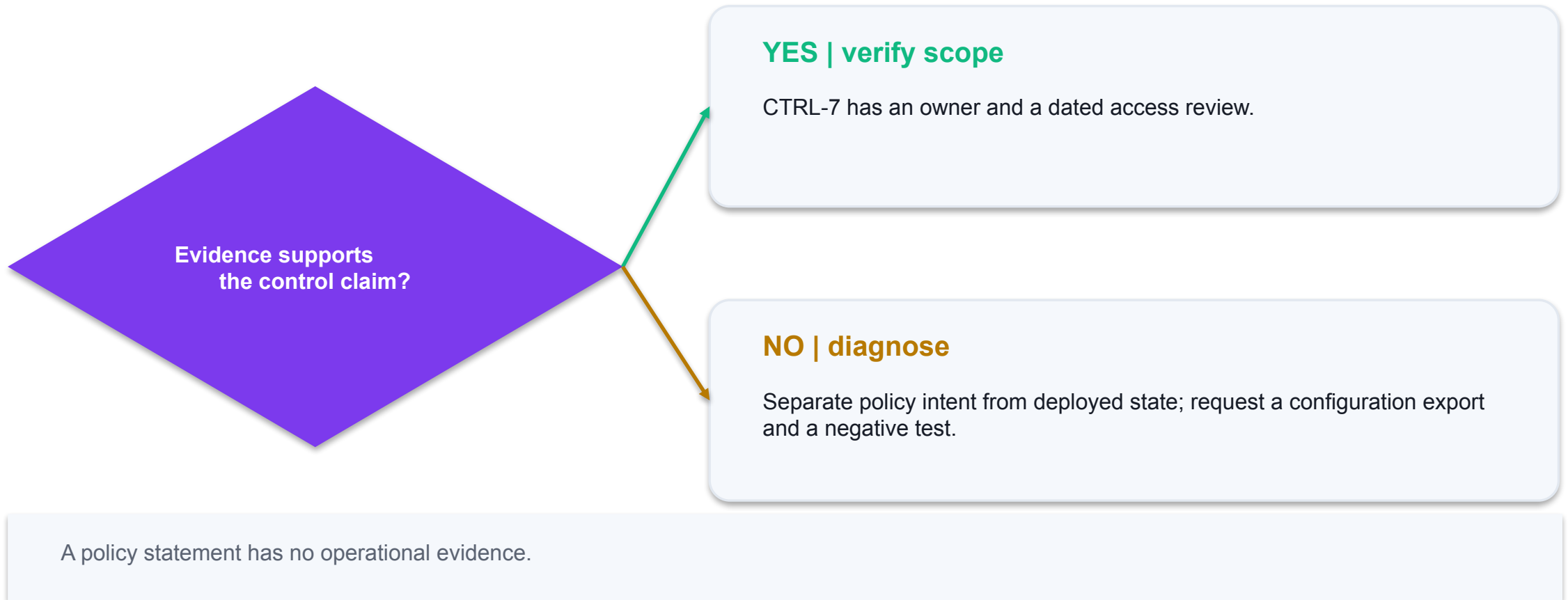
CTRL-7 has an owner and a dated access review.

FAILURE CASE

A policy statement has no operational evidence.

Assign each cloud control to a named operator and review its implementation evidence.

Control responsibility | diagnosis



Original worked example; supplied references

Control responsibility | verification

EVIDENCE TO PRESERVE

A control register must show evidence date and unresolved exceptions.

ACCEPTANCE BOUNDARY

CTRL-7 has an owner and a dated access review.

Separate policy intent from deployed state; request a configuration export and a negative test.

Control responsibility | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A policy statement has no
operational evidence.

Resolve it using:
control_id, accountable,
evidence_uri, review_due

Lab 2 | input schema

INSPECTABLE ARTIFACT

id: C1
evidence_id: E17
user: person01@example.test
token: SYNTHETIC-TOKEN
claim: E17 reports failure

INTERPRETATION

Synthetic fixture record.

Redacted evidence table and corrected ai claims.

The full dataset and instructions are in this lab's own folder.

Lab 2 | decision logic

```
valid={'E17','E18'}
for i,r in enumerate(rows):
    out.append({'id':r['id'],'user':'user_03d%i','token':['RE
MOVED'],'decision':'SUPPORTED_ID' if r['evidence_id'] in valid
else 'UNSUPPORTED_ID'})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

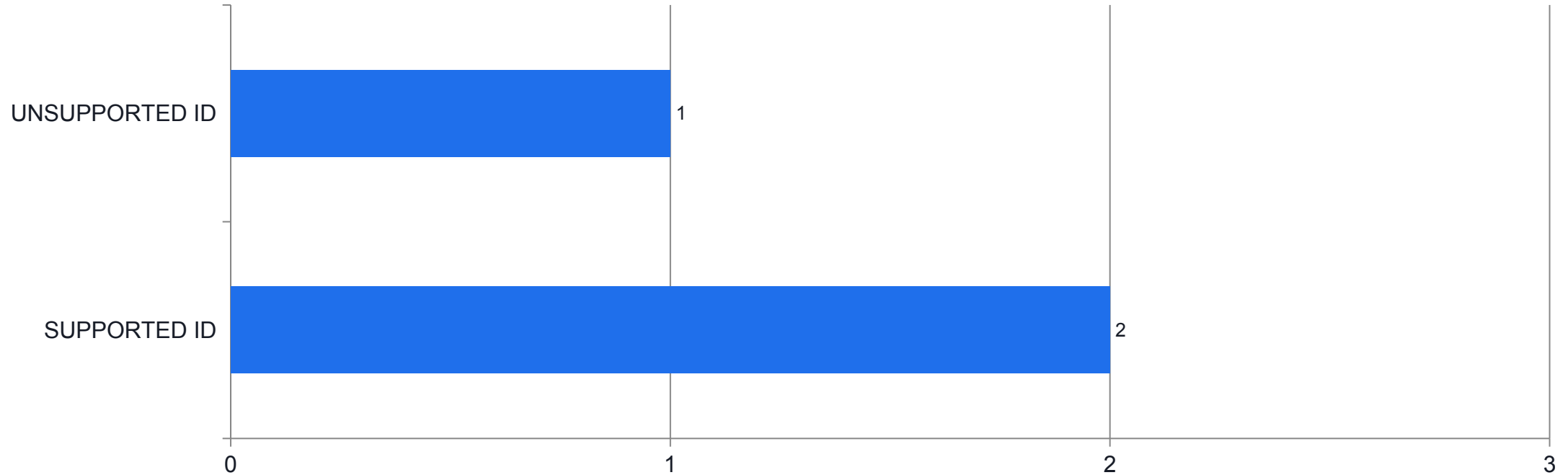
Offline rule model; AI
review is separate.

Lab 2 | computed decisions

Record	Observed decision
C1	SUPPORTED_ID
C2	UNSUPPORTED_ID
C3	SUPPORTED_ID

Original worked example; supplied references

Lab 2 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 2 | test a changed condition

CONTROLLED CHANGE

Change C2 evidence_id to E18. Identifier validation will pass, but the claim still does not prove compromise. Explain why matching an ID is necessary but insufficient.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 2 | operational verification

DELIVERABLE

Redacted evidence table and corrected ai claims.

Record scope, UTC time and approval state.

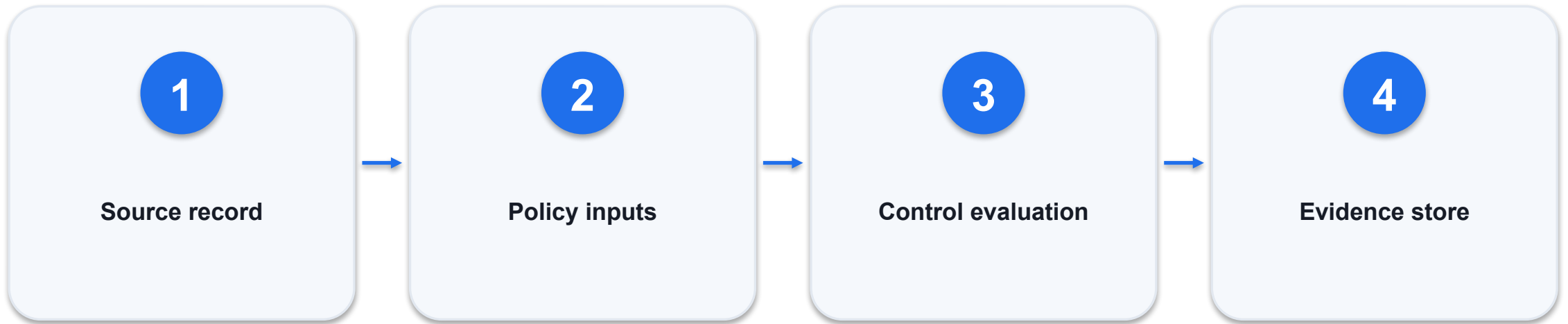
WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Tea break

15 minutes

RBAC scope inheritance



MECHANISM

Permissions at parent scope apply to child resources; additional Reader access does not reduce Contributor.

RBAC scope inheritance | field contract

INSPECTABLE ARTIFACT

principalId

roleDefinitionId

scope

INTERPRETATION

Reader at rg-sec provides read-only management access.

Preserve principal ID, full scope and inherited role list.

RBAC scope inheritance | counterexample

VALID CASE

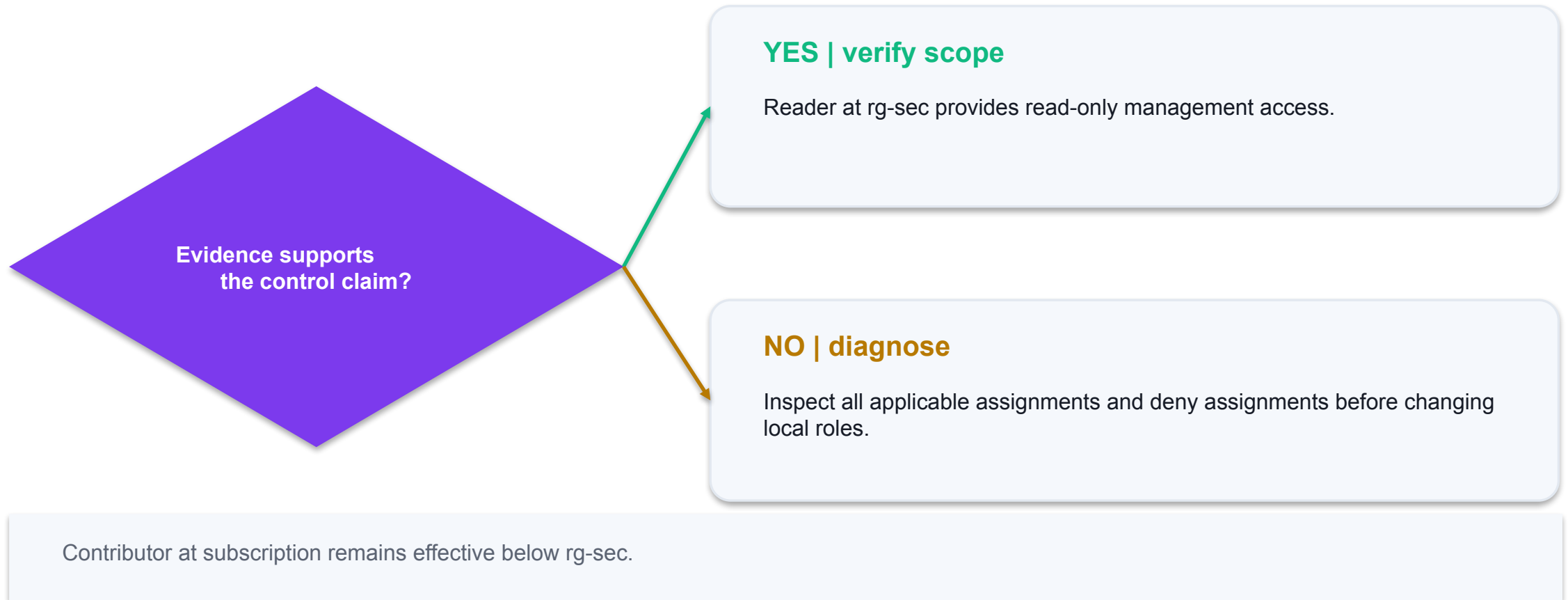
Reader at rg-sec provides read-only management access.

FAILURE CASE

Contributor at subscription remains effective below rg-sec.

Permissions at parent scope apply to child resources; additional Reader access does not reduce Contributor.

RBAC scope inheritance | diagnosis



Original worked example; supplied references

RBAC scope inheritance | verification

EVIDENCE TO PRESERVE

Preserve principal ID, full scope and inherited role list.

ACCEPTANCE BOUNDARY

Reader at rg-sec provides read-only management access.

Inspect all applicable assignments and deny assignments before changing local roles.

RBAC scope inheritance | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

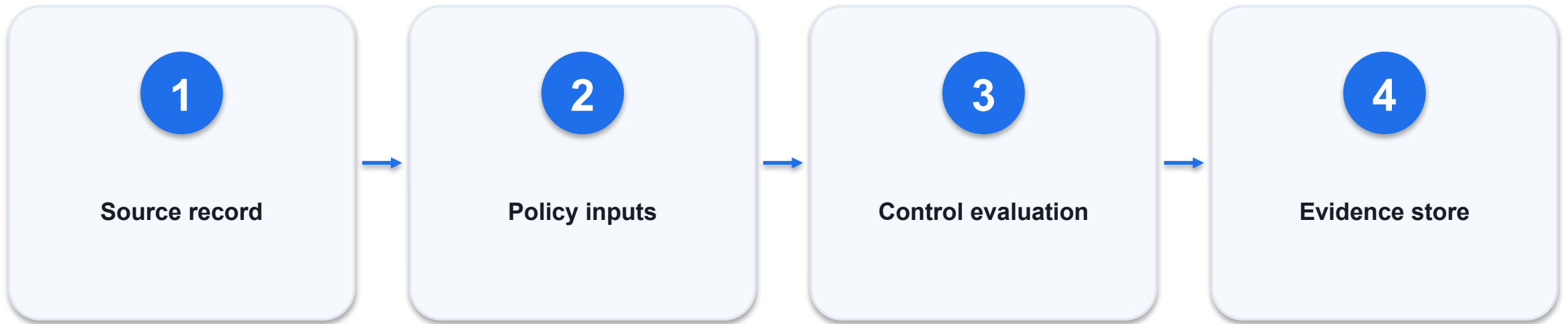
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Contributor at subscription remains
effective below rg-sec.

Resolve it using:
principalId, roleDefinitionId, scope

Custom role actions



MECHANISM

Management actions and data actions authorise different operations; subtracting NotActions is not a global deny.

Custom role actions | field contract

INSPECTABLE ARTIFACT

Actions

NotActions

DataActions

AssignableScopes

INTERPRETATION

A custom inventory role grants
Microsoft.Resources/subscriptions/
resourceGroups/read.

Compare allowed action strings
against the approved job duties.

Custom role actions | counterexample

VALID CASE

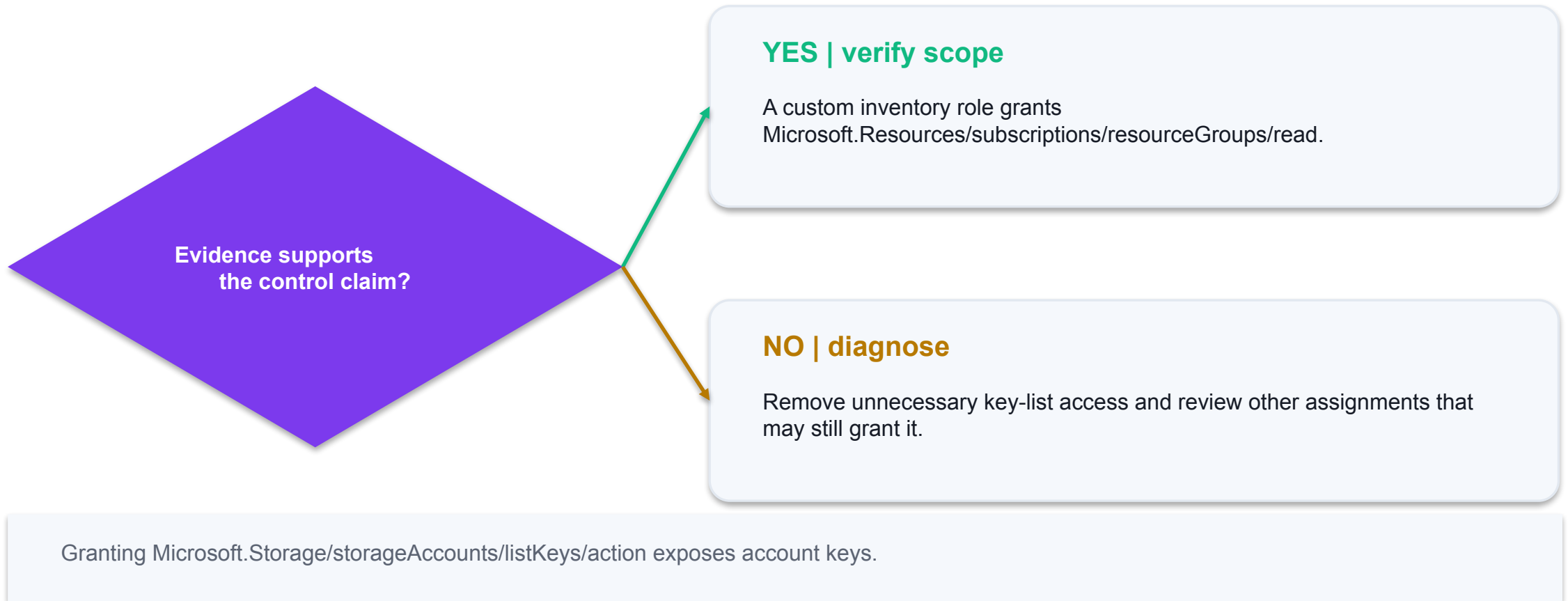
A custom inventory role grants
Microsoft.Resources/subscriptions/resourceGroups/read.

FAILURE CASE

Granting
Microsoft.Storage/storageAccounts/listKeys/action
exposes account keys.

Management actions and data actions authorise different operations; subtracting NotActions is not a global deny.

Custom role actions | diagnosis



Original worked example; supplied references

Custom role actions | verification

EVIDENCE TO PRESERVE

Compare allowed action strings against the approved job duties.

ACCEPTANCE BOUNDARY

A custom inventory role grants
Microsoft.Resources/subscriptions/resourceGroups/read.

Remove unnecessary key-list access and review other assignments that may still grant it.

Custom role actions | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:

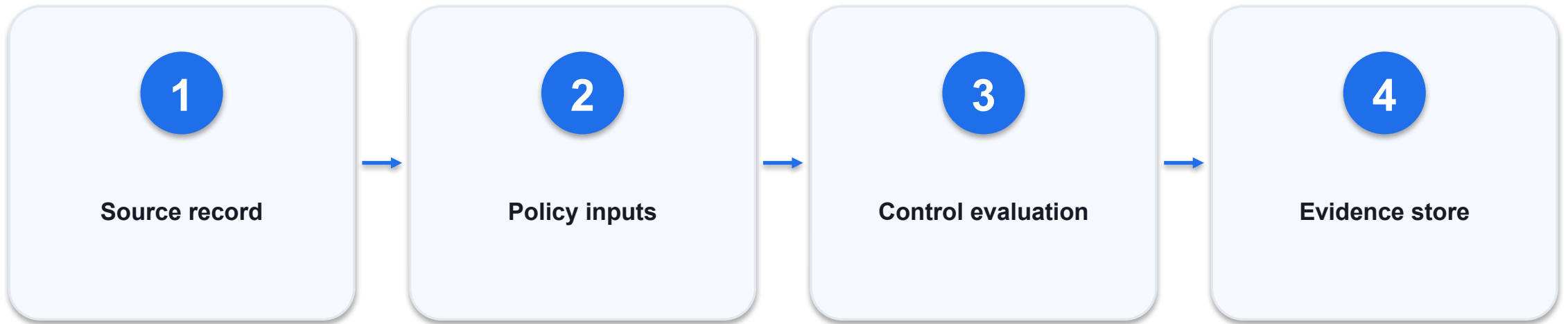
Granting

Microsoft.Storage/storageAccounts
/listKeys/action exposes account
keys.

Resolve it using:

Actions, NotActions, DataActions,
AssignableScopes

Privileged activation



MECHANISM

An eligible privileged role becomes active for an approved bounded interval.

Privileged activation | field contract

INSPECTABLE ARTIFACT

principal

role

justification

start_utc

end_utc

INTERPRETATION

An approved 30-minute activation expires at 10:30Z.

Record eligible versus active state, approver and actual expiry.

Privileged activation | counterexample

VALID CASE

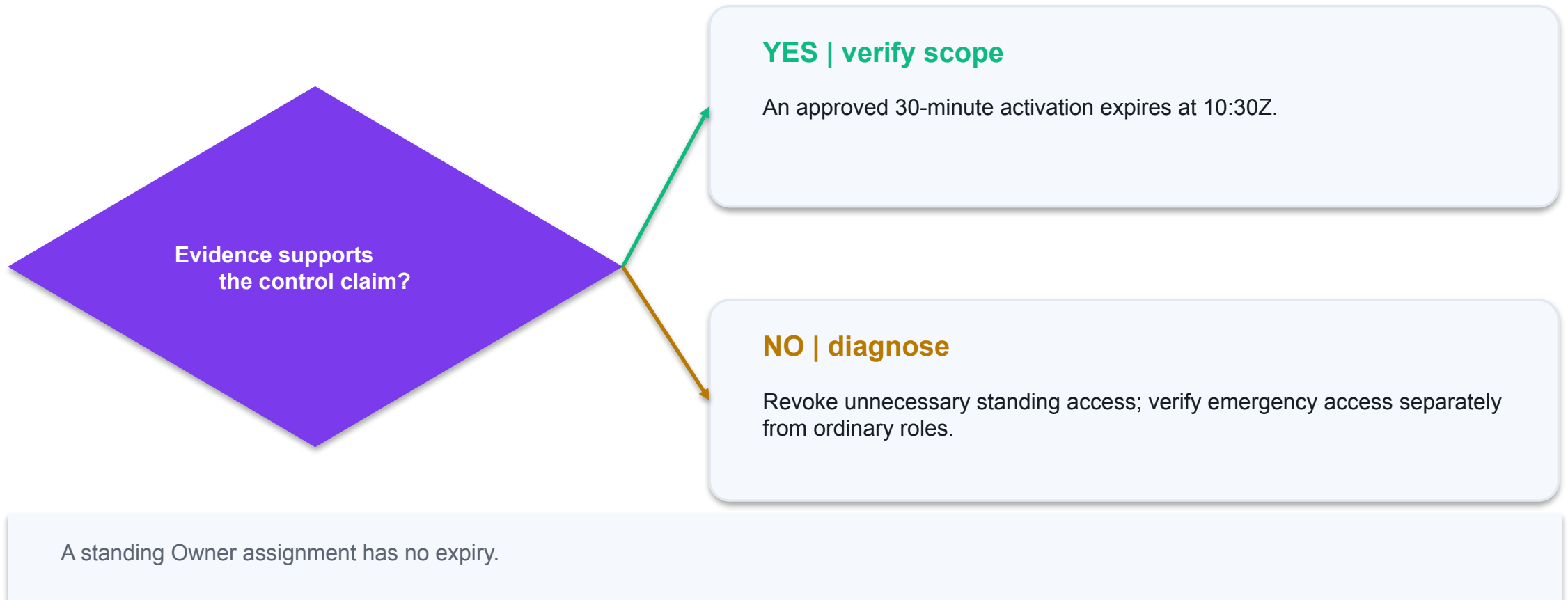
An approved 30-minute activation expires at 10:30Z.

FAILURE CASE

A standing Owner assignment has no expiry.

An eligible privileged role becomes active for an approved bounded interval.

Privileged activation | diagnosis



Original worked example; supplied references

Privileged activation | verification

EVIDENCE TO PRESERVE

Record eligible versus active state, approver and actual expiry.

ACCEPTANCE BOUNDARY

An approved 30-minute activation expires at 10:30Z.

Revoke unnecessary standing access; verify emergency access separately from ordinary roles.

Privileged activation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A standing Owner assignment has
no expiry.

Resolve it using:
principal, role, justification,
start_utc, end_utc

Lab 3 | input schema

INSPECTABLE ARTIFACT

id: u-read
roles: ['Reader']
scope: rg-sec
active_minutes: 0

INTERPRETATION

Synthetic fixture record.

Access matrix with a least-privilege change proposal.

The full dataset and instructions are in this lab's own folder.

Lab 3 | decision logic

```
for r in rows:
    broad='Owner' in r['roles'] or r['scope']=='subscription'
    out.append({'id':r['id'],'decision':'REVIEW_BROAD' if
    broad else 'SCOPED','minutes':r['active_minutes']})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

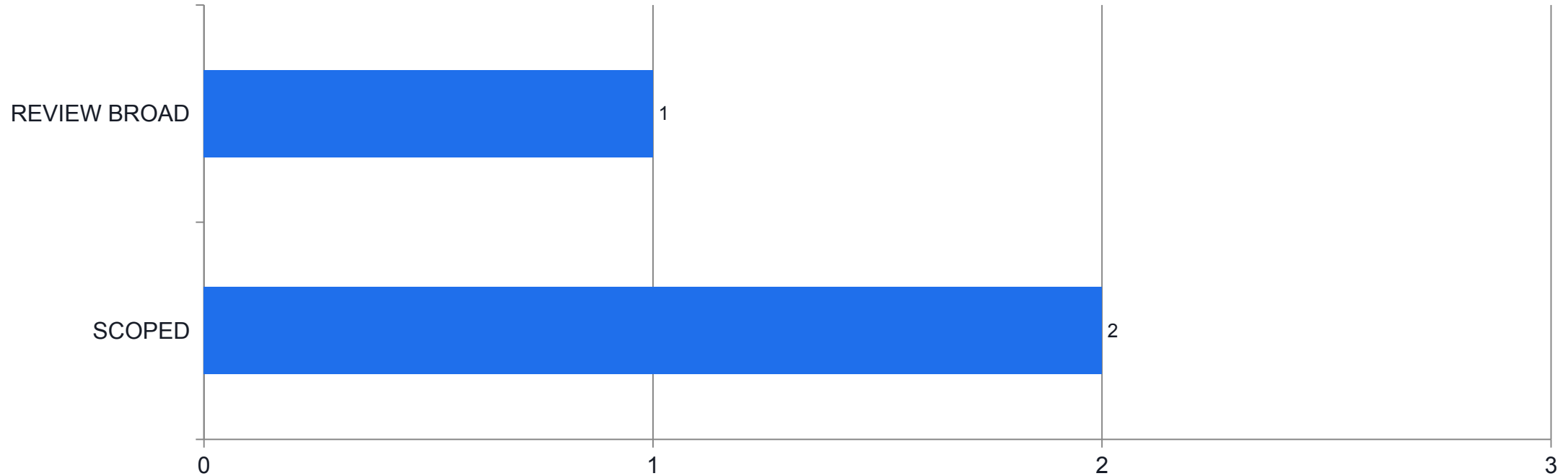
Offline rule model; AI
review is separate.

Lab 3 | computed decisions

Record	Observed decision
u-read	SCOPED
u-owner	REVIEW_BROAD
u-pim	SCOPED

Original worked example; supplied references

Lab 3 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 3 | test a changed condition

CONTROLLED CHANGE

Add Reader to u-owner. The result must remain REVIEW_BROAD because a narrower grant does not remove Owner.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 3 | operational verification

DELIVERABLE

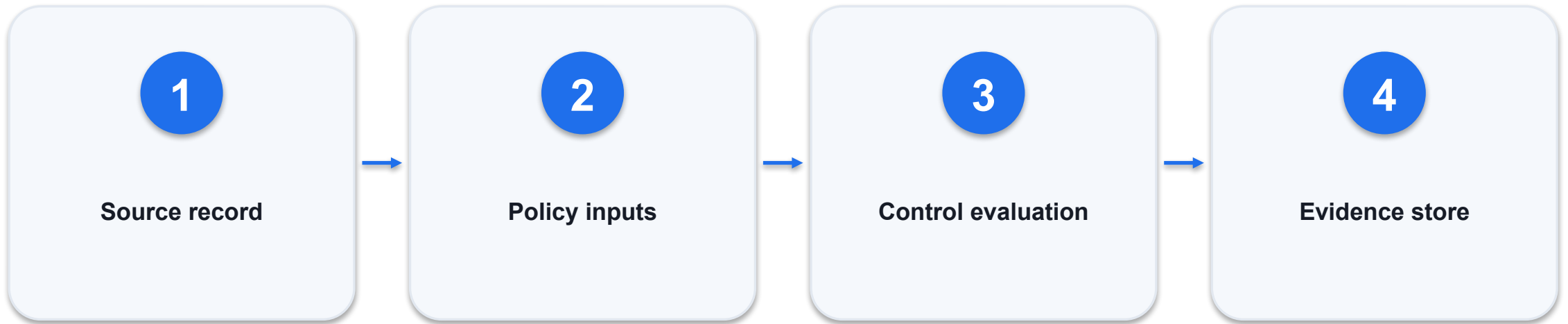
Access matrix with a least-privilege change proposal.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Conditional Access evaluation



MECHANISM

Report-only evaluates a policy without enforcing its access decision.

Conditional Access evaluation | field contract

INSPECTABLE ARTIFACT

state=enabledForReportingButNotEnforced

INTERPRETATION

An MFA policy records a would-block result for the test user.

Preserve policy mode and sign-in evaluation result, not only its name.

Conditional Access evaluation | counterexample

VALID CASE

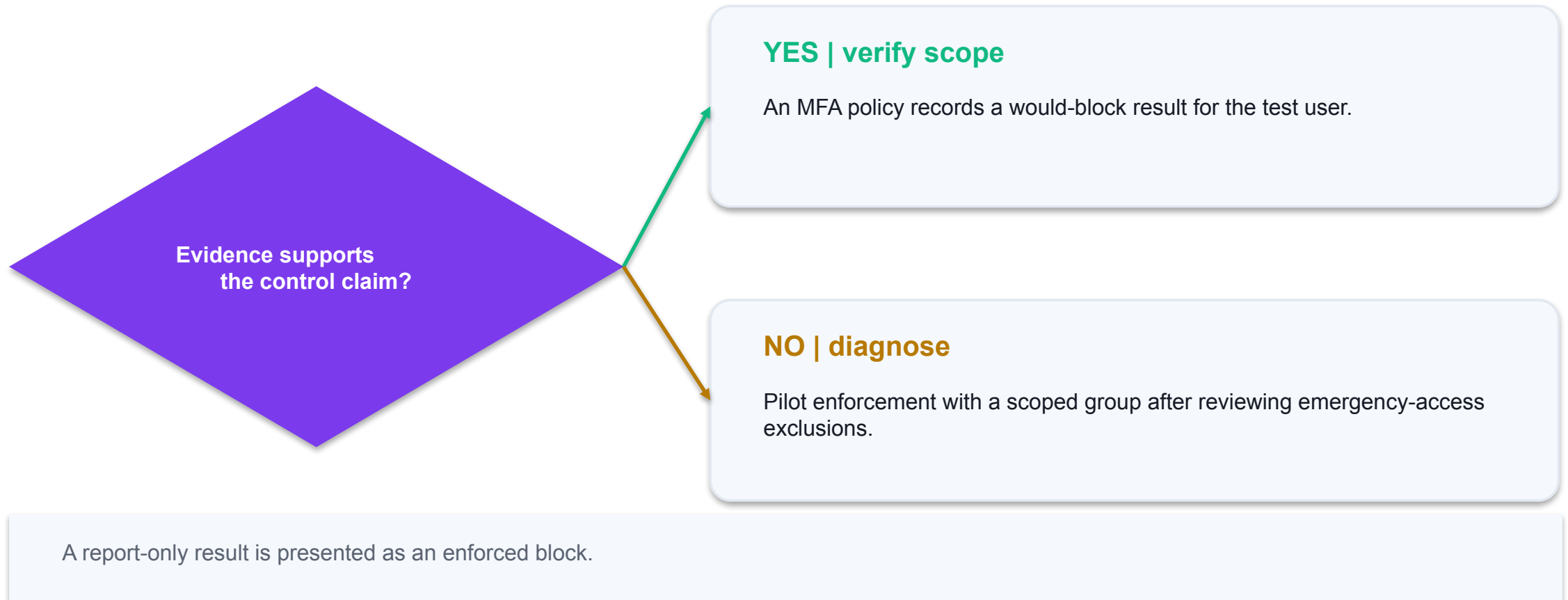
An MFA policy records a would-block result for the test user.

FAILURE CASE

A report-only result is presented as an enforced block.

Report-only evaluates a policy without enforcing its access decision.

Conditional Access evaluation | diagnosis



Original worked example; supplied references

Conditional Access evaluation | verification

EVIDENCE TO PRESERVE

Preserve policy mode and sign-in evaluation result, not only its name.

ACCEPTANCE BOUNDARY

An MFA policy records a would-block result for the test user.

Pilot enforcement with a scoped group after reviewing emergency-access exclusions.

Conditional Access evaluation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

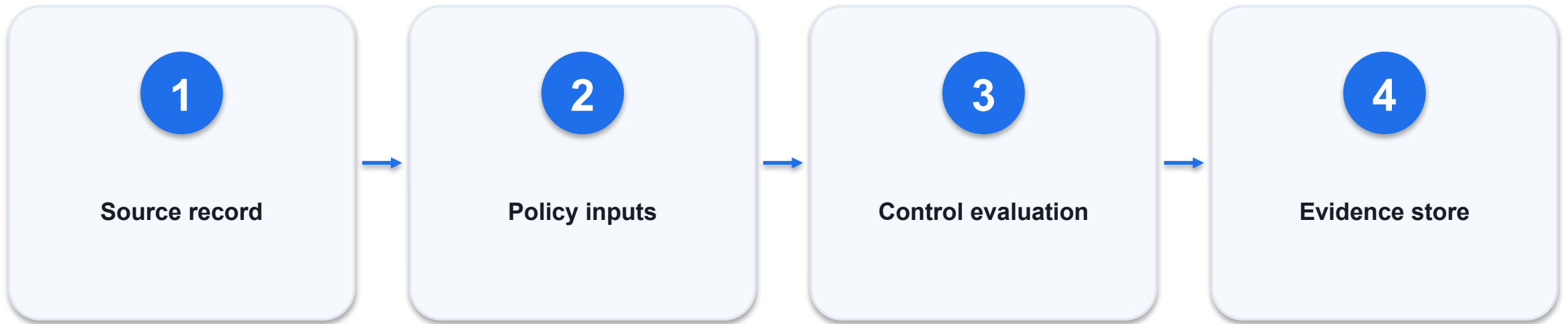
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A report-only result is presented as
an enforced block.

Resolve it using:
state=enabledForReportingButNot
Enforced

Managed identity token flow



MECHANISM

An Azure workload requests a token and the resource checks its audience and assigned permissions.

Managed identity token flow | field contract

INSPECTABLE ARTIFACT

principal_id

token_audience

resource_scope

INTERPRETATION

A workload identity has the required role on its target resource.

Record identity object ID, target resource and redacted error code.

Managed identity token flow | counterexample

VALID CASE

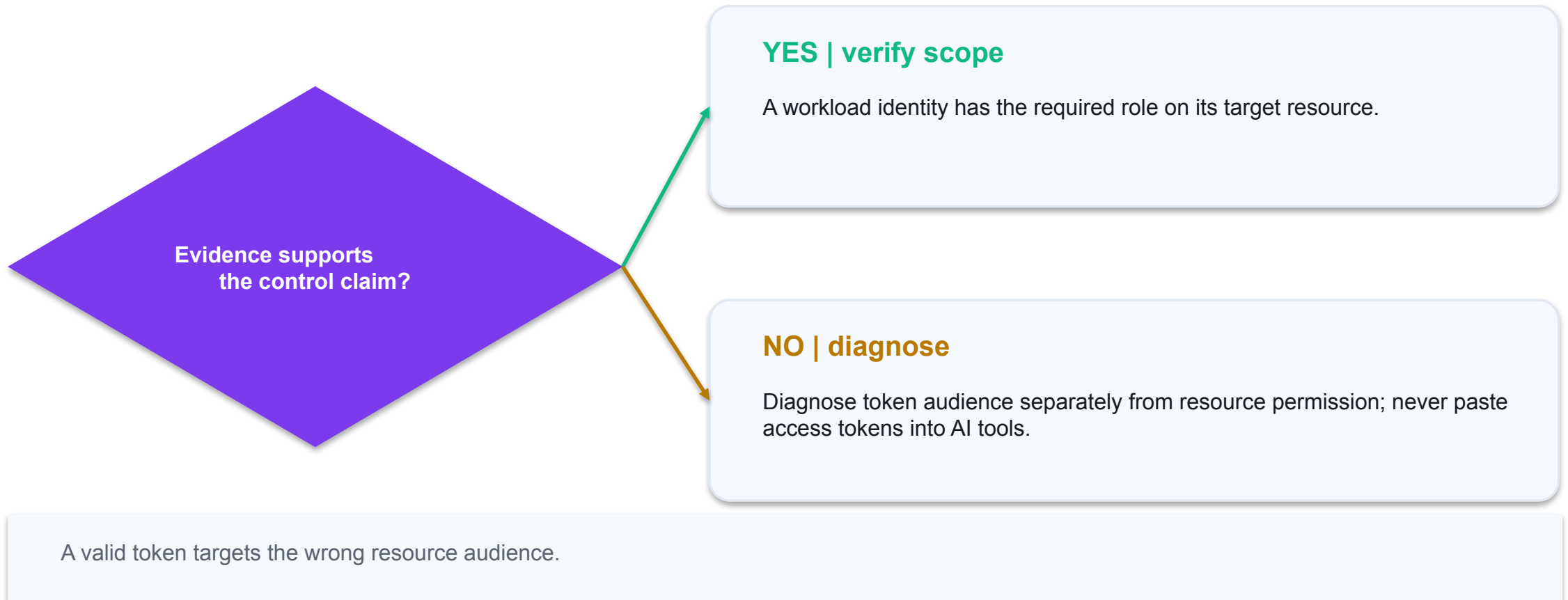
A workload identity has the required role on its target resource.

FAILURE CASE

A valid token targets the wrong resource audience.

An Azure workload requests a token and the resource checks its audience and assigned permissions.

Managed identity token flow | diagnosis



Original worked example; supplied references

Managed identity token flow | verification

EVIDENCE TO PRESERVE

Record identity object ID, target resource and redacted error code.

ACCEPTANCE BOUNDARY

A workload identity has the required role on its target resource.

Diagnose token audience separately from resource permission; never paste access tokens into AI tools.

Managed identity token flow | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

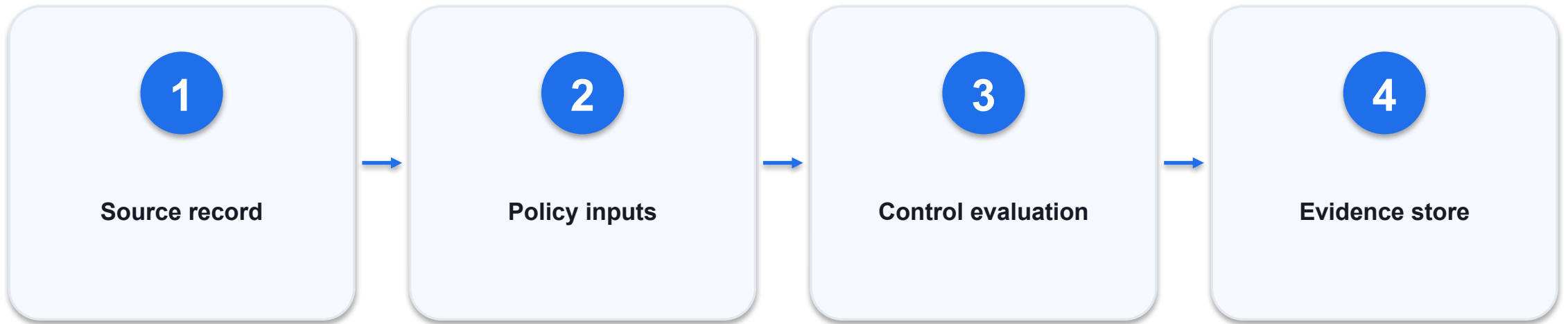
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A valid token targets the wrong
resource audience.

Resolve it using:
principal_id, token_audience,
resource_scope

Application consent boundaries



MECHANISM

API permission consent and Azure resource RBAC are separate grants.

Application consent boundaries | field contract

INSPECTABLE ARTIFACT

app_id

service_principal_id

permission_type

consent

INTERPRETATION

An app has only the delegated scope needed for the signed-in user.

Capture permission type, consenting authority and intended data boundary.

Application consent boundaries | counterexample

VALID CASE

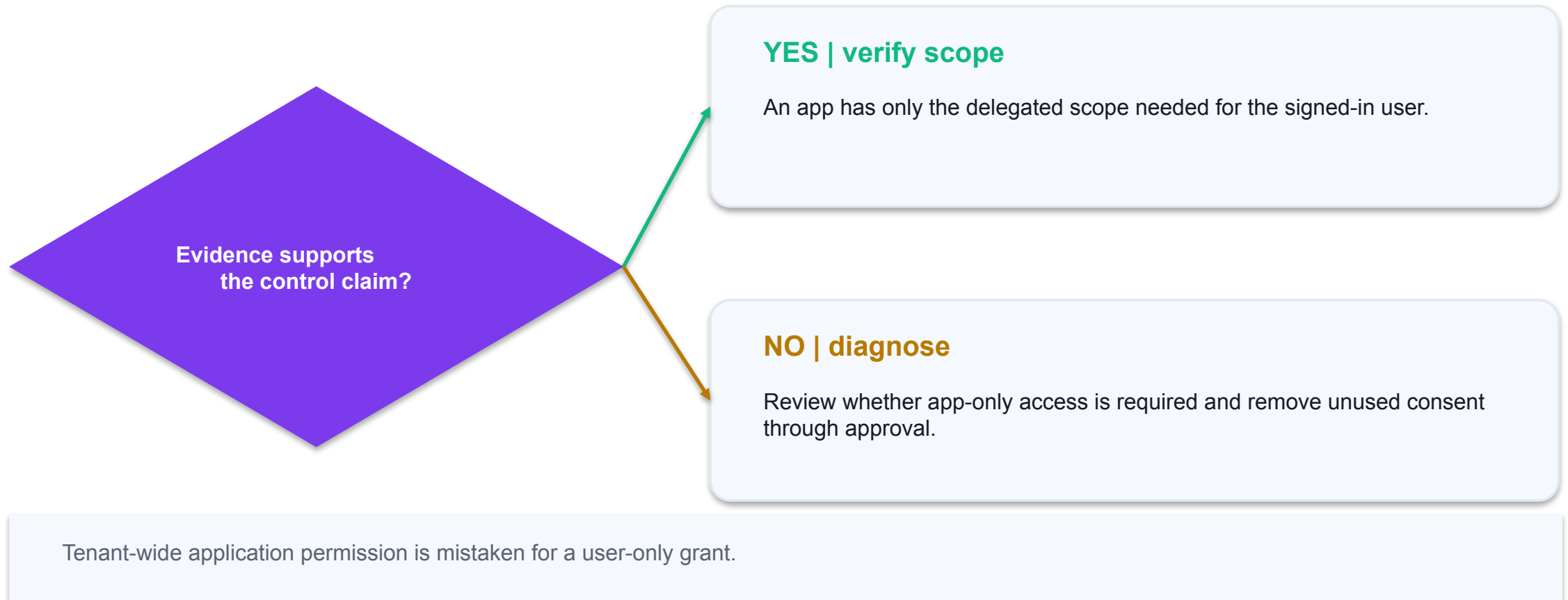
An app has only the delegated scope needed for the signed-in user.

FAILURE CASE

Tenant-wide application permission is mistaken for a user-only grant.

API permission consent and Azure resource RBAC are separate grants.

Application consent boundaries | diagnosis



Original worked example; supplied references

Application consent boundaries | verification

EVIDENCE TO PRESERVE

Capture permission type, consenting authority and intended data boundary.

ACCEPTANCE BOUNDARY

An app has only the delegated scope needed for the signed-in user.

Review whether app-only access is required and remove unused consent through approval.

Application consent boundaries | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Tenant-wide application permission
is mistaken for a user-only grant.

Resolve it using:
app_id, service_principal_id,
permission_type, consent

Lab 4 | input schema

INSPECTABLE ARTIFACT

id: signin-1
mode: report-only
requires_mfa: True
mfa: False
audience_ok: True

INTERPRETATION

Synthetic fixture record.

Policy-mode comparison and
workload identity diagnosis.

The full dataset and instructions
are in this lab's own folder.

Lab 4 | decision logic

```
for r in rows:
    fail=r['requires_mfa'] and not r['mfa']
    decision='WRONG_AUDIENCE' if not r['audience_ok'] else
('WOULD_BLOCK' if fail and r['mode']=='report-only' else
('BLOCK' if fail else 'ALLOW'))
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

Offline rule model; AI
review is separate.

Lab 4 | computed decisions

Record	Observed decision
signin-1	WOULD_BLOCK
signin-2	BLOCK
signin-3	WRONG_AUDIENCE

Original worked example; supplied references

Lab 4 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 4 | test a changed condition

CONTROLLED CHANGE

Set signin-1 mfa to true. The result changes to ALLOW in this simplified model; explain why this does not prove a real Conditional Access deployment.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 4 | operational verification

DELIVERABLE

Policy-mode comparison and workload identity diagnosis.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Day 1 | evidence review

EXHIBITS

Labs 1–4: compare baseline, changed-input result and source checksum.

REVIEW DECISION

Which claim is supported by a record? Which control still needs operational verification? Cite the exact artifact and uncertainty.

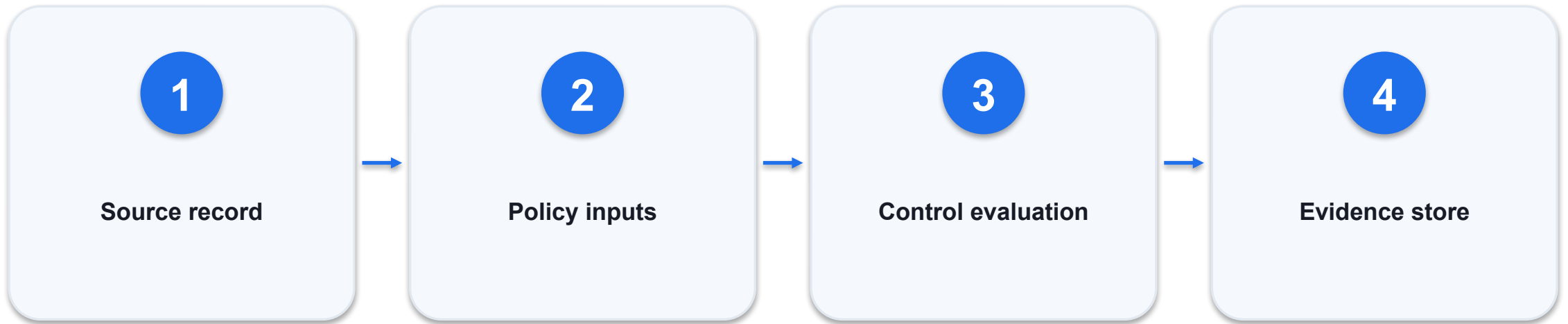
DAY 2

Network and data protection

Technical mechanisms, evidence and diagnostic cases



NSG rule precedence



MECHANISM

Evaluate matching rules by ascending priority; the first match decides a new flow.

NSG rule precedence | field contract

INSPECTABLE ARTIFACT

priority

source

destination

port

access

INTERPRETATION

Priority 100 allows web to app TCP 443.

Record the five-tuple, matched rule and direction.

NSG rule precedence | counterexample

VALID CASE

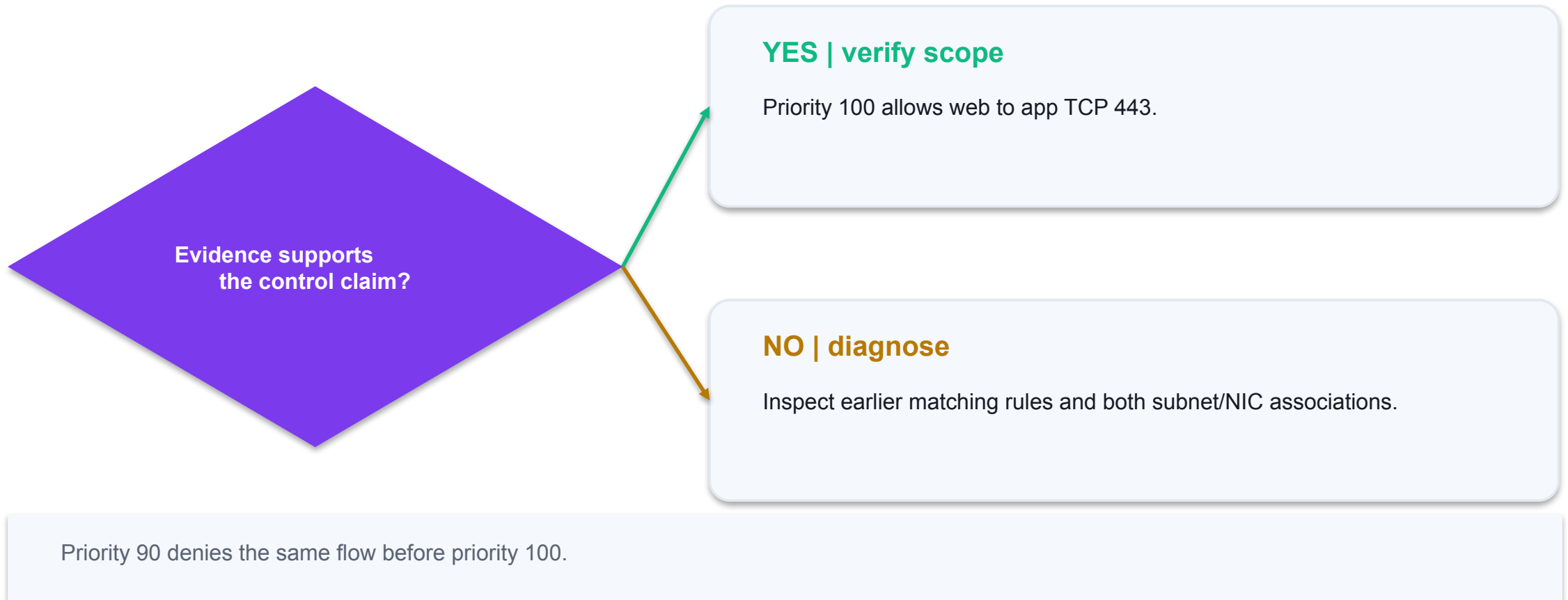
Priority 100 allows web to app TCP 443.

FAILURE CASE

Priority 90 denies the same flow before priority 100.

Evaluate matching rules by ascending priority; the first match decides a new flow.

NSG rule precedence | diagnosis



Original worked example; supplied references

NSG rule precedence | verification

EVIDENCE TO PRESERVE

Record the five-tuple, matched rule and direction.

ACCEPTANCE BOUNDARY

Priority 100 allows web to app TCP 443.

Inspect earlier matching rules and both subnet/NIC associations.

NSG rule precedence | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

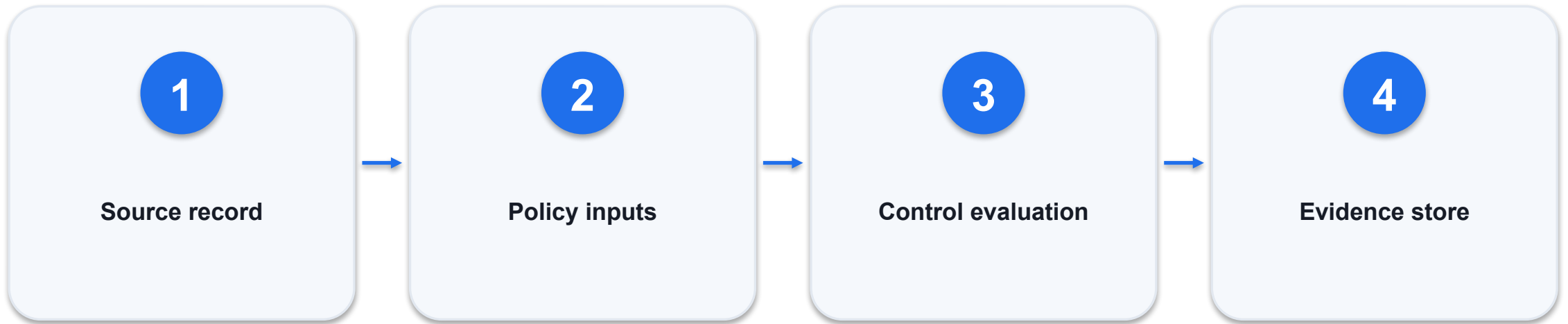
Test this claim:

Priority 90 denies the same flow
before priority 100.

Resolve it using:

priority, source, destination, port,
access

ASG membership



MECHANISM

An application security group groups NICs so rules can express workload roles.

ASG membership | field contract

INSPECTABLE ARTIFACT

source_asg=web

destination_asg=app

port=443

INTERPRETATION

The app NIC belongs to the app group used by the rule.

Export NIC membership and the effective rule result.

ASG membership | counterexample

VALID CASE

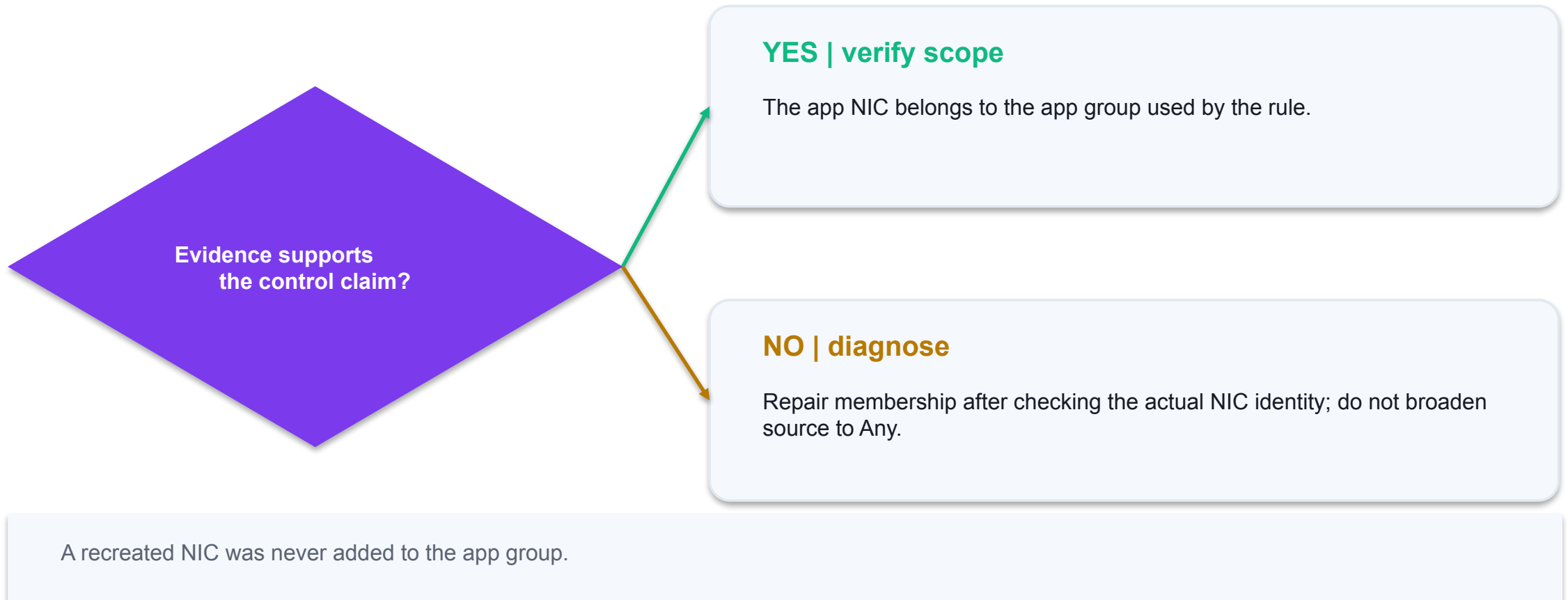
The app NIC belongs to the app group used by the rule.

FAILURE CASE

A recreated NIC was never added to the app group.

An application security group groups NICs so rules can express workload roles.

ASG membership | diagnosis



Original worked example; supplied references

ASG membership | verification

EVIDENCE TO PRESERVE

Export NIC membership and the effective rule result.

ACCEPTANCE BOUNDARY

The app NIC belongs to the app group used by the rule.

Repair membership after checking the actual NIC identity; do not broaden source to Any.

ASG membership | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

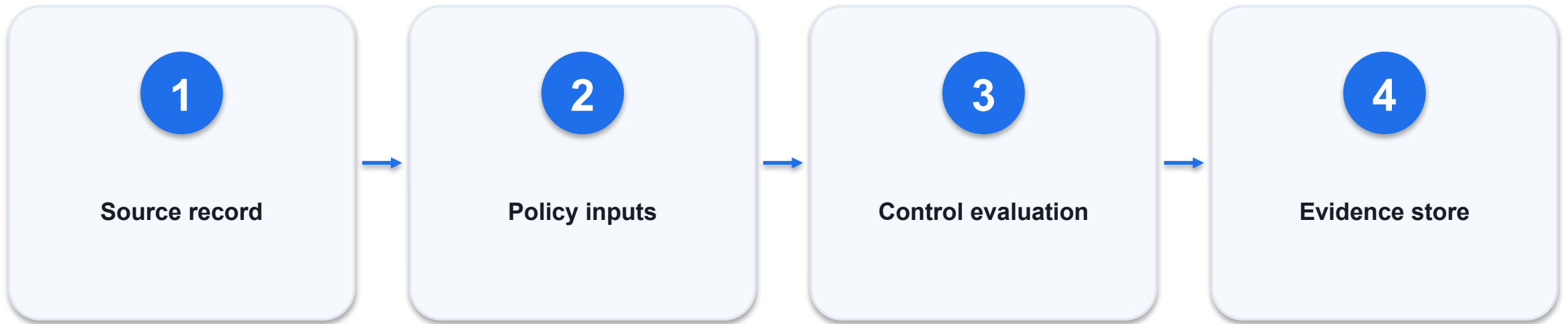
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A recreated NIC was never added
to the app group.

Resolve it using:
source_asg=web,
destination_asg=app, port=443

Flow verification



MECHANISM

A permitted packet requires matching route, filter and listening service state.

Flow verification | field contract

INSPECTABLE ARTIFACT

src_ip

dst_ip

dst_port

direction

protocol

INTERPRETATION

TCP 443 is allowed and the application listens on 443.

Keep filter result plus an application connection test.

Flow verification | counterexample

VALID CASE

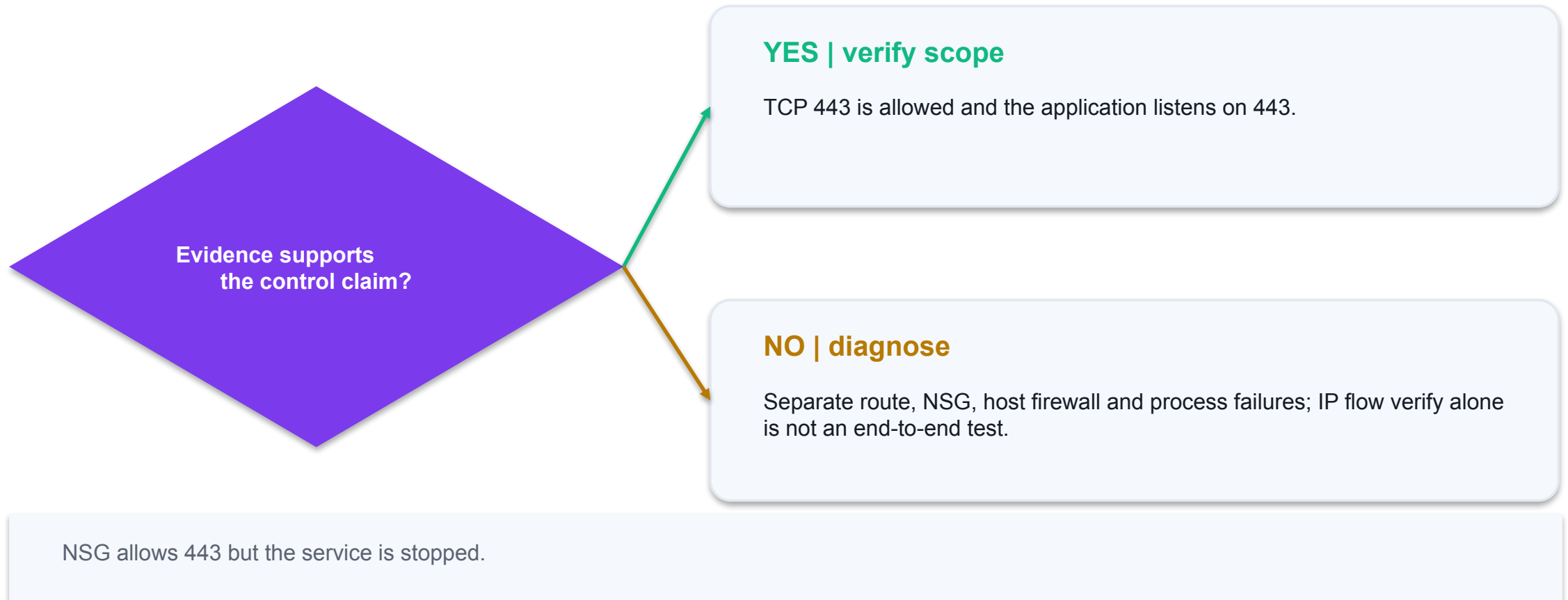
TCP 443 is allowed and the application listens on 443.

FAILURE CASE

NSG allows 443 but the service is stopped.

A permitted packet requires matching route, filter and listening service state.

Flow verification | diagnosis



Original worked example; supplied references

Flow verification | verification

EVIDENCE TO PRESERVE

Keep filter result plus an application connection test.

ACCEPTANCE BOUNDARY

TCP 443 is allowed and the application listens on 443.

Separate route, NSG, host firewall and process failures; IP flow verify alone is not an end-to-end test.

Flow verification | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
NSG allows 443 but the service is stopped.

Resolve it using:
src_ip, dst_ip, dst_port, direction, protocol

Lab 5 | input schema

INSPECTABLE ARTIFACT

id: flow-1
src: web
dst: app
port: 443

INTERPRETATION

Synthetic fixture record.

Flow decision table with least-privilege rules.

The full dataset and instructions are in this lab's own folder.

Lab 5 | decision logic

```
rules=[(100,'web','app',443,'ALLOW'),(110,'app','data',1433,'A
ALLOW')]
for r in rows:
    match=next((x for x in sorted(rules) if
(r['src'],r['dst'],r['port'])==x[1:4]),None)
    out.append({'id':r['id'],'decision':match[4] if match else
'DENY','rule':match[0] if match else 'default'})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

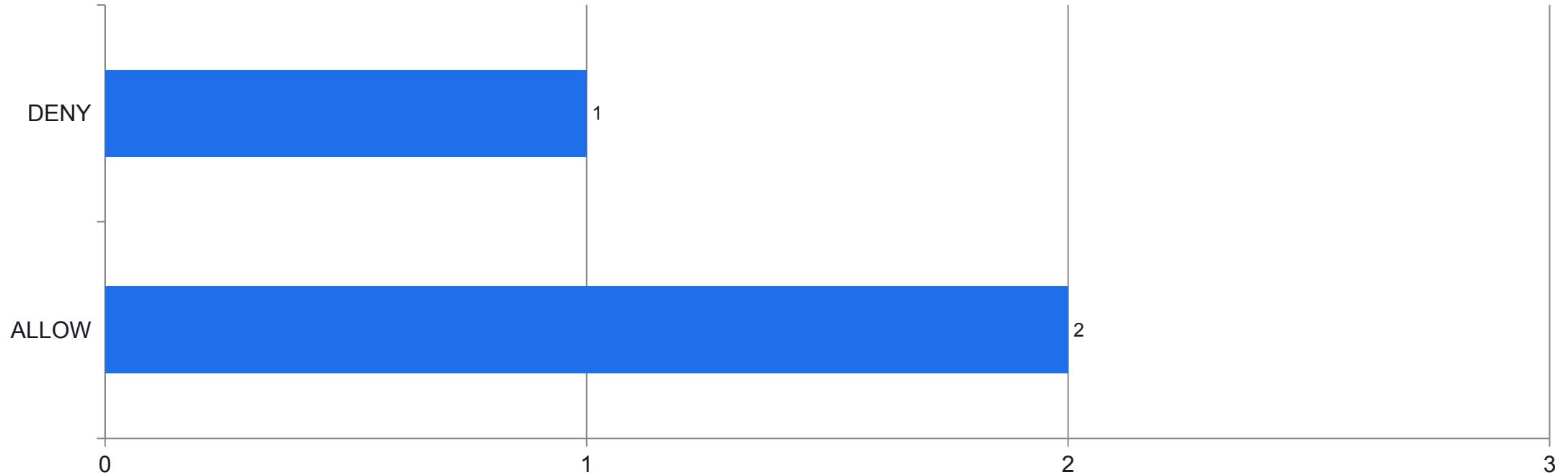
Offline rule model; AI
review is separate.

Lab 5 | computed decisions

Record	Observed decision
flow-1	ALLOW
flow-2	DENY
flow-3	ALLOW

Original worked example; supplied references

Lab 5 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 5 | test a changed condition

CONTROLLED CHANGE

Change flow-1 port to 8443. It must be denied. Explain the exact rule needed if the application legitimately moves to 8443; do not allow every port.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 5 | operational verification

DELIVERABLE

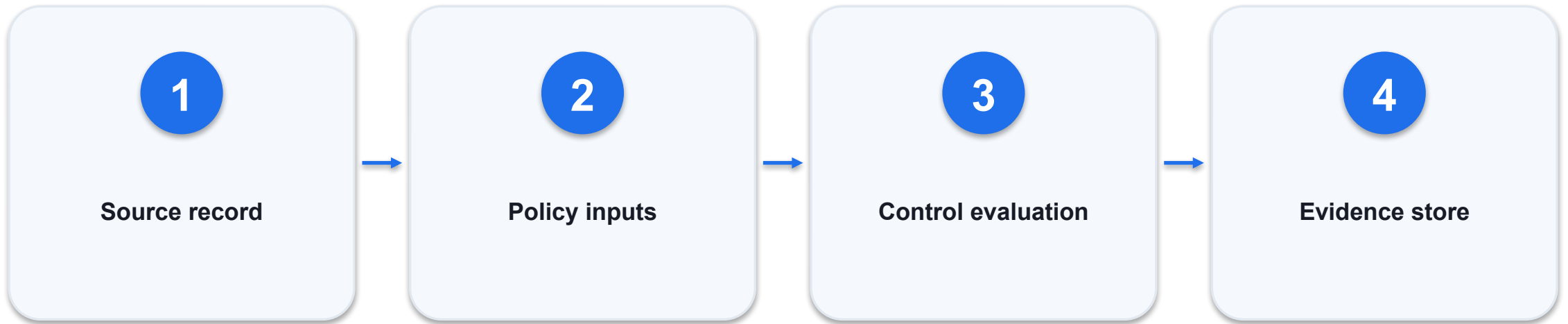
Flow decision table with least-privilege rules.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Firewall and WAF boundaries



MECHANISM

Firewall controls network/application egress; WAF inspects HTTP application requests.

Firewall and WAF boundaries | field contract

INSPECTABLE ARTIFACT

layer

source

destination

host

request_path

INTERPRETATION

WAF blocks a disallowed request at the web edge.

Show the traffic path and which layer makes each decision.

Firewall and WAF boundaries | counterexample

VALID CASE

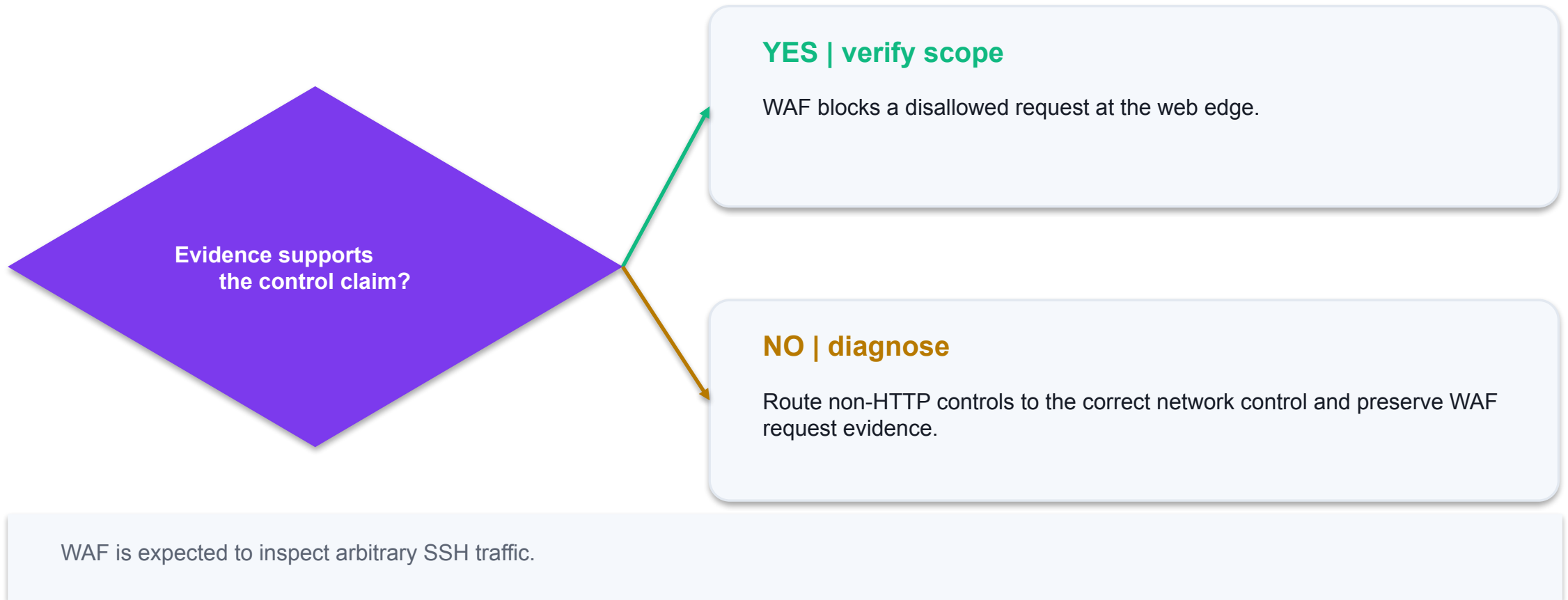
WAF blocks a disallowed request at the web edge.

FAILURE CASE

WAF is expected to inspect arbitrary SSH traffic.

Firewall controls network/application egress; WAF inspects HTTP application requests.

Firewall and WAF boundaries | diagnosis



Original worked example; supplied references

Firewall and WAF boundaries | verification

EVIDENCE TO PRESERVE

Show the traffic path and which layer makes each decision.

ACCEPTANCE BOUNDARY

WAF blocks a disallowed request at the web edge.

Route non-HTTP controls to the correct network control and preserve WAF request evidence.

Firewall and WAF boundaries | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

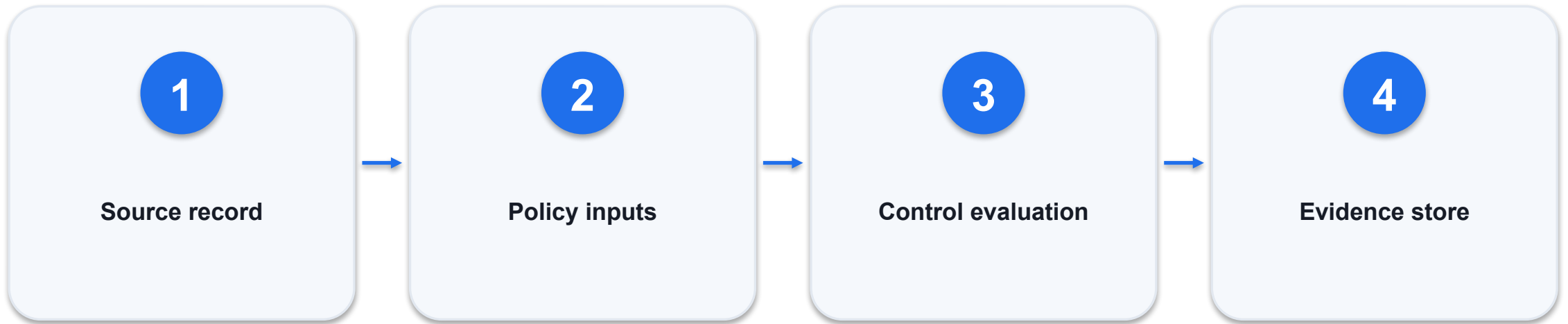
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
WAF is expected to inspect
arbitrary SSH traffic.

Resolve it using:
layer, source, destination, host,
request_path

Private endpoint resolution



MECHANISM

Private DNS resolves a service name to the endpoint NIC private address.

Private endpoint resolution | field contract

INSPECTABLE ARTIFACT

fqdn

resolved_ip

endpoint_ip

public_access

INTERPRETATION

The service resolves to 10.10.3.5 from the training VNet.

Record DNS output and endpoint approval state; endpoint creation alone is insufficient.

Private endpoint resolution | counterexample

VALID CASE

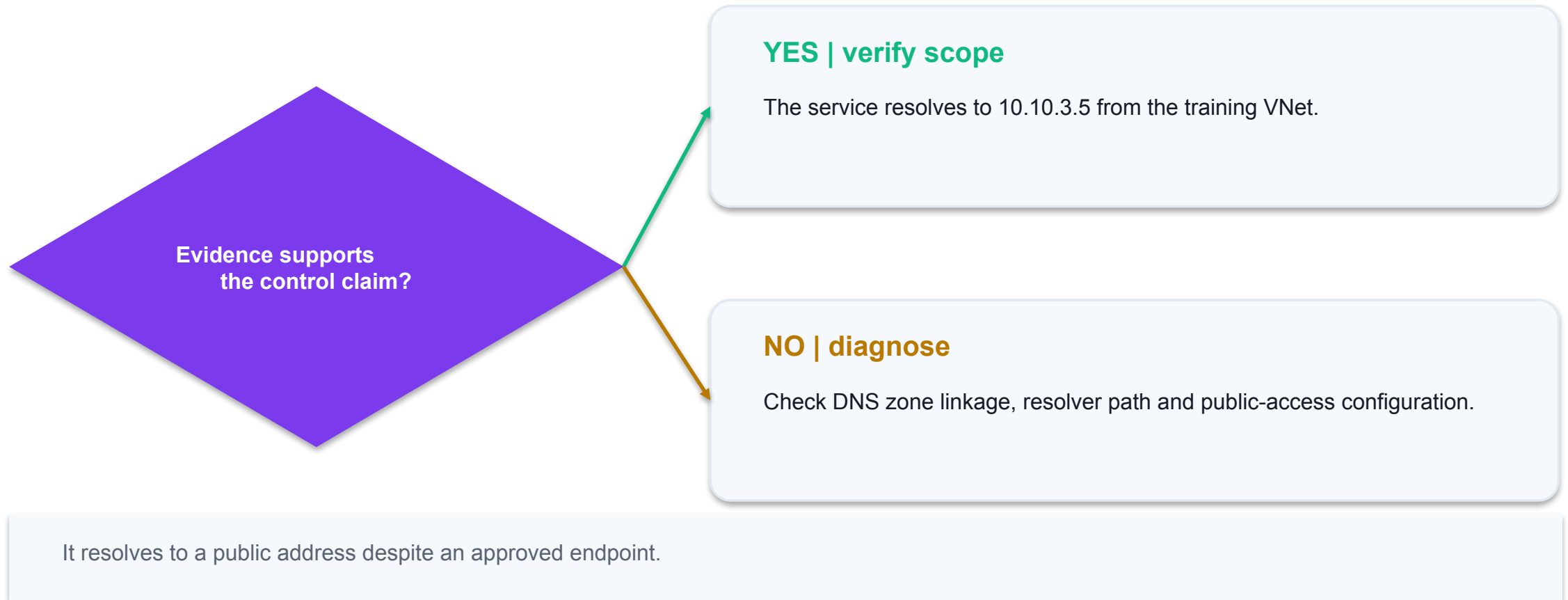
The service resolves to 10.10.3.5 from the training VNet.

FAILURE CASE

It resolves to a public address despite an approved endpoint.

Private DNS resolves a service name to the endpoint NIC private address.

Private endpoint resolution | diagnosis



Original worked example; supplied references

Private endpoint resolution | verification

EVIDENCE TO PRESERVE

Record DNS output and endpoint approval state; endpoint creation alone is insufficient.

ACCEPTANCE BOUNDARY

The service resolves to 10.10.3.5 from the training VNet.

Check DNS zone linkage, resolver path and public-access configuration.

Private endpoint resolution | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

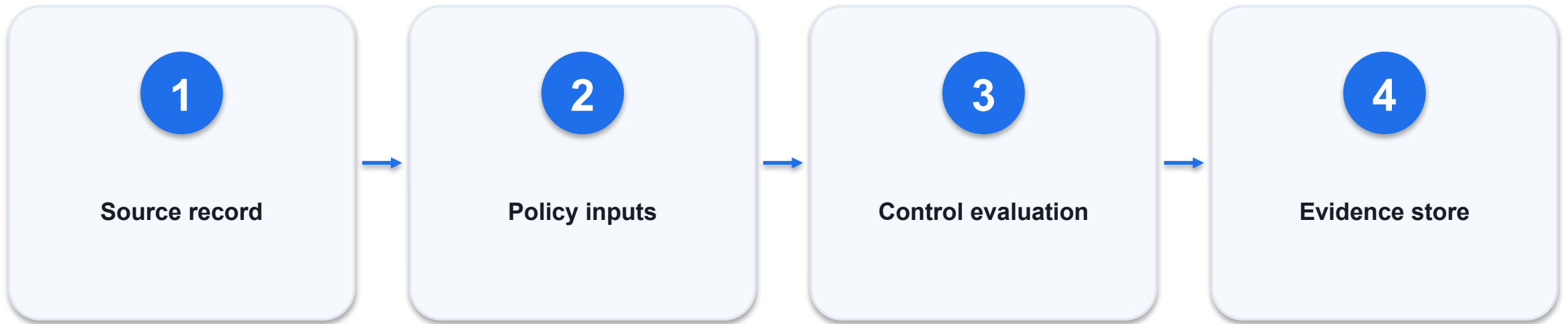
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
It resolves to a public address
despite an approved endpoint.

Resolve it using:
fqdn, resolved_ip, endpoint_ip,
public_access

Egress allowlists



MECHANISM

The gateway authorises a destination independently of an AI agent's requested action.

Egress allowlists | field contract

INSPECTABLE ARTIFACT

tool

host

port

approved_destination

INTERPRETATION

A report goes to
reports.example.test on port 443.

Log destination, policy result and
correlation ID without exporting
content.

Egress allowlists | counterexample

VALID CASE

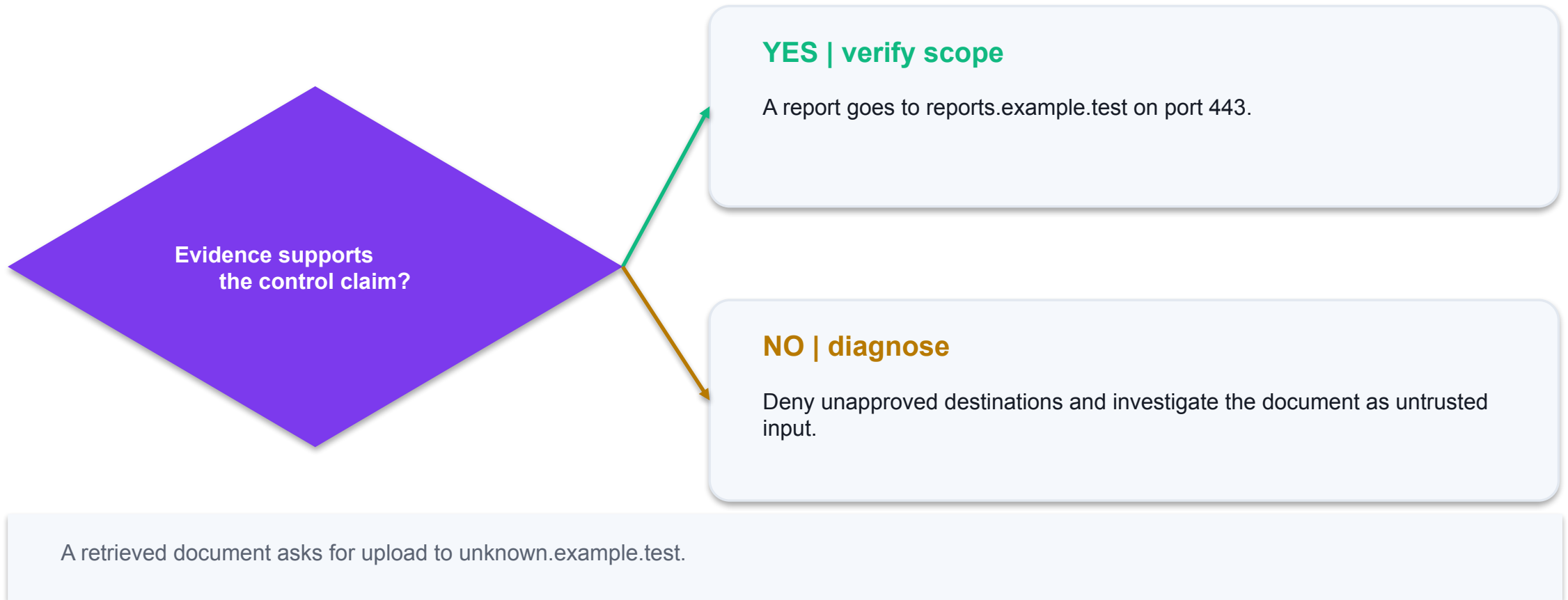
A report goes to reports.example.test on port 443.

FAILURE CASE

A retrieved document asks for upload to unknown.example.test.

The gateway authorises a destination independently of an AI agent's requested action.

Egress allowlists | diagnosis



Original worked example; supplied references

Egress allowlists | verification

EVIDENCE TO PRESERVE

Log destination, policy result and correlation ID without exporting content.

ACCEPTANCE BOUNDARY

A report goes to reports.example.test on port 443.

Deny unapproved destinations and investigate the document as untrusted input.

Egress allowlists | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A retrieved document asks for
upload to unknown.example.test.

Resolve it using:
tool, host, port,
approved_destination

Original worked example; supplied references

Lab 6 | input schema

INSPECTABLE ARTIFACT

```
id: storage-a  
dns_ip: 10.10.3.5  
endpoint_ip: 10.10.3.5  
public_access: False
```

INTERPRETATION

Synthetic fixture record.

Private-access diagnosis and traffic-layer diagram.

The full dataset and instructions are in this lab's own folder.

Lab 6 | decision logic

```
for r in rows:
    decision='DNS_MISMATCH' if r['dns_ip']!=r['endpoint_ip']
    else ('PUBLIC_PATH_REMAINS' if r['public_access'] else
    'PRIVATE_CONFIG')
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

Offline rule model; AI
review is separate.

Lab 6 | computed decisions

Record	Observed decision
storage-a	PRIVATE_CONFIG
storage-b	DNS_MISMATCH
storage-c	PUBLIC_PATH_REMAINS

Original worked example; supplied references

Lab 6 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 6 | test a changed condition

CONTROLLED CHANGE

Correct storage-b dns_ip to 10.10.3.6. Its result becomes PRIVATE_CONFIG, but list the real connection and authentication tests still required.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 6 | operational verification

DELIVERABLE

Private-access diagnosis and traffic-layer diagram.

Record scope, UTC time and approval state.

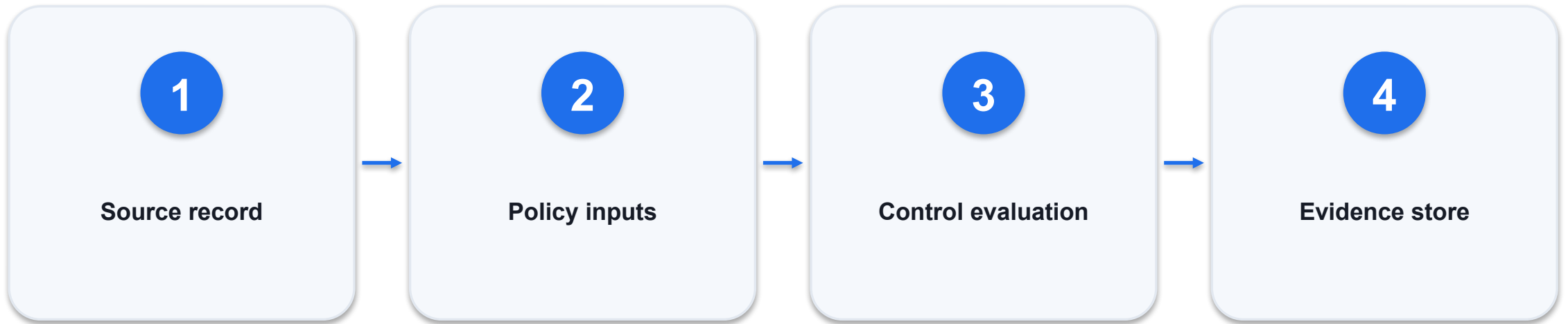
WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Tea break

15 minutes

Bastion access path



MECHANISM

A managed jump path can remove direct public administrative exposure on a VM.

Bastion access path | field contract

INSPECTABLE ARTIFACT

vm_public_ip

admin_port

bastion_path

INTERPRETATION

The VM has no public IP and uses the approved Bastion path.

Capture NIC public IP state and effective inbound rules.

Bastion access path | counterexample

VALID CASE

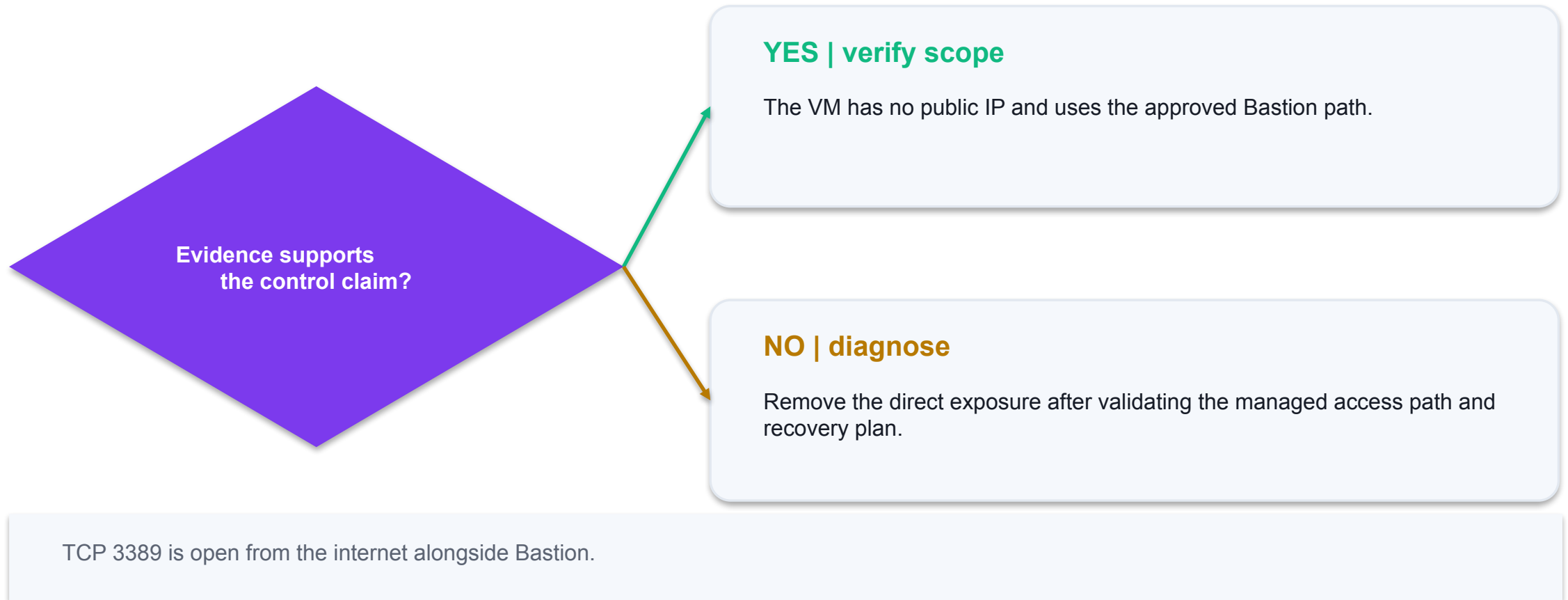
The VM has no public IP and uses the approved Bastion path.

FAILURE CASE

TCP 3389 is open from the internet alongside Bastion.

A managed jump path can remove direct public administrative exposure on a VM.

Bastion access path | diagnosis



Original worked example; supplied references

Bastion access path | verification

EVIDENCE TO PRESERVE

Capture NIC public IP state and effective inbound rules.

ACCEPTANCE BOUNDARY

The VM has no public IP and uses the approved Bastion path.

Remove the direct exposure after validating the managed access path and recovery plan.

Bastion access path | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

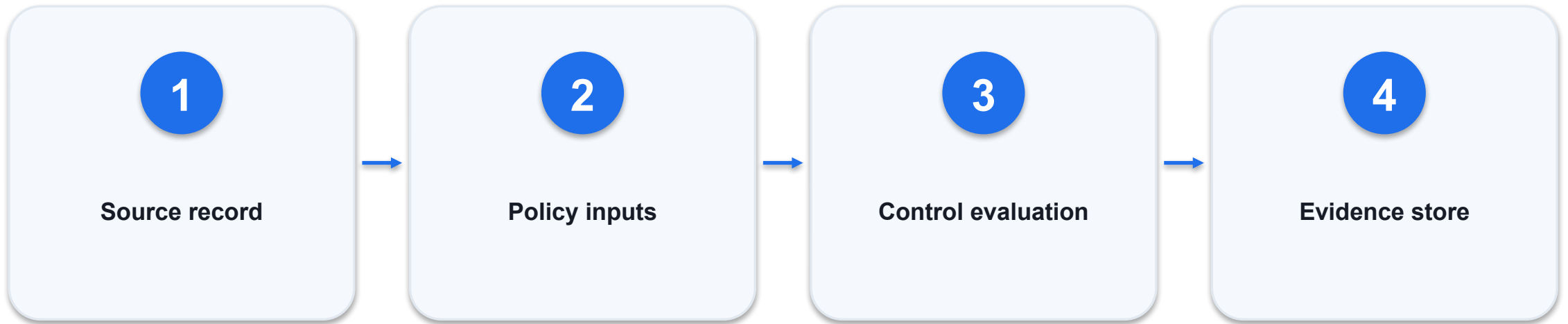
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
TCP 3389 is open from the internet
alongside Bastion.

Resolve it using:
vm_public_ip, admin_port,
bastion_path

Just in time administration



MECHANISM

Time-limited access narrows source and duration for administrative ports.

Just in time administration | field contract

INSPECTABLE ARTIFACT

source_cidr

port

requested_minutes

expiry

INTERPRETATION

One approved source opens port 22 for 30 minutes.

Keep request, approval, start, expiry and post-expiry denial evidence.

Just in time administration | counterexample

VALID CASE

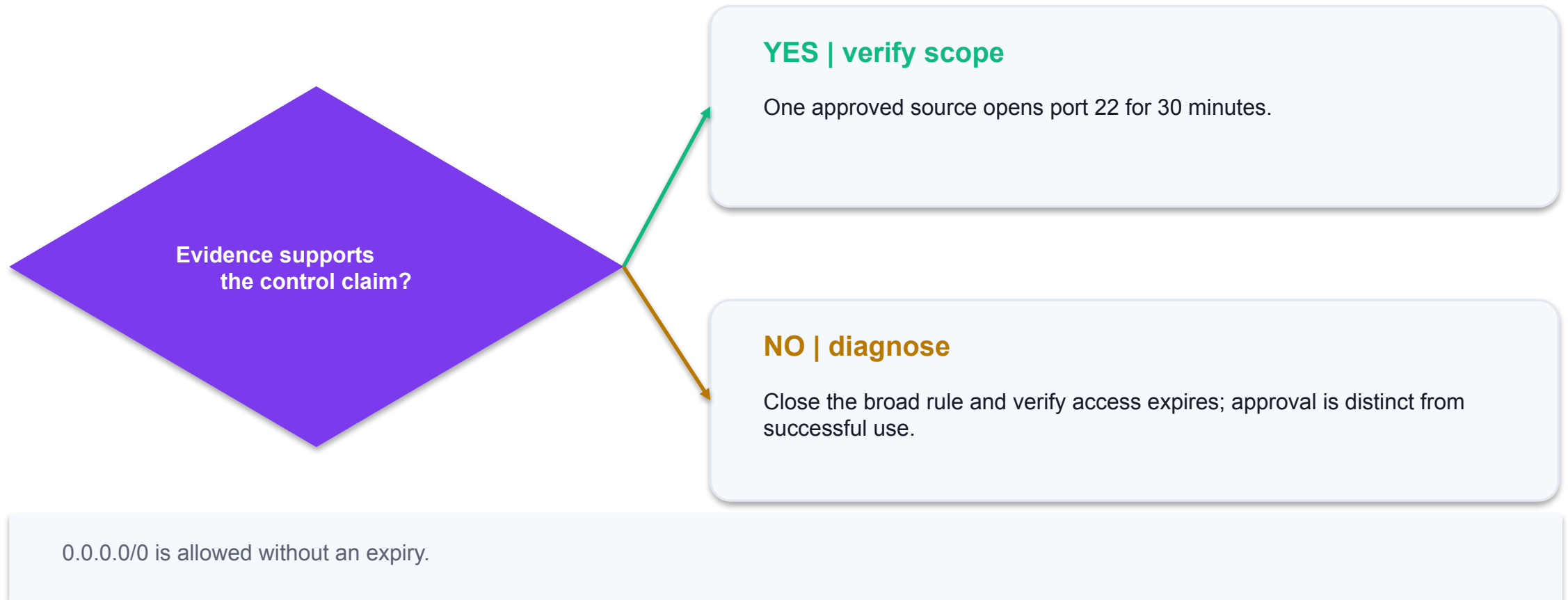
One approved source opens port 22 for 30 minutes.

FAILURE CASE

0.0.0.0/0 is allowed without an expiry.

Time-limited access narrows source and duration for administrative ports.

Just in time administration | diagnosis



Original worked example; supplied references

Just in time administration | verification

EVIDENCE TO PRESERVE

Keep request, approval, start, expiry and post-expiry denial evidence.

ACCEPTANCE BOUNDARY

One approved source opens port 22 for 30 minutes.

Close the broad rule and verify access expires; approval is distinct from successful use.

Just in time administration | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

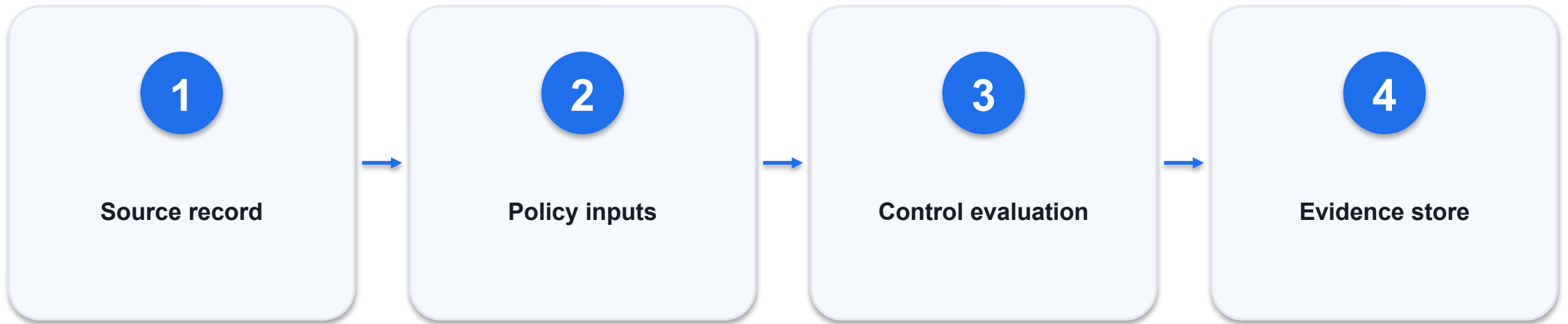
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
0.0.0.0/0 is allowed without an
expiry.

Resolve it using:
source_cidr, port,
requested_minutes, expiry

Encryption and identity



MECHANISM

Encryption protects stored bytes while identity controls authorised plaintext access.

Encryption and identity | field contract

INSPECTABLE ARTIFACT

encryption_state

key_reference

principal

INTERPRETATION

Encrypted disks remain protected by scoped operator access.

Separate encryption configuration evidence from access test results.

Original worked example; supplied references

Encryption and identity | counterexample

VALID CASE

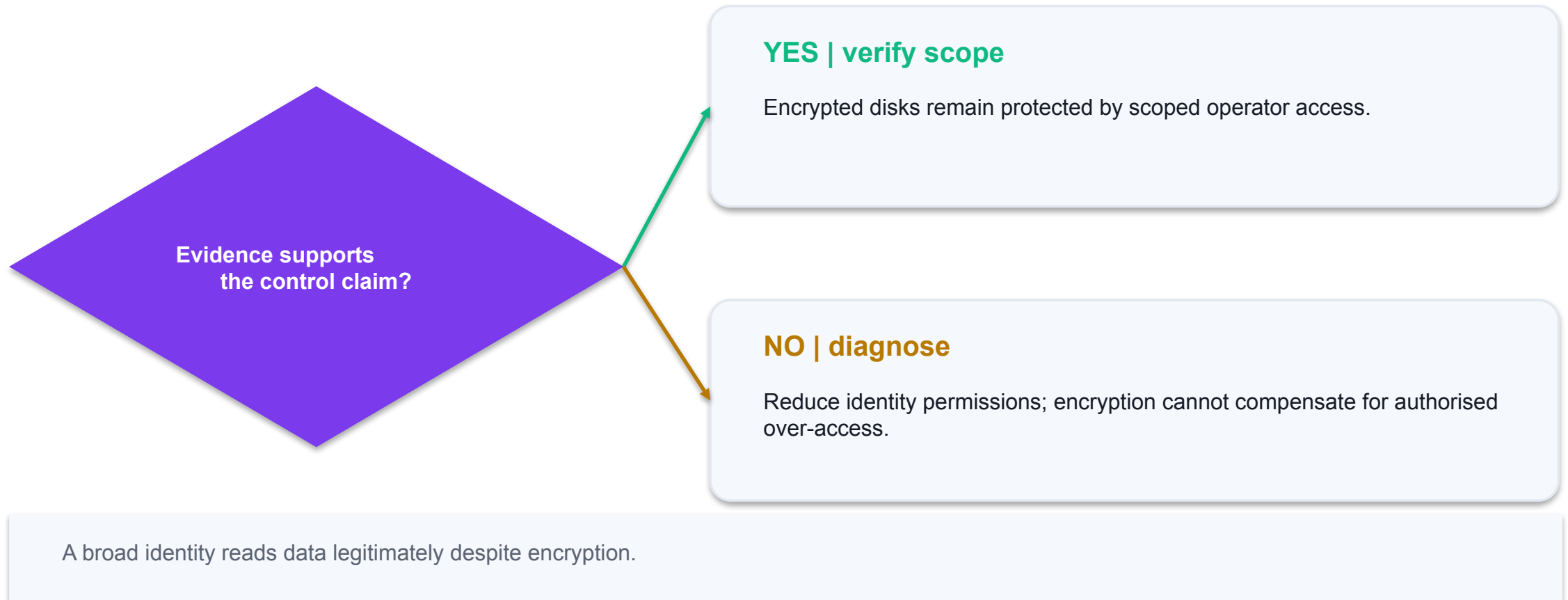
Encrypted disks remain protected by scoped operator access.

FAILURE CASE

A broad identity reads data legitimately despite encryption.

Encryption protects stored bytes while identity controls authorised plaintext access.

Encryption and identity | diagnosis



Original worked example; supplied references

Encryption and identity | verification

EVIDENCE TO PRESERVE

Separate encryption configuration evidence from access test results.

ACCEPTANCE BOUNDARY

Encrypted disks remain protected by scoped operator access.

Reduce identity permissions; encryption cannot compensate for authorised over-access.

Encryption and identity | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A broad identity reads data
legitimately despite encryption.

Resolve it using:
encryption_state, key_reference,
principal

Lab 7 | input schema

INSPECTABLE ARTIFACT

id: vm-a
public_admin: False
jit_minutes: 30
encrypted: True

INTERPRETATION

Synthetic fixture record.

Vm control evidence matrix.

The full dataset and instructions are in this lab's own folder.

Lab 7 | decision logic

```
for r in rows:
    issues=[]
    if r['public_admin']: issues.append('PUBLIC_ADMIN')
    if r['jit_minutes']>60: issues.append('LONG_WINDOW')
    if not r['encrypted']: issues.append('ENCRYPTION_REVIEW')
    out.append({'id':r['id'],'decision':','.join(issues) if
issues else 'BASELINE_OK'})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

Offline rule model; AI
review is separate.

Lab 7 | computed decisions

Record	Observed decision
vm-a	BASELINE_OK
vm-b	PUBLIC_ADMIN, LONG_WINDOW
vm-c	ENCRYPTION_REVIEW

Original worked example; supplied references

Lab 7 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 7 | test a changed condition

CONTROLLED CHANGE

Set vm-b public_admin to false. LONG_WINDOW must remain; closing one exposure does not satisfy all controls.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 7 | operational verification

DELIVERABLE

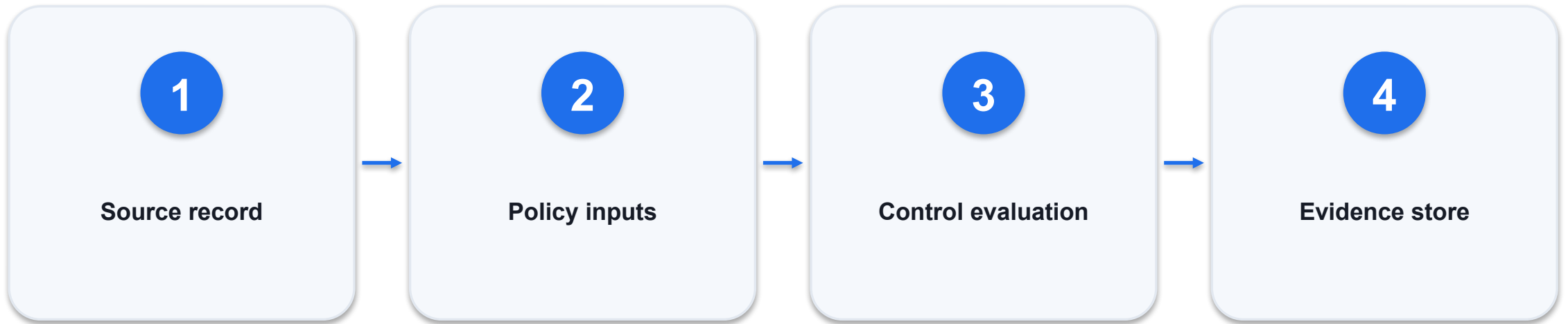
Vm control evidence matrix.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Storage access boundaries



MECHANISM

Data-plane roles, shared keys, SAS and public access create distinct access paths.

Storage access boundaries | field contract

INSPECTABLE ARTIFACT

allow_public

allow_shared_key

sas_expiry

data_role

INTERPRETATION

An identity receives scoped blob data access with public access disabled.

Capture role scope, anonymous denial and expiry of temporary grants.

Storage access boundaries | counterexample

VALID CASE

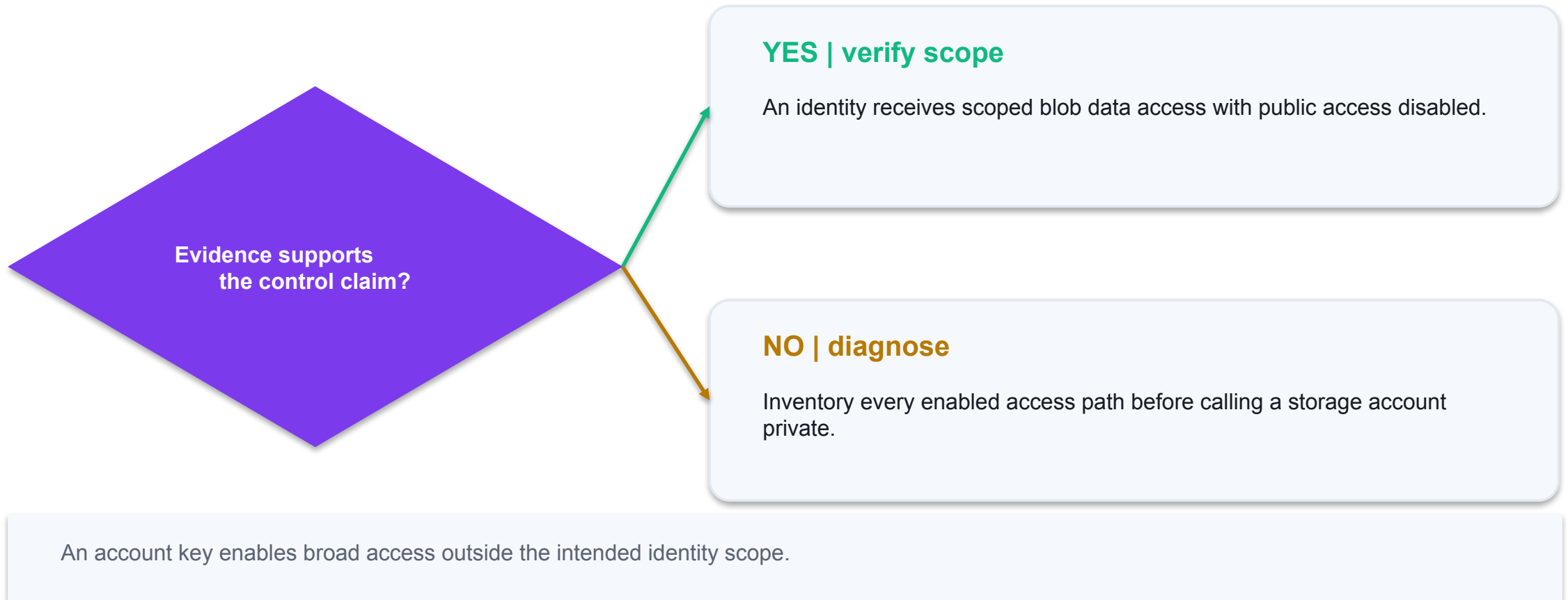
An identity receives scoped blob data access with public access disabled.

FAILURE CASE

An account key enables broad access outside the intended identity scope.

Data-plane roles, shared keys, SAS and public access create distinct access paths.

Storage access boundaries | diagnosis



Original worked example; supplied references

Storage access boundaries | verification

EVIDENCE TO PRESERVE

Capture role scope, anonymous denial and expiry of temporary grants.

ACCEPTANCE BOUNDARY

An identity receives scoped blob data access with public access disabled.

Inventory every enabled access path before calling a storage account private.

Storage access boundaries | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

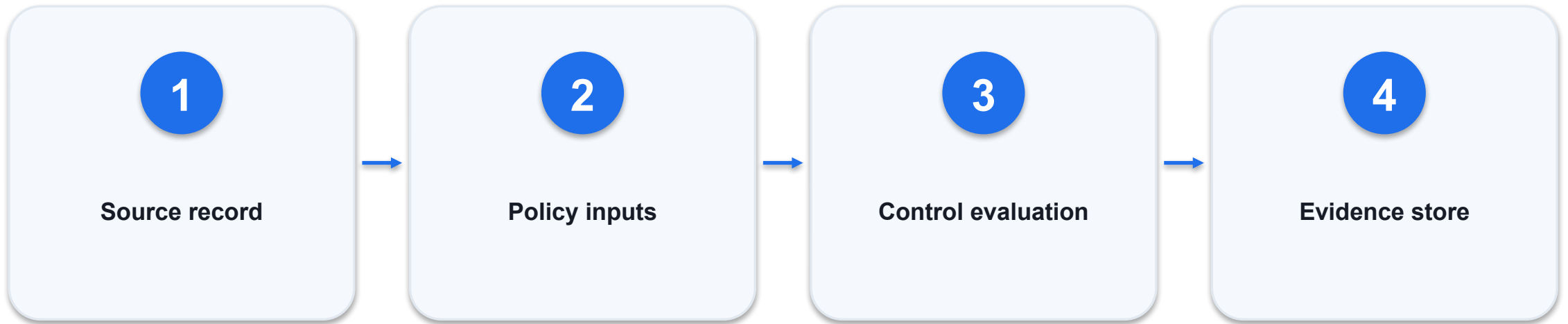
Test this claim:

An account key enables broad access outside the intended identity scope.

Resolve it using:

allow_public, allow_shared_key,
sas_expiry, data_role

SQL and secret protection



MECHANISM

A database authenticates a principal and authorises its operations; a vault limits secret retrieval.

SQL and secret protection | field contract

INSPECTABLE ARTIFACT

sql_principal

database_role

vault_role

secret_version

INTERPRETATION

A read-only database user and scoped secret reader serve a reporting workload.

Record role names and secret metadata, never the secret value.

SQL and secret protection | counterexample

VALID CASE

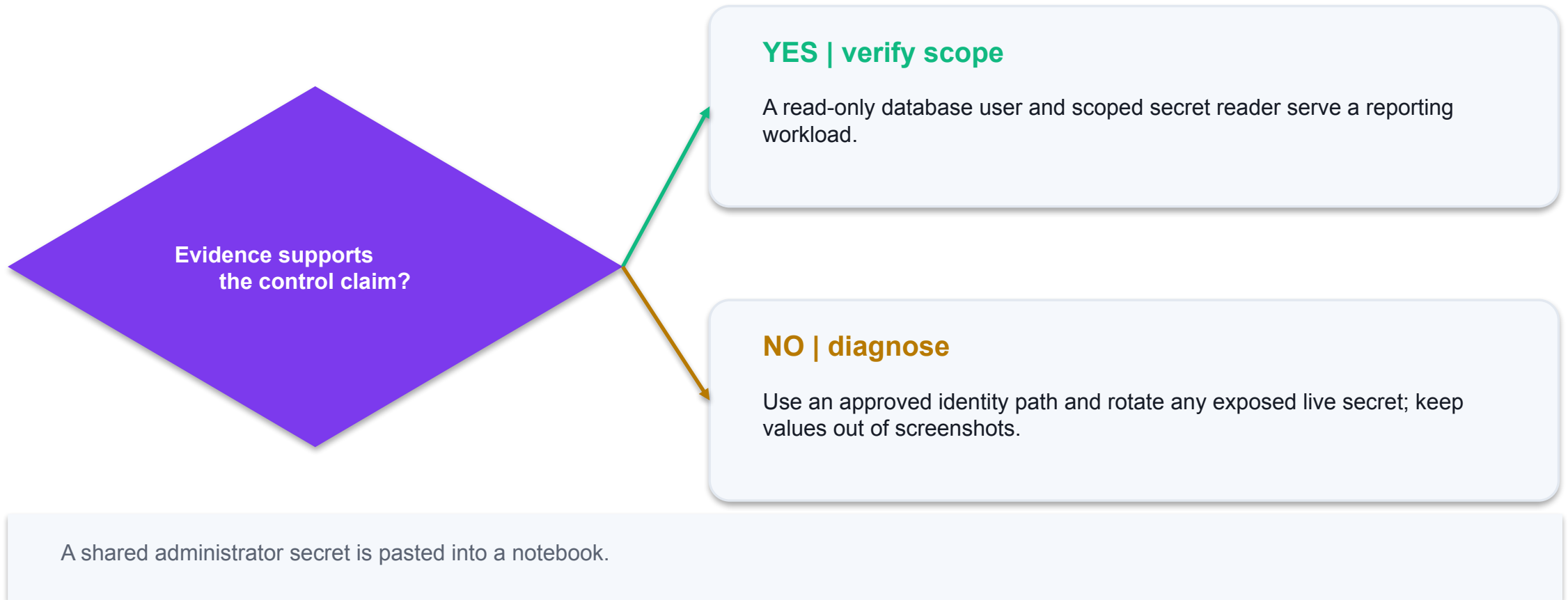
A read-only database user and scoped secret reader serve a reporting workload.

FAILURE CASE

A shared administrator secret is pasted into a notebook.

A database authenticates a principal and authorises its operations; a vault limits secret retrieval.

SQL and secret protection | diagnosis



Original worked example; supplied references

SQL and secret protection | verification

EVIDENCE TO PRESERVE

Record role names and secret metadata, never the secret value.

ACCEPTANCE BOUNDARY

A read-only database user and scoped secret reader serve a reporting workload.

Use an approved identity path and rotate any exposed live secret; keep values out of screenshots.

SQL and secret protection | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

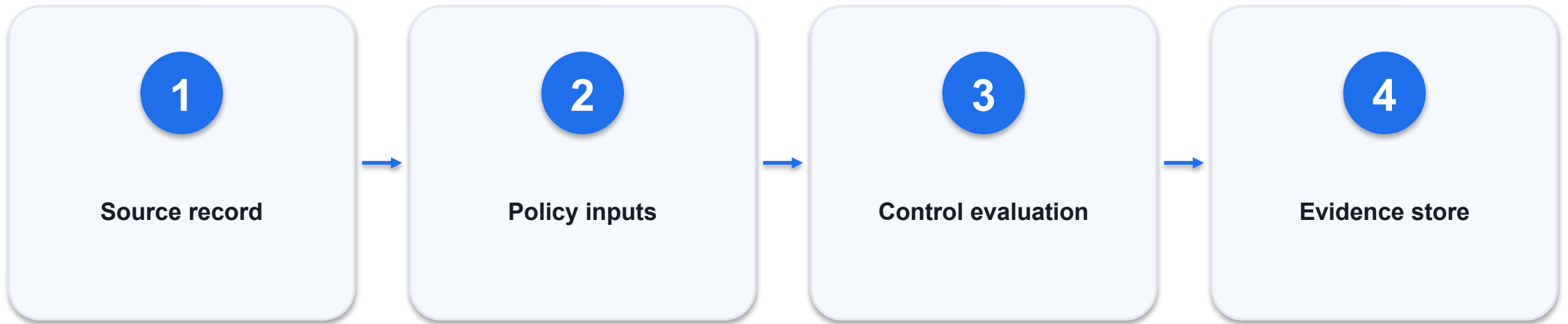
Test this claim:

A shared administrator secret is
pasted into a notebook.

Resolve it using:

sql_principal, database_role,
vault_role, secret_version

Retention and recovery



MECHANISM

Recovery points and restore tests establish recoverability independently of encryption.

Retention and recovery | field contract

INSPECTABLE ARTIFACT

backup_time

restore_time

rpo_minutes

rto_minutes

INTERPRETATION

A 15-minute data gap meets a 30-minute RPO.

Record measured data loss and elapsed restoration time.

Retention and recovery | counterexample

VALID CASE

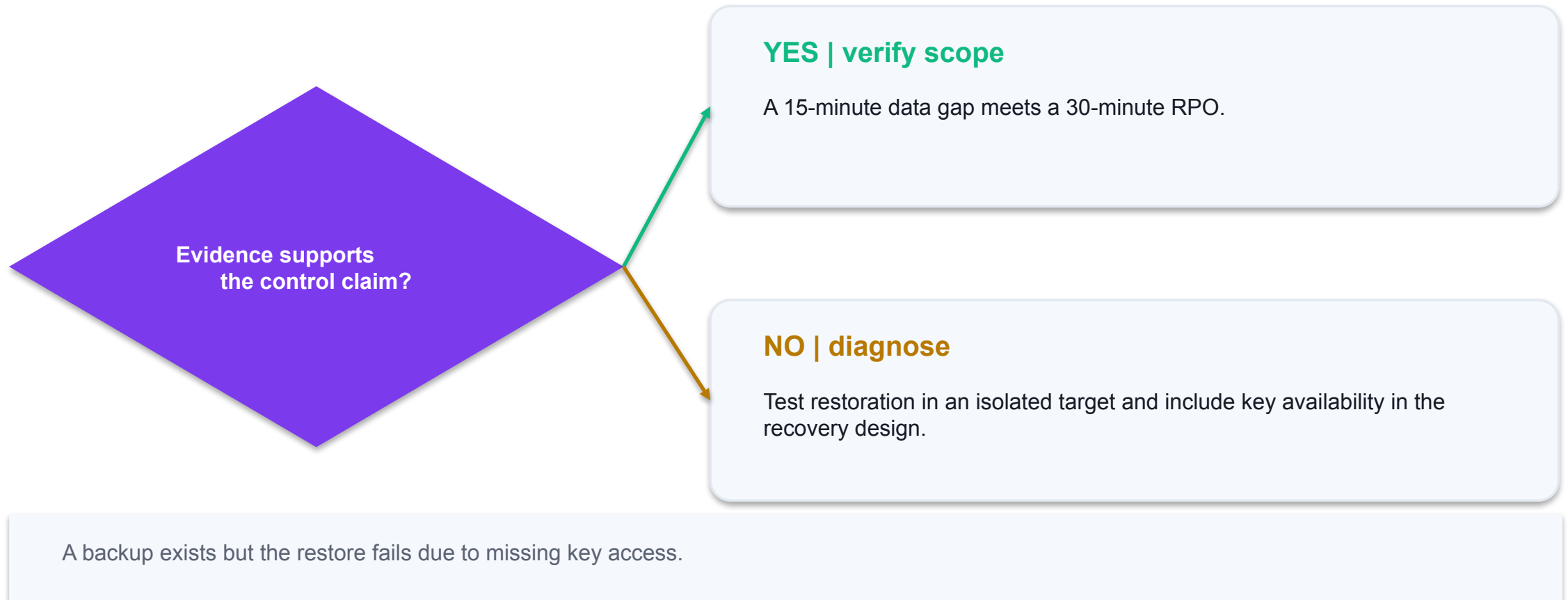
A 15-minute data gap meets a 30-minute RPO.

FAILURE CASE

A backup exists but the restore fails due to missing key access.

Recovery points and restore tests establish recoverability independently of encryption.

Retention and recovery | diagnosis



Original worked example; supplied references

Retention and recovery | verification

EVIDENCE TO PRESERVE

Record measured data loss and elapsed restoration time.

ACCEPTANCE BOUNDARY

A 15-minute data gap meets a 30-minute RPO.

Test restoration in an isolated target and include key availability in the recovery design.

Retention and recovery | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:

A backup exists but the restore fails due to missing key access.

Resolve it using:

backup_time, restore_time,
rpo_minutes, rto_minutes

Lab 8 | input schema

INSPECTABLE ARTIFACT

id: data-a
public: False
shared_key: False
secret_in_code: False
rpo: 15

INTERPRETATION

Synthetic fixture record.

Data-access and recovery
exception report.

The full dataset and instructions
are in this lab's own folder.

Lab 8 | decision logic

```
for r in rows:
    issues=[]
    if r['public'] or r['shared_key']:
        issues.append('ACCESS_REVIEW')
        if r['secret_in_code']: issues.append('SECRET_EXPOSURE')
        if r['rpo']>30: issues.append('RPO_BREACH')
        out.append({'id':r['id'],'decision':','.join(issues) if
        issues else 'BASELINE_OK'})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

Offline rule model; AI
review is separate.

Lab 8 | computed decisions

Record	Observed decision
data-a	BASELINE_OK
data-b	ACCESS_REVIEW
data-c	SECRET_EXPOSURE,RPO_BREACH

Original worked example; supplied references

Lab 8 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 8 | test a changed condition

CONTROLLED CHANGE

Set data-c secret_in_code to false.
RPO_BREACH must remain; access hygiene
and recovery objectives are separate.

EVIDENCE CONTRACT

Record the input SHA-256, changed field,
predicted decision and actual decision. Explain
discrepancies using the script.

Lab 8 | operational verification

DELIVERABLE

Data-access and recovery exception report.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Day 2 | evidence review

EXHIBITS

Labs 5–8: compare baseline, changed-input result and source checksum.

REVIEW DECISION

Which claim is supported by a record? Which control still needs operational verification? Cite the exact artifact and uncertainty.

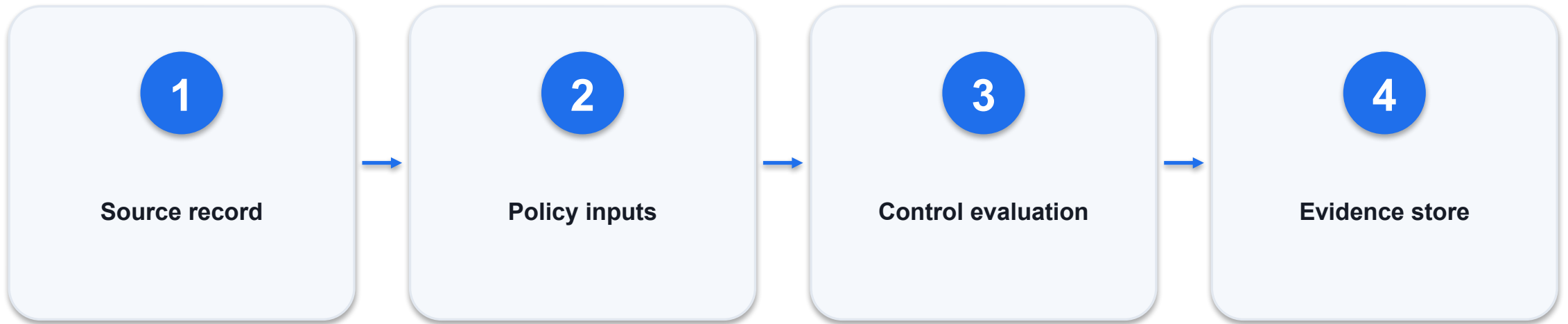


DAY 3

Monitoring and investigation

Technical mechanisms, evidence and diagnostic cases

Policy effect semantics



MECHANISM

Audit records noncompliance; deny prevents supported noncompliant resource requests.

Policy effect semantics | field contract

INSPECTABLE ARTIFACT

effect

assignment_scope

resource_type

INTERPRETATION

Audit flags public exposure for review.

Capture effect, scope, exemption and compliance timestamp.

Original worked example; supplied references

Policy effect semantics | counterexample

VALID CASE

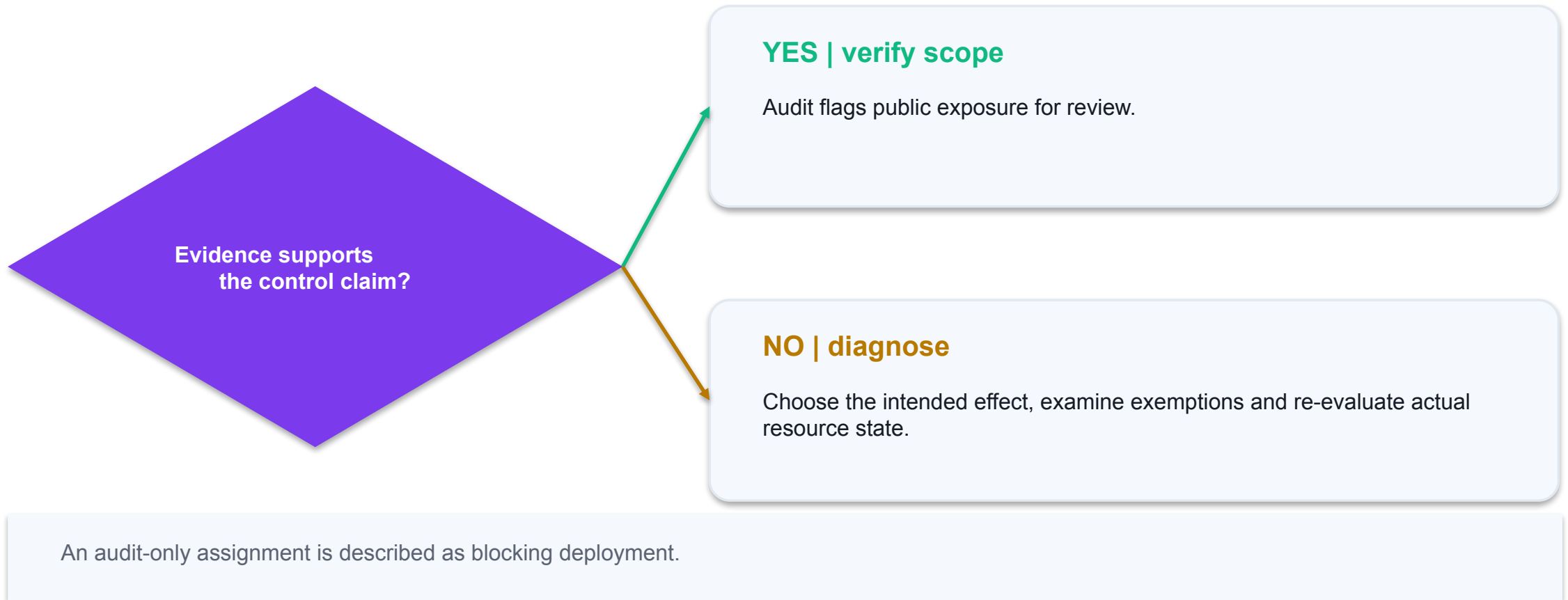
Audit flags public exposure for review.

FAILURE CASE

An audit-only assignment is described as blocking deployment.

Audit records noncompliance; deny prevents supported noncompliant resource requests.

Policy effect semantics | diagnosis



Original worked example; supplied references

Policy effect semantics | verification

EVIDENCE TO PRESERVE

Capture effect, scope, exemption and compliance timestamp.

ACCEPTANCE BOUNDARY

Audit flags public exposure for review.

Choose the intended effect, examine exemptions and re-evaluate actual resource state.

Policy effect semantics | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

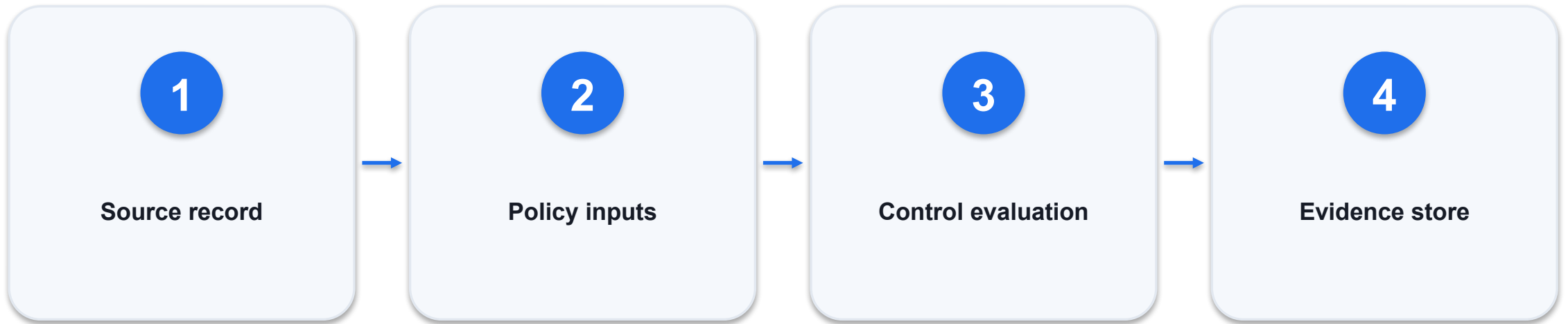
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
An audit-only assignment is
described as blocking deployment.

Resolve it using:
effect, assignment_scope,
resource_type

Posture prioritisation



MECHANISM

A posture recommendation becomes actionable when tied to affected assets and validated exposure.

Posture prioritisation | field contract

INSPECTABLE ARTIFACT

recommendation_id

resource_id

severity

owner

INTERPRETATION

A critical recommendation affects the internet-facing payment VM.

Record resource state, owner, remediation ticket and retest.

Posture prioritisation | counterexample

VALID CASE

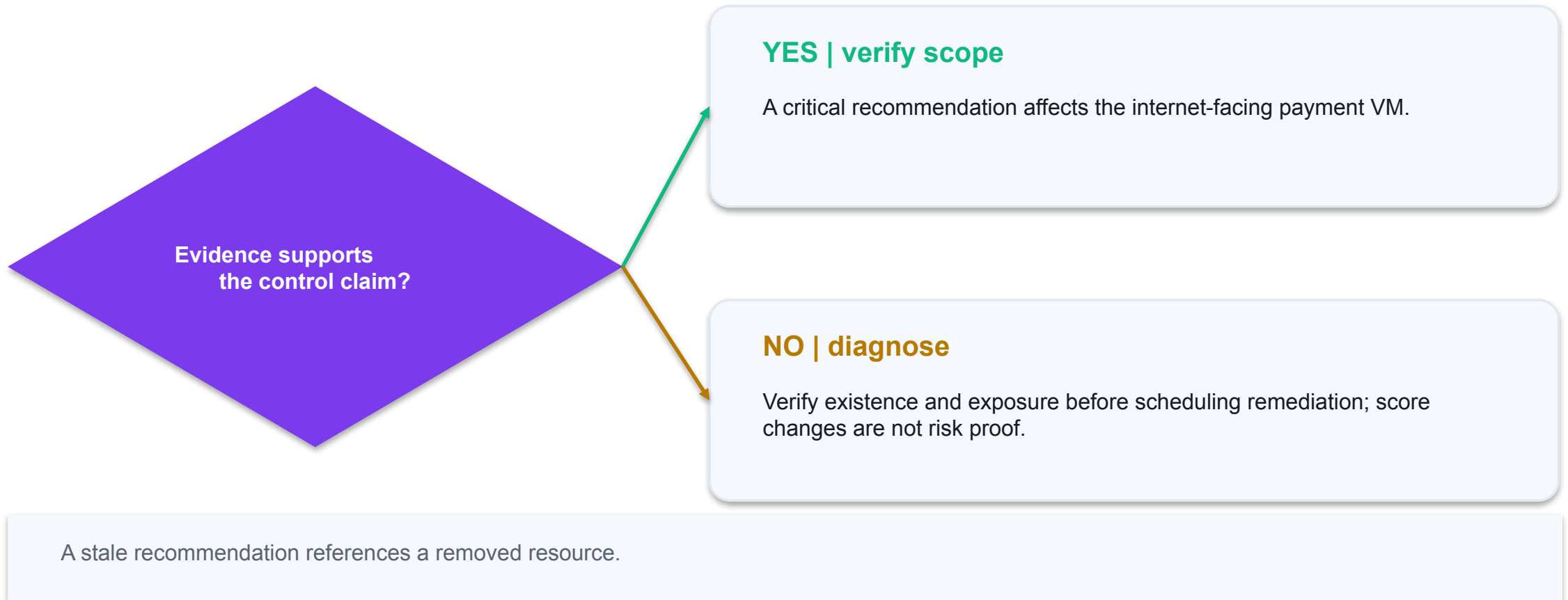
A critical recommendation affects the internet-facing payment VM.

FAILURE CASE

A stale recommendation references a removed resource.

A posture recommendation becomes actionable when tied to affected assets and validated exposure.

Posture prioritisation | diagnosis



Original worked example; supplied references

Posture prioritisation | verification

EVIDENCE TO PRESERVE

Record resource state, owner, remediation ticket and retest.

ACCEPTANCE BOUNDARY

A critical recommendation affects the internet-facing payment VM.

Verify existence and exposure before scheduling remediation; score changes are not risk proof.

Posture prioritisation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

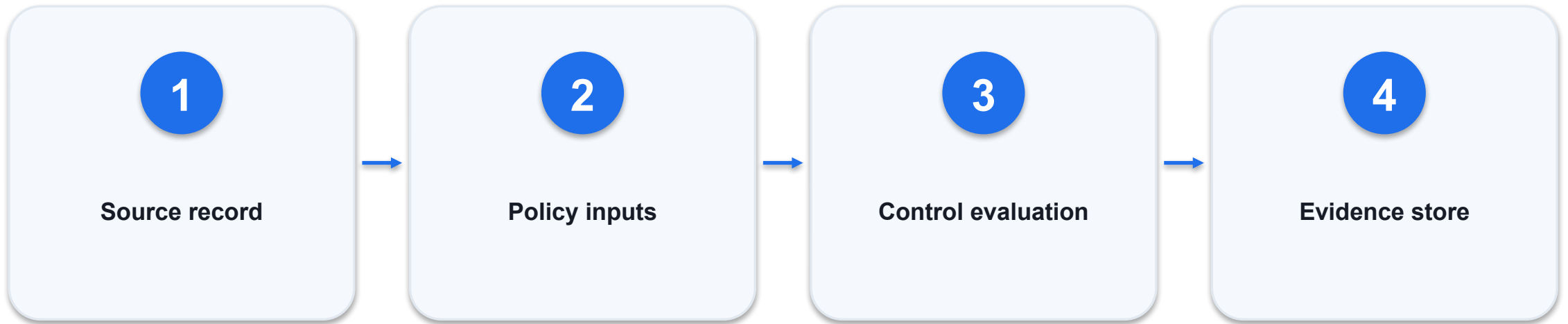
INTERPRETATION

Test this claim:
A stale recommendation
references a removed resource.

Resolve it using:
recommendation_id, resource_id,
severity, owner

Original worked example; supplied references

Exception lifecycle



MECHANISM

A risk exception is bounded by an owner, compensating control and expiry.

Exception lifecycle | field contract

INSPECTABLE ARTIFACT

exception_id

expires_utc

owner

compensating_control

INTERPRETATION

A temporary exception expires after a planned migration.

List expired exceptions separately from compliant controls.

Exception lifecycle | counterexample

VALID CASE

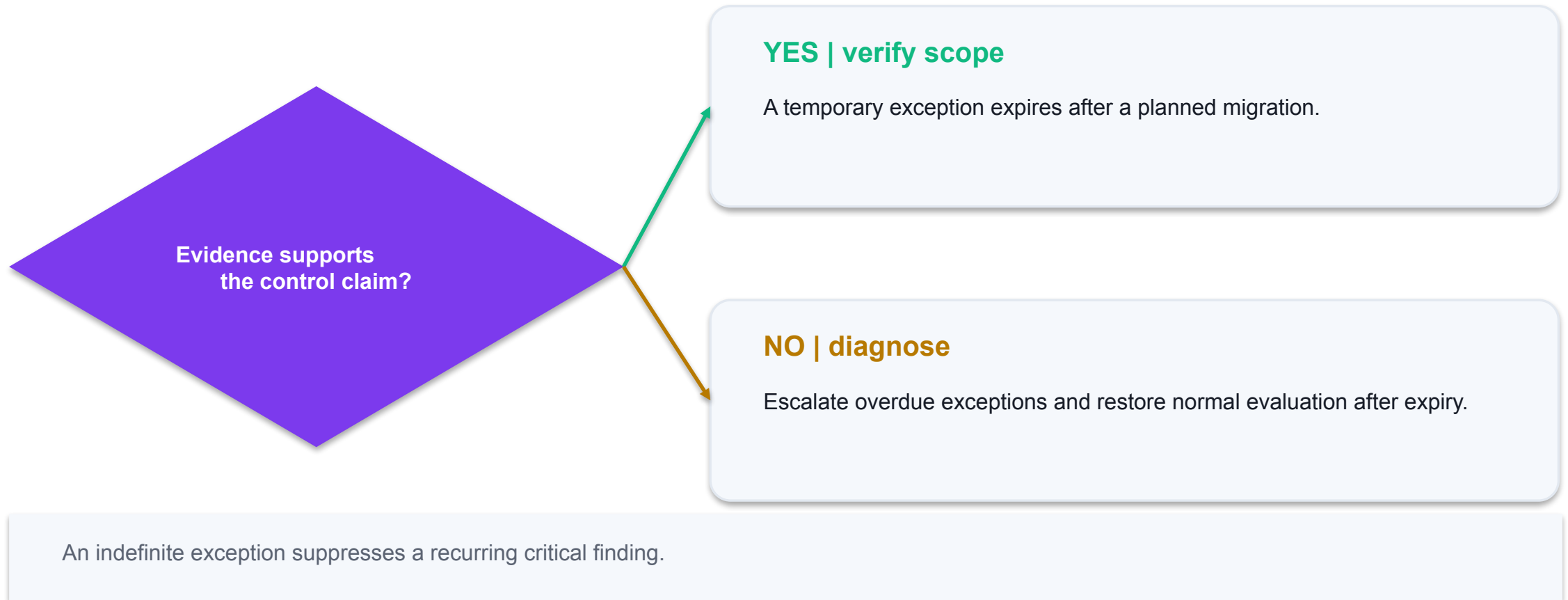
A temporary exception expires after a planned migration.

FAILURE CASE

An indefinite exception suppresses a recurring critical finding.

A risk exception is bounded by an owner, compensating control and expiry.

Exception lifecycle | diagnosis



Original worked example; supplied references

Exception lifecycle | verification

EVIDENCE TO PRESERVE

List expired exceptions separately from compliant controls.

ACCEPTANCE BOUNDARY

A temporary exception expires after a planned migration.

Escalate overdue exceptions and restore normal evaluation after expiry.

Exception lifecycle | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
An indefinite exception suppresses
a recurring critical finding.

Resolve it using:
exception_id, expires_utc, owner,
compensating_control

Lab 9 | input schema

INSPECTABLE ARTIFACT

id: pol-a
effect: audit
compliant: False
exception_expired: False

INTERPRETATION

Synthetic fixture record.

Policy finding register with accountable owners.

The full dataset and instructions are in this lab's own folder.

Lab 9 | decision logic

```
for r in rows:
    decision='EXPIRED_EXCEPTION' if r['exception_expired']
else ('COMPLIANT' if r['compliant'] else ('WOULD_DENY_REQUEST'
if r['effect']=='deny' else 'AUDIT_FINDING'))
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

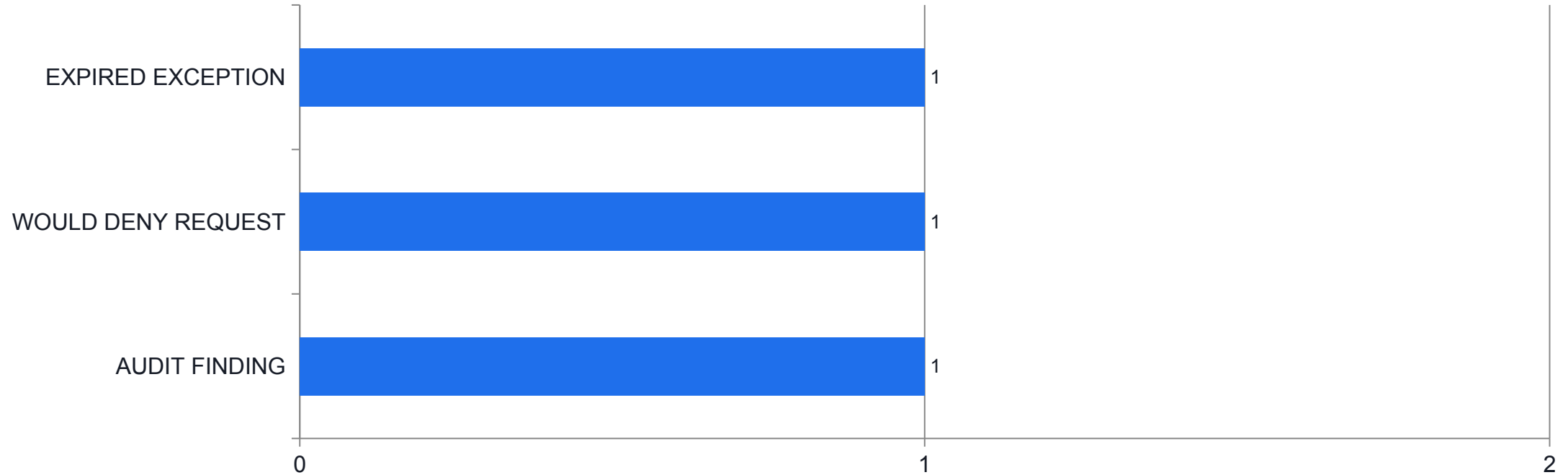
Offline rule model; AI
review is separate.

Lab 9 | computed decisions

Record	Observed decision
pol-a	AUDIT_FINDING
pol-b	WOULD_DENY_REQUEST
pol-c	EXPIRED_EXCEPTION

Original worked example; supplied references

Lab 9 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 9 | test a changed condition

CONTROLLED CHANGE

Change pol-a effect to deny. Explain that the model describes a new request, not automatic remediation of an existing resource.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 9 | operational verification

DELIVERABLE

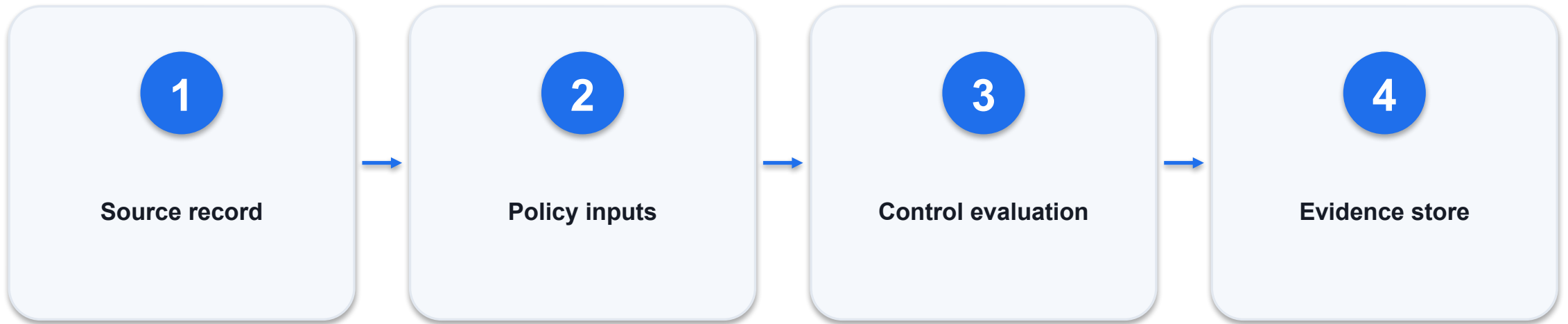
Policy finding register with accountable owners.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Log schema and time



MECHANISM

Normalise event time and actor identifiers before correlating records.

Log schema and time | field contract

INSPECTABLE ARTIFACT

event_id

event_time_utc

user_id

operation

result

INTERPRETATION

Two sources use UTC and the same stable actor ID.

Record timezone conversion and the event-to-ingestion delay.

Log schema and time | counterexample

VALID CASE

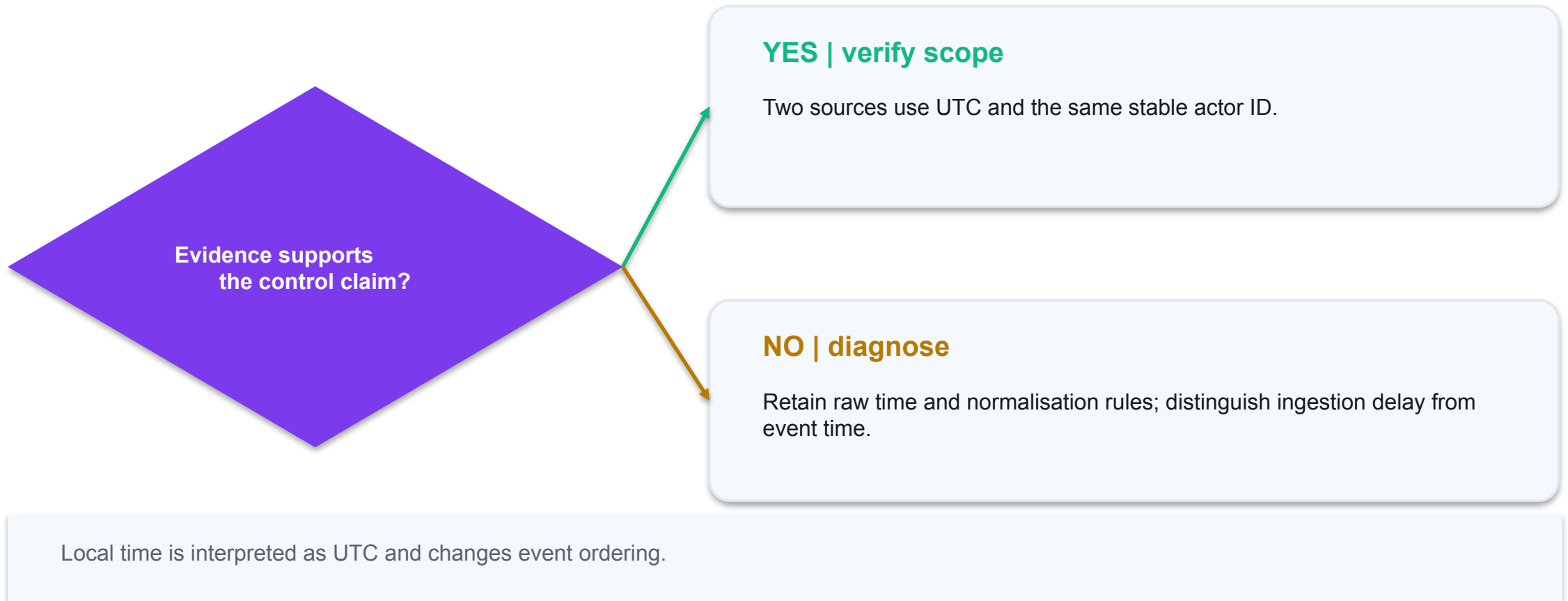
Two sources use UTC and the same stable actor ID.

FAILURE CASE

Local time is interpreted as UTC and changes event ordering.

Normalise event time and actor identifiers before correlating records.

Log schema and time | diagnosis



Original worked example; supplied references

Log schema and time | verification

EVIDENCE TO PRESERVE

Record timezone conversion and the event-to-ingestion delay.

ACCEPTANCE BOUNDARY

Two sources use UTC and the same stable actor ID.

Retain raw time and normalisation rules; distinguish ingestion delay from event time.

Log schema and time | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

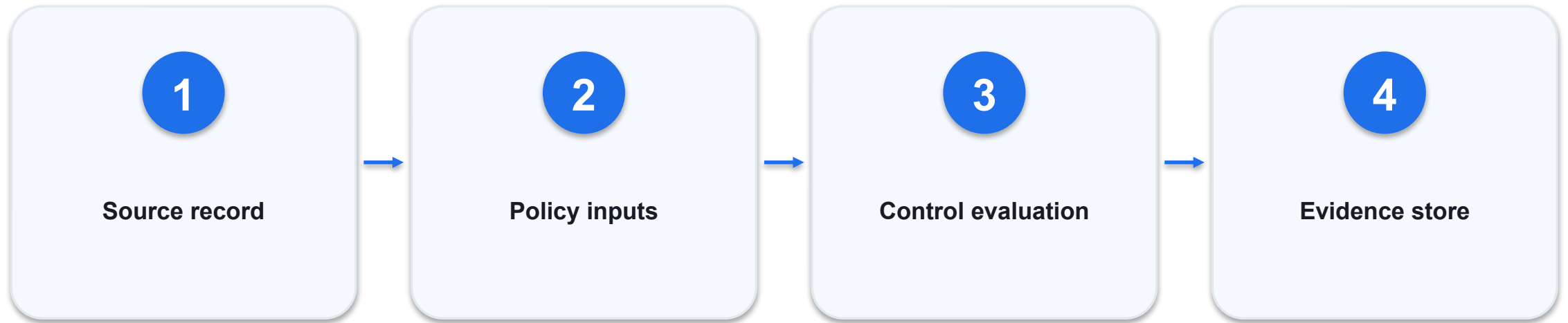
Test this claim:

Local time is interpreted as UTC
and changes event ordering.

Resolve it using:

event_id, event_time_utc, user_id,
operation, result

Detection threshold



MECHANISM

Group failures by actor and time window; compare the count to a defined threshold.

Detection threshold | field contract

INSPECTABLE ARTIFACT

window_minutes=5

failed_count>=5

INTERPRETATION

Six failures for user_004 in five minutes trigger review.

Retain the contributing event IDs and precise window boundaries.

Original worked example; supplied references

Detection threshold | counterexample

VALID CASE

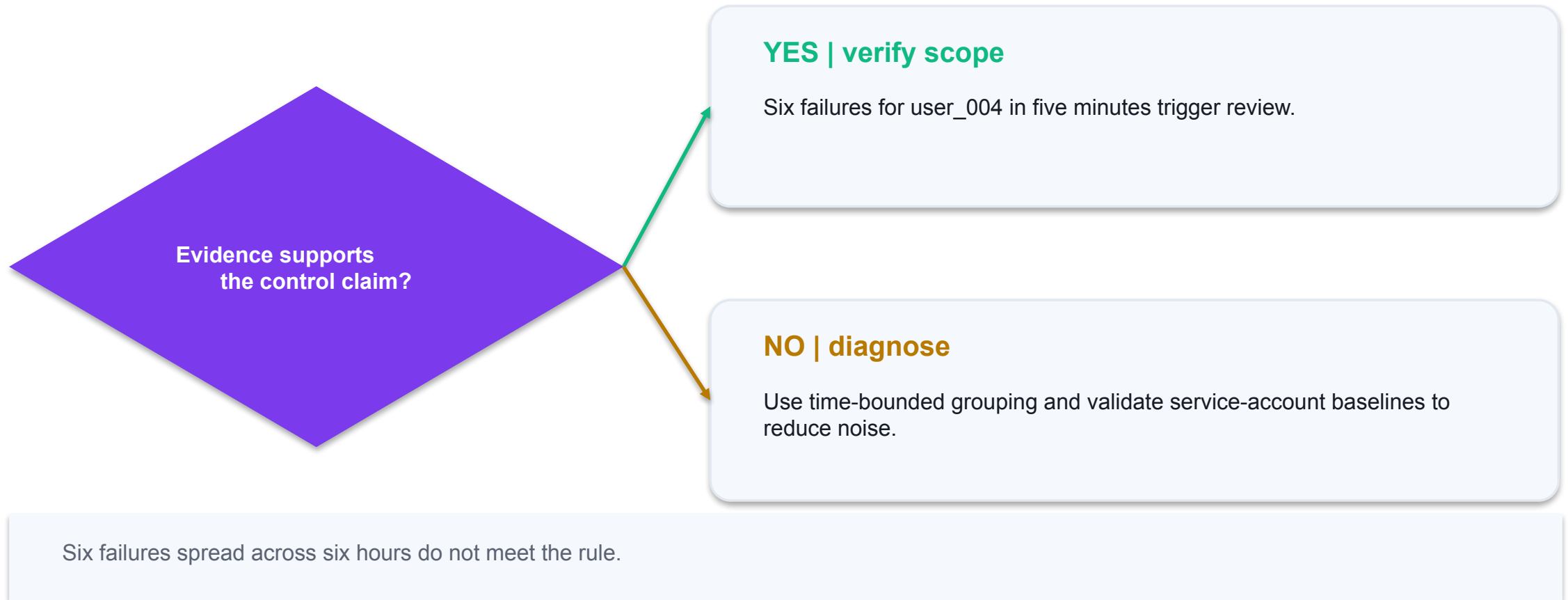
Six failures for user_004 in five minutes trigger review.

FAILURE CASE

Six failures spread across six hours do not meet the rule.

Group failures by actor and time window; compare the count to a defined threshold.

Detection threshold | diagnosis



Original worked example; supplied references

Detection threshold | verification

EVIDENCE TO PRESERVE

Retain the contributing event IDs and precise window boundaries.

ACCEPTANCE BOUNDARY

Six failures for user_004 in five minutes trigger review.

Use time-bounded grouping and validate service-account baselines to reduce noise.

Detection threshold | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

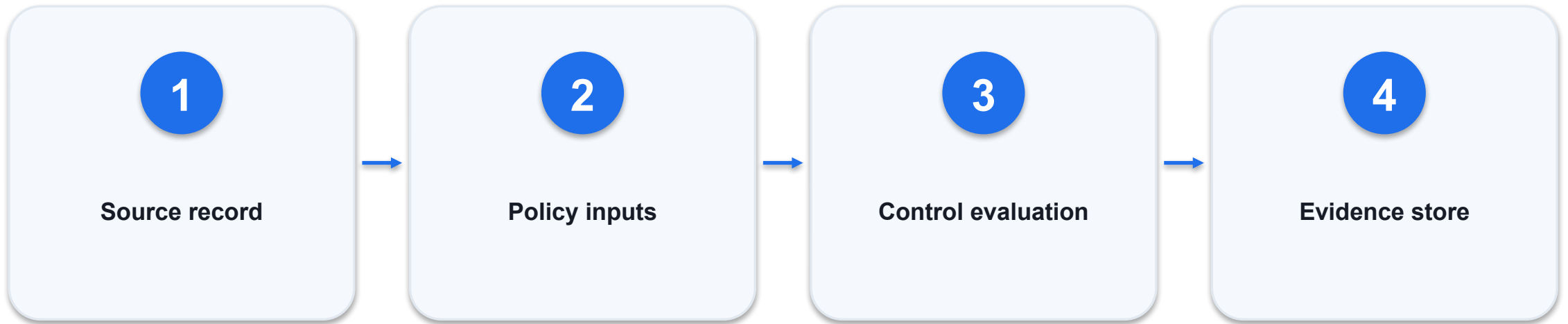
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Six failures spread across six
hours do not meet the rule.

Resolve it using:
window_minutes=5,
failed_count>=5

Detection metrics



MECHANISM

Compare detector output to labelled cases to measure precision and recall.

Detection metrics | field contract

INSPECTABLE ARTIFACT

$\text{precision} = \text{TP} / (\text{TP} + \text{FP})$; $\text{recall} = \text{TP} / (\text{TP} + \text{FN})$

INTERPRETATION

TP=8, FP=2, FN=4 gives 80% precision and 66.7% recall.

Save confusion counts, threshold and dataset version.

Detection metrics | counterexample

VALID CASE

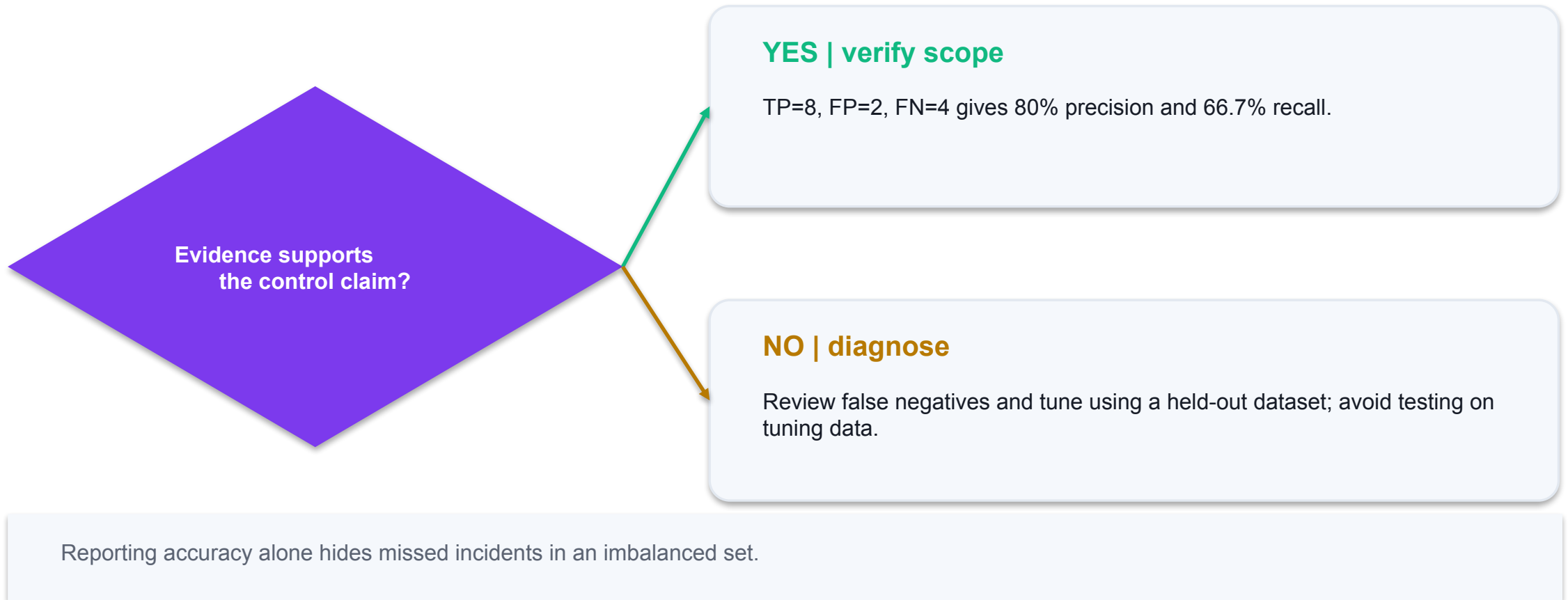
TP=8, FP=2, FN=4 gives 80% precision and 66.7% recall.

FAILURE CASE

Reporting accuracy alone hides missed incidents in an imbalanced set.

Compare detector output to labelled cases to measure precision and recall.

Detection metrics | diagnosis



Original worked example; supplied references

Detection metrics | verification

EVIDENCE TO PRESERVE

Save confusion counts, threshold and dataset version.

ACCEPTANCE BOUNDARY

TP=8, FP=2, FN=4 gives 80% precision and 66.7% recall.

Review false negatives and tune using a held-out dataset; avoid testing on tuning data.

Detection metrics | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Reporting accuracy alone hides
missed incidents in an imbalanced
set.

Resolve it using:
 $\text{precision} = \text{TP} / (\text{TP} + \text{FP})$;
 $\text{recall} = \text{TP} / (\text{TP} + \text{FN})$

Lab 10 | input schema

INSPECTABLE ARTIFACT

id: e1
user: user_004
minute: 1
failed: True
label: True

INTERPRETATION

Synthetic fixture record.

Time-window detection output and tuning note.

The full dataset and instructions are in this lab's own folder.

Lab 10 | decision logic

```
for user in sorted({r['user'] for r in rows}):
    events=sorted([r for r in rows if r['user']==user and
r['failed']],key=lambda r:r['minute'])
    peak=max((sum(0<=x['minute']-e['minute']<5 for x in
events) for e in events),default=0)
    out.append({'id':user,'peak':peak,'decision':'ALERT' if
peak>=5 else 'NO_ALERT'})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

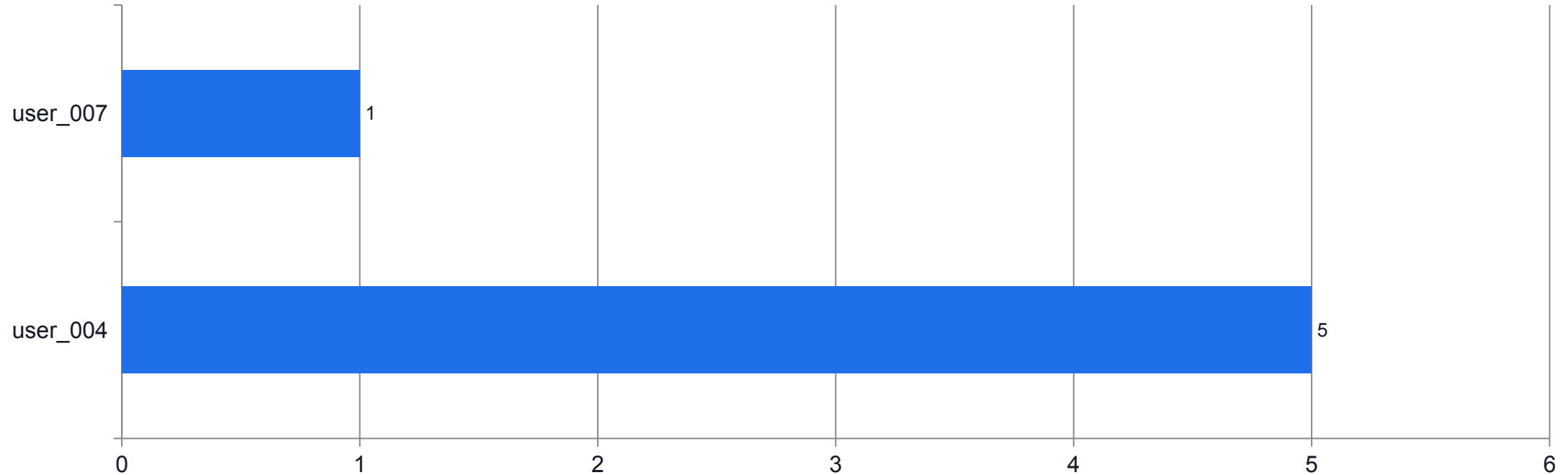
Offline rule model; AI
review is separate.

Lab 10 | computed decisions

Record	Observed decision
user_004	ALERT
user_007	NO_ALERT

Original worked example; supplied references

Lab 10 | evidence distribution



WHAT THE DATA SHOWS

Synthetic five-minute peak failure counts. The classroom alert threshold is five; the window is as important as the total.

Lab 10 | test a changed condition

CONTROLLED CHANGE

Move e5 to minute 10. The five-minute peak becomes 4 and the alert disappears. Explain the blind spot and propose a separately tested longer-window detector.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 10 | operational verification

DELIVERABLE

Time-window detection output and tuning note.

Record scope, UTC time and approval state.

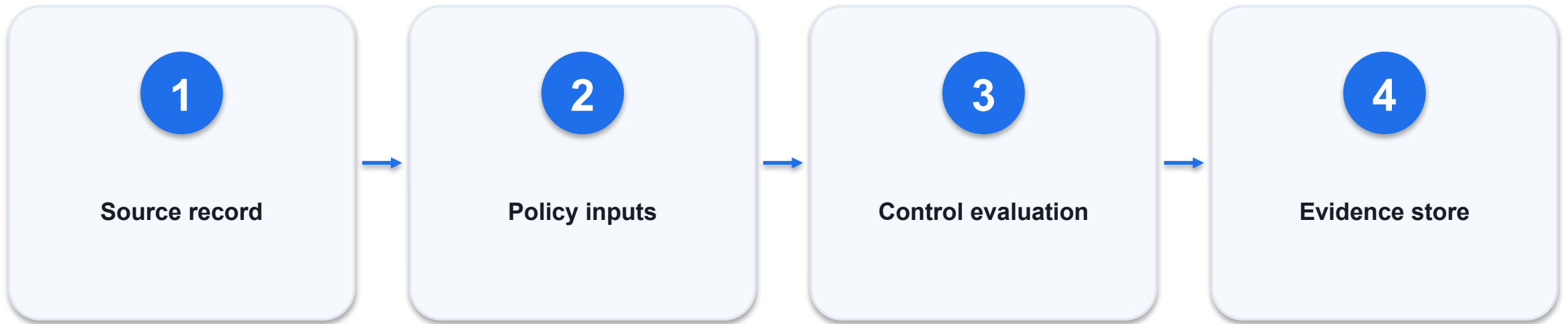
WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Tea break

15 minutes

Least privilege troubleshooting



MECHANISM

Diagnose actor, scope, action and policy before granting broader access.

Least privilege troubleshooting | field contract

INSPECTABLE ARTIFACT

actor_id

target_scope

attempted_action

error_code

INTERPRETATION

The failing action is absent at the intended resource scope.

Keep the original error, policy evaluation and post-fix result.

Least privilege troubleshooting | counterexample

VALID CASE

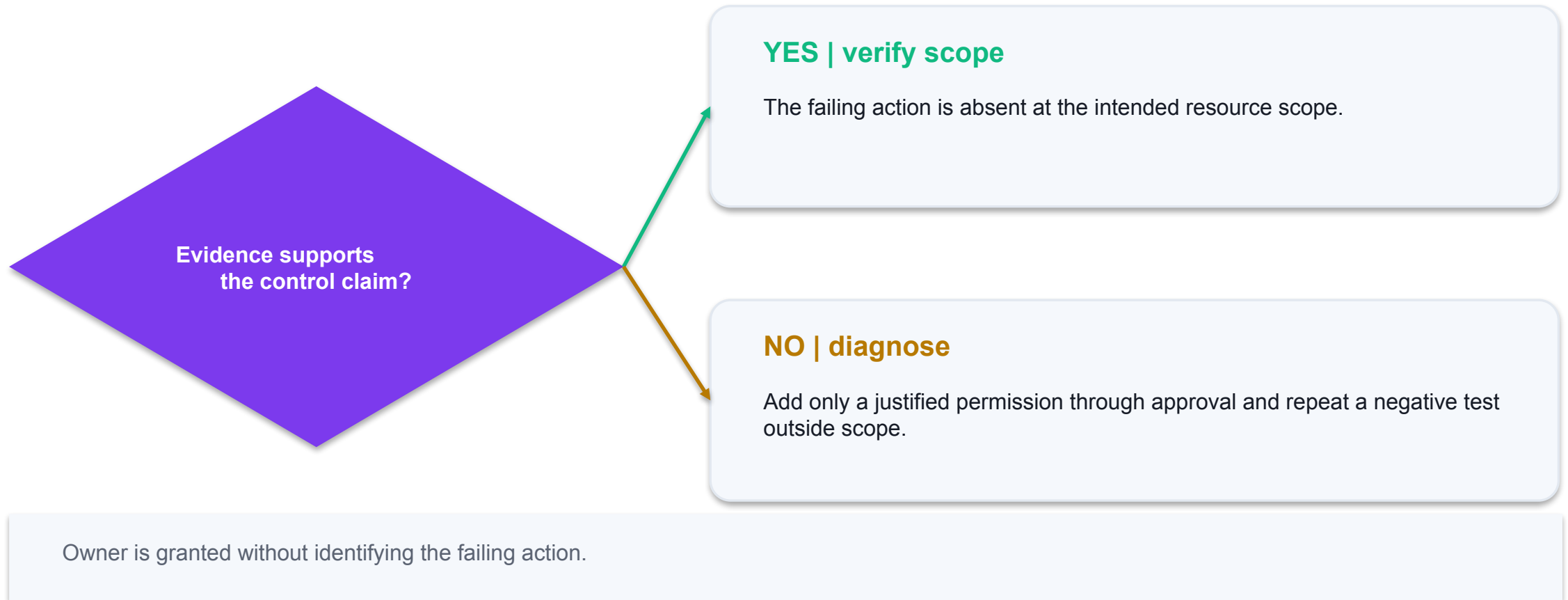
The failing action is absent at the intended resource scope.

FAILURE CASE

Owner is granted without identifying the failing action.

Diagnose actor, scope, action and policy before granting broader access.

Least privilege troubleshooting | diagnosis



Original worked example; supplied references

Least privilege troubleshooting | verification

EVIDENCE TO PRESERVE

Keep the original error, policy evaluation and post-fix result.

ACCEPTANCE BOUNDARY

The failing action is absent at the intended resource scope.

Add only a justified permission through approval and repeat a negative test outside scope.

Least privilege troubleshooting | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

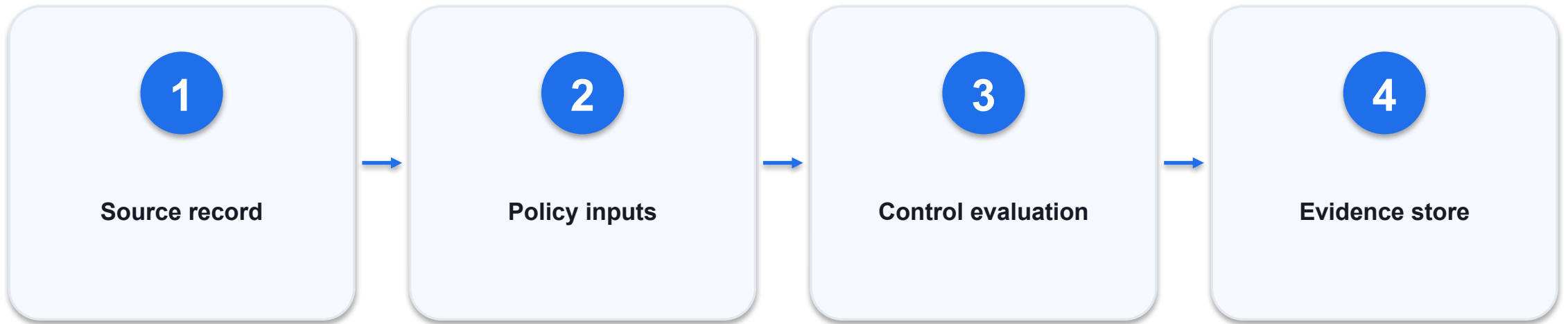
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Owner is granted without
identifying the failing action.

Resolve it using:
actor_id, target_scope,
attempted_action, error_code

Access review decisions



MECHANISM

Compare actual grants to job need and make an accountable retain/revoke decision.

Access review decisions | field contract

INSPECTABLE ARTIFACT

principal

grant

business_need

reviewer

decision

INTERPRETATION

An inactive contractor's unneeded grant is revoked.

Record reviewer reasoning and a subsequent denied access attempt.

Access review decisions | counterexample

VALID CASE

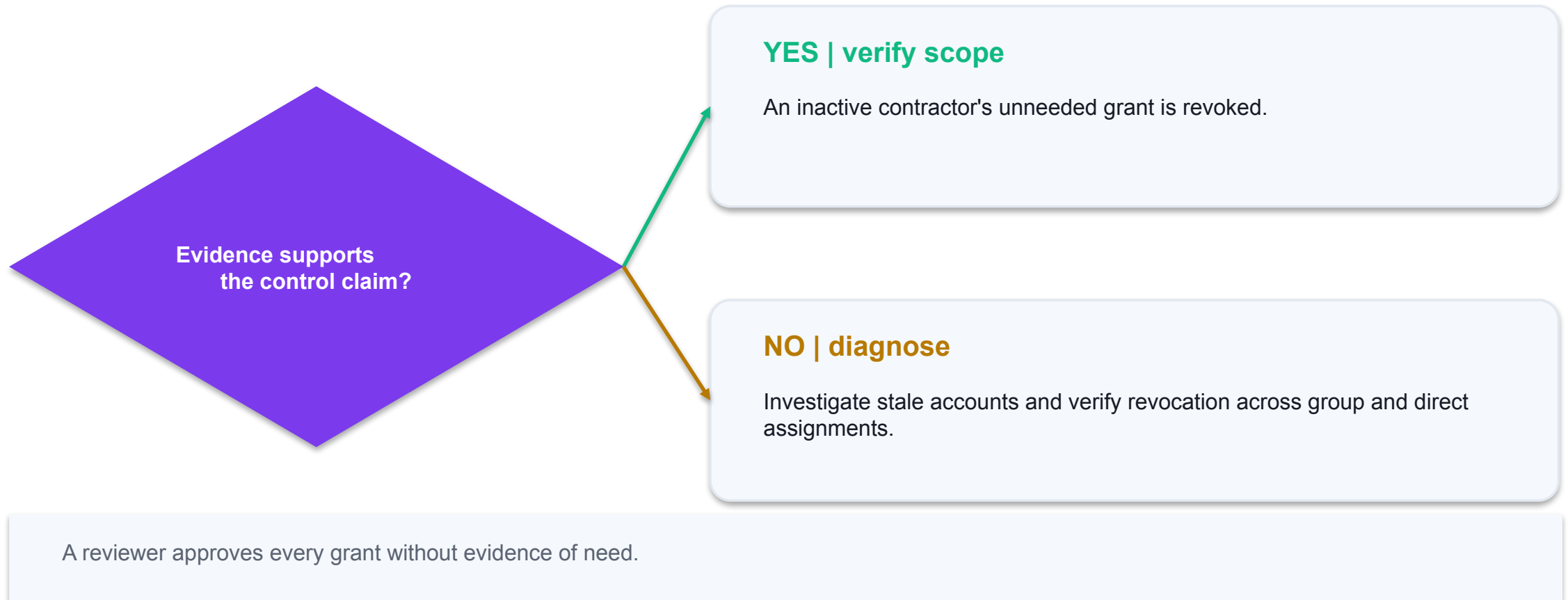
An inactive contractor's unneeded grant is revoked.

FAILURE CASE

A reviewer approves every grant without evidence of need.

Compare actual grants to job need and make an accountable retain/revoke decision.

Access review decisions | diagnosis



Original worked example; supplied references

Access review decisions | verification

EVIDENCE TO PRESERVE

Record reviewer reasoning and a subsequent denied access attempt.

ACCEPTANCE BOUNDARY

An inactive contractor's unneeded grant is revoked.

Investigate stale accounts and verify revocation across group and direct assignments.

Access review decisions | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

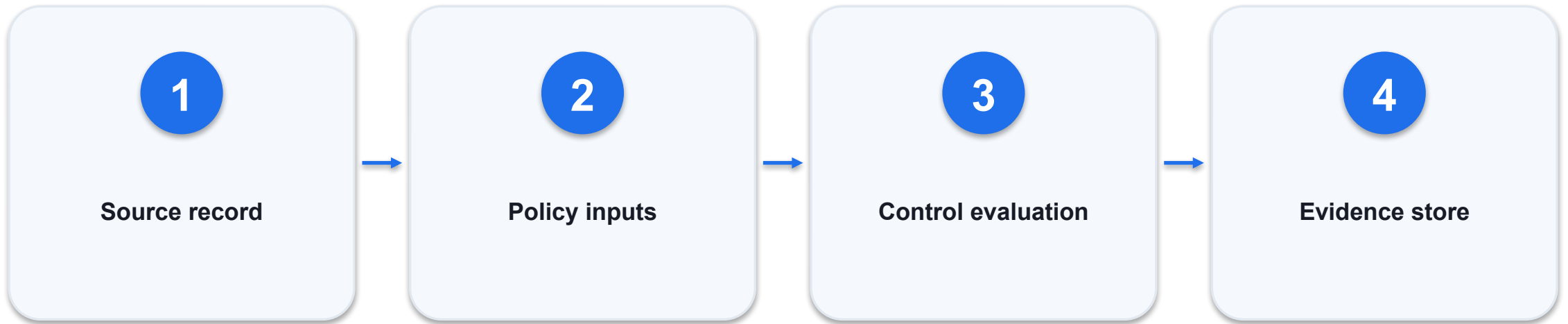
Test this claim:

A reviewer approves every grant
without evidence of need.

Resolve it using:

principal, grant, business_need,
reviewer, decision

Separation of duties



MECHANISM

A requester cannot approve their own privileged change when the process requires independent review.

Separation of duties | field contract

INSPECTABLE ARTIFACT

requester_id

approver_id

requested_action

INTERPRETATION

user_004 requests and owner_002 approves.

Capture both identities and the immutable request identifier.

Separation of duties | counterexample

VALID CASE

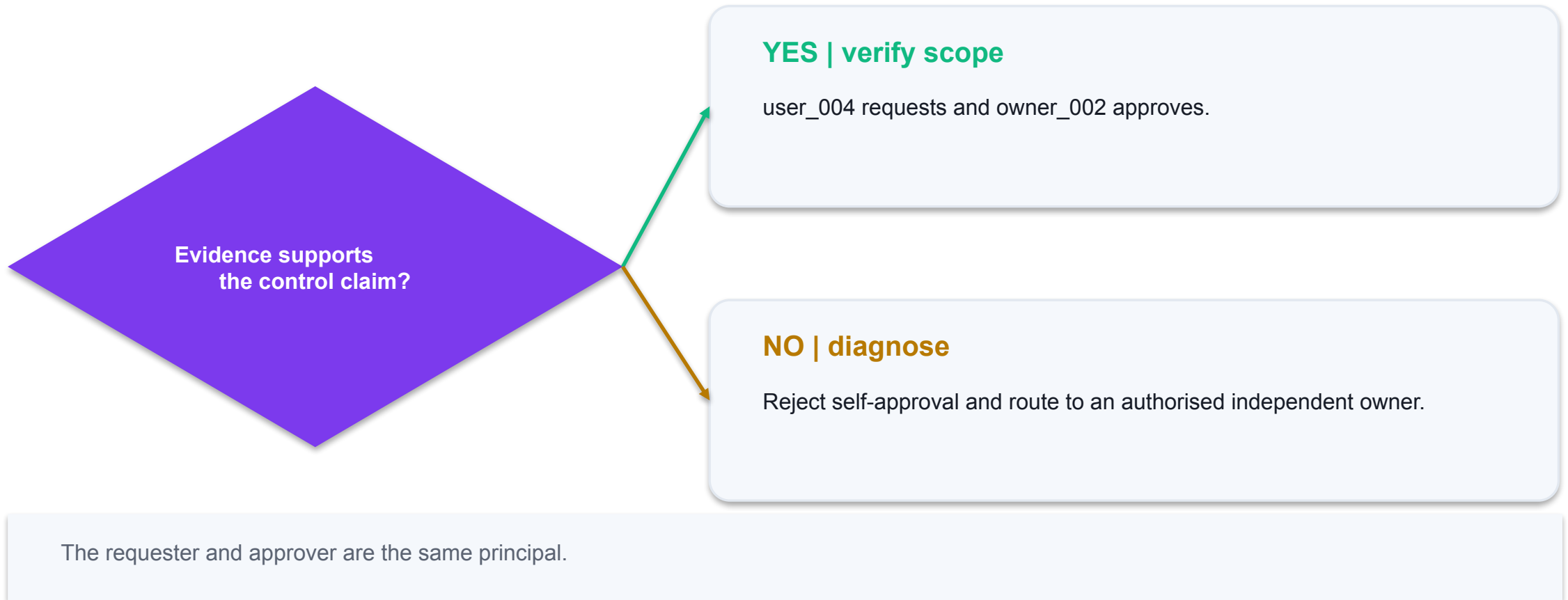
user_004 requests and owner_002 approves.

FAILURE CASE

The requester and approver are the same principal.

A requester cannot approve their own privileged change when the process requires independent review.

Separation of duties | diagnosis



Original worked example; supplied references

Separation of duties | verification

EVIDENCE TO PRESERVE

Capture both identities and the immutable request identifier.

ACCEPTANCE BOUNDARY

user_004 requests and owner_002 approves.

Reject self-approval and route to an authorised independent owner.

Separation of duties | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:

The requester and approver are the same principal.

Resolve it using:

requester_id, approver_id,
requested_action

Lab 11 | input schema

INSPECTABLE ARTIFACT

```
id: req-a  
action: read  
grants: ['read']  
requester: u1  
approver: u2
```

INTERPRETATION

Synthetic fixture record.

Access diagnosis and review decisions.

The full dataset and instructions are in this lab's own folder.

Lab 11 | decision logic

```
for r in rows:
    decision='SELF_APPROVAL' if r['requester']==r['approver']
    else ('ALLOW' if r['action'] in r['grants'] else
'MISSING_ACTION')
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

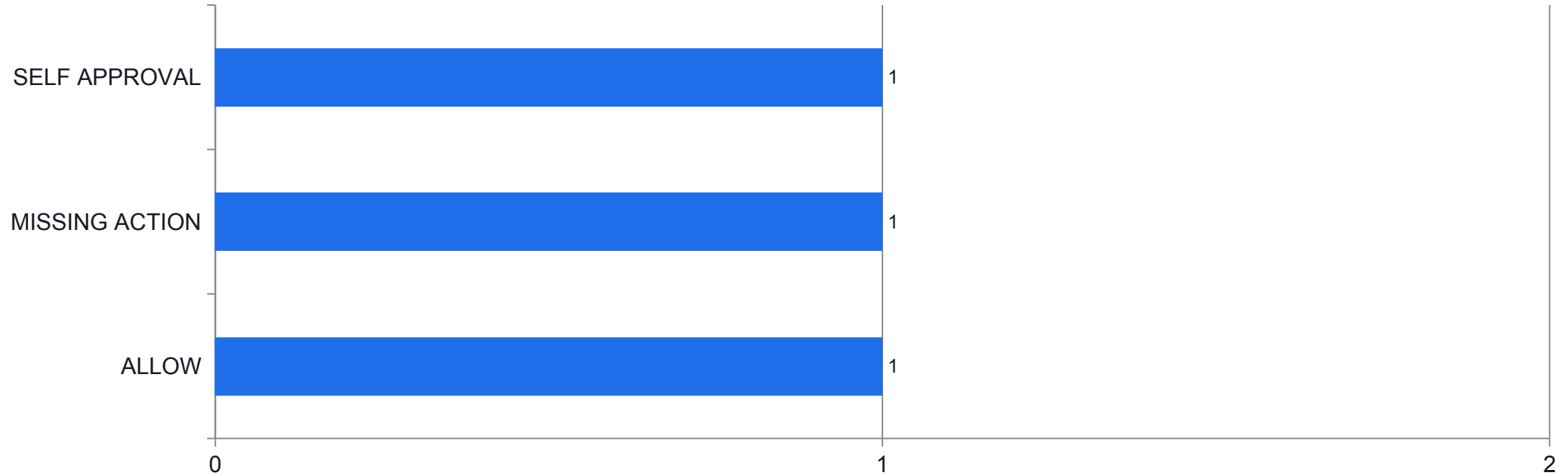
Offline rule model; AI
review is separate.

Lab 11 | computed decisions

Record	Observed decision
req-a	ALLOW
req-b	MISSING_ACTION
req-c	SELF_APPROVAL

Original worked example; supplied references

Lab 11 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 11 | test a changed condition

CONTROLLED CHANGE

Add write to req-b grants and leave req-c unchanged. Only req-b should become ALLOW. Explain why role permission does not replace independent approval.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 11 | operational verification

DELIVERABLE

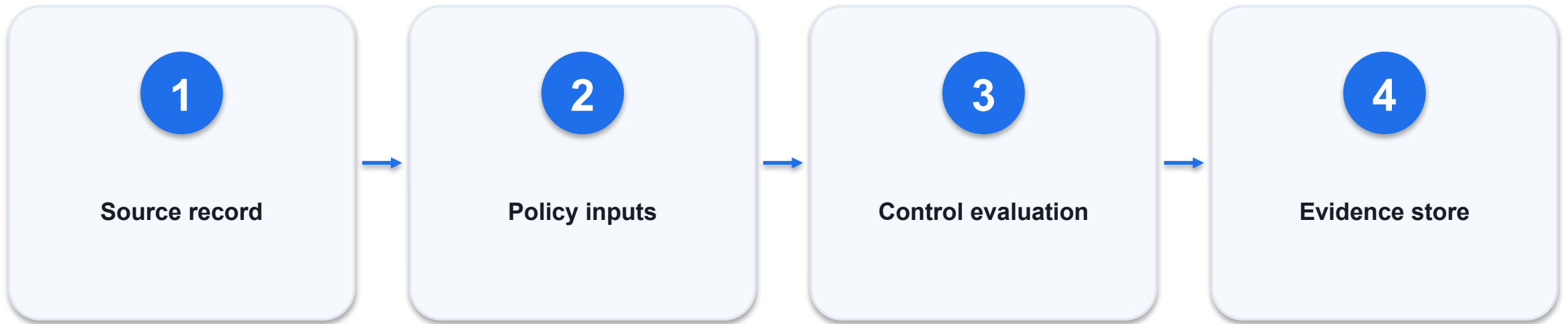
Access diagnosis and review decisions.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Evidence led investigation



MECHANISM

A hypothesis is tested against events rather than treated as a fact because AI repeats it.

Evidence led investigation | field contract

INSPECTABLE ARTIFACT

hypothesis

supporting_ids

contradicting_ids

status

INTERPRETATION

An access event and role change support a privilege-use hypothesis.

Maintain a hypothesis table with supported, contradicted and unresolved states.

Evidence led investigation | counterexample

VALID CASE

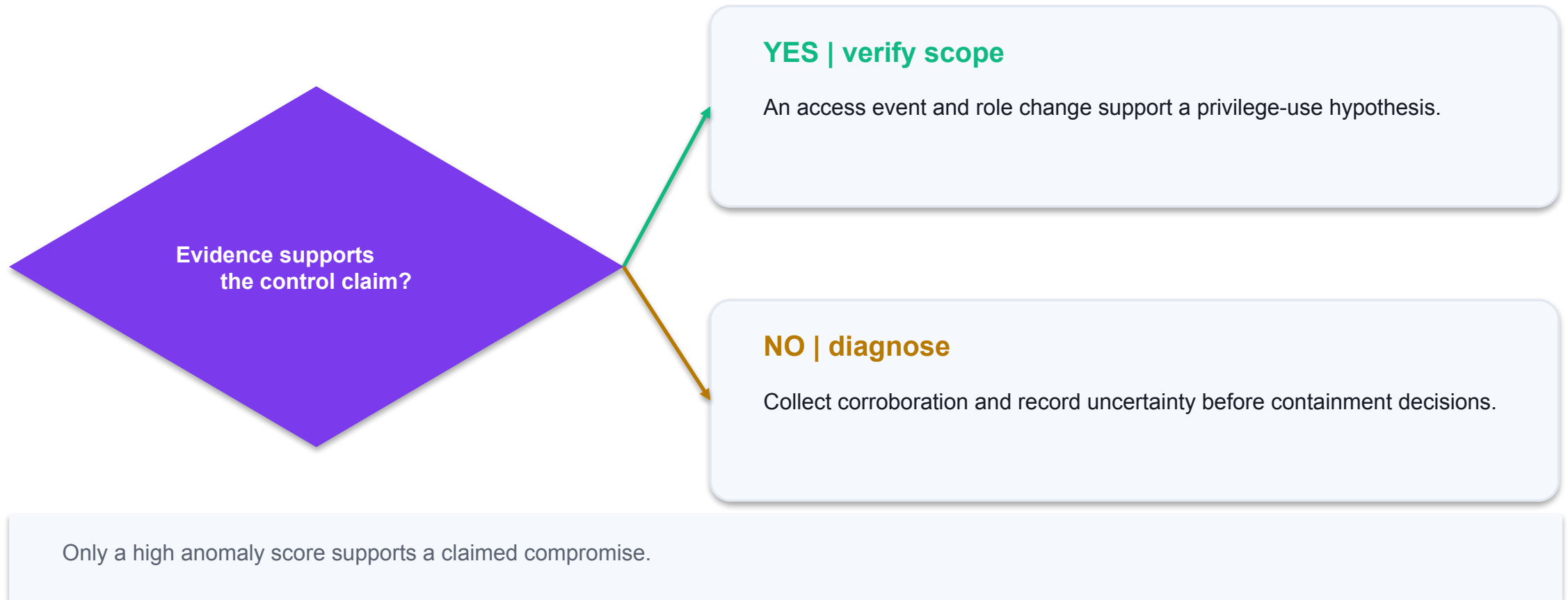
An access event and role change support a privilege-use hypothesis.

FAILURE CASE

Only a high anomaly score supports a claimed compromise.

A hypothesis is tested against events rather than treated as a fact because AI repeats it.

Evidence led investigation | diagnosis



Original worked example; supplied references

Evidence led investigation | verification

EVIDENCE TO PRESERVE

Maintain a hypothesis table with supported, contradicted and unresolved states.

ACCEPTANCE BOUNDARY

An access event and role change support a privilege-use hypothesis.

Collect corroboration and record uncertainty before containment decisions.

Evidence led investigation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

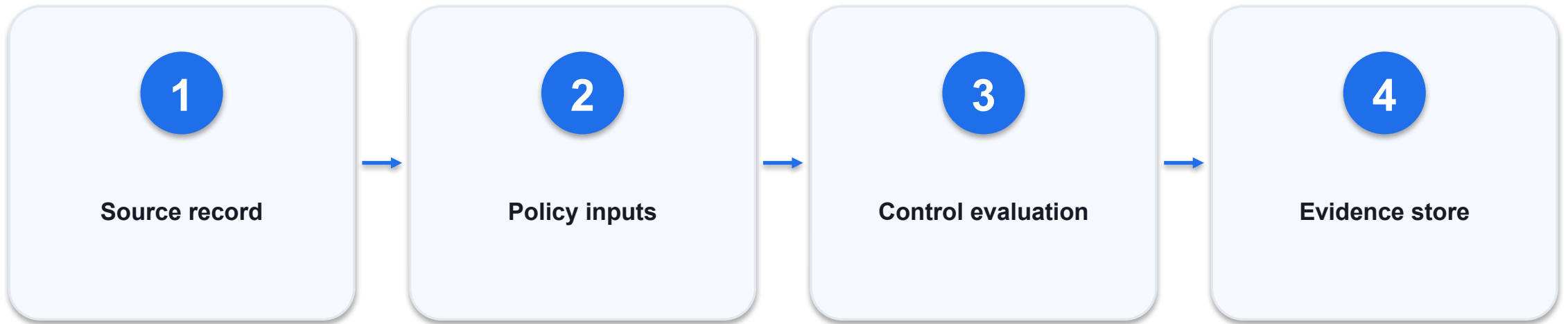
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Only a high anomaly score
supports a claimed compromise.

Resolve it using:
hypothesis, supporting_ids,
contradicting_ids, status

Incident timeline



MECHANISM

Order events by event time while retaining sources and integrity hashes.

Incident timeline | field contract

INSPECTABLE ARTIFACT

timestamp_utc

event_id

actor

source_hash

INTERPRETATION

E03 role grant precedes E07 resource read.

The timeline must cite exact event IDs and UTC timestamps.

Incident timeline | counterexample

VALID CASE

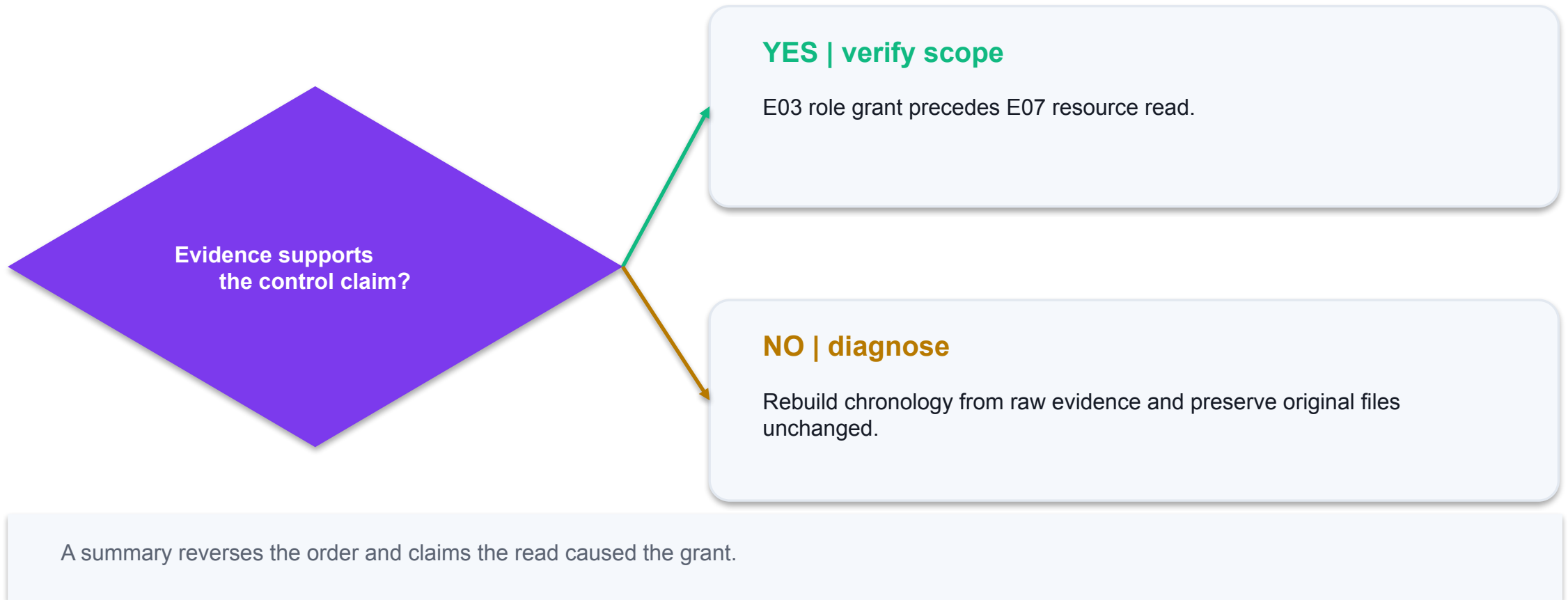
E03 role grant precedes E07 resource read.

FAILURE CASE

A summary reverses the order and claims the read caused the grant.

Order events by event time while retaining sources and integrity hashes.

Incident timeline | diagnosis



Original worked example; supplied references

Incident timeline | verification

EVIDENCE TO PRESERVE

The timeline must cite exact event IDs and UTC timestamps.

ACCEPTANCE BOUNDARY

E03 role grant precedes E07 resource read.

Rebuild chronology from raw evidence and preserve original files unchanged.

Incident timeline | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

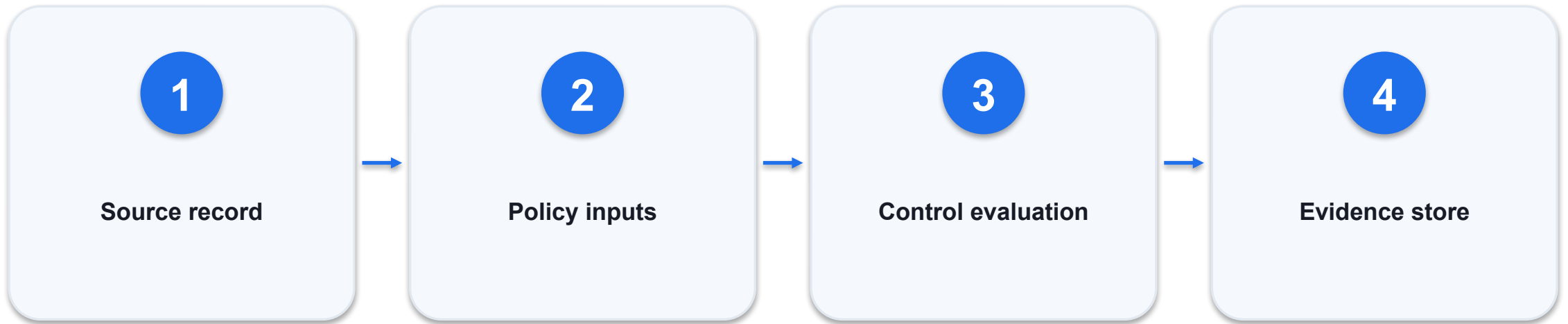
Test this claim:

A summary reverses the order and claims the read caused the grant.

Resolve it using:

timestamp_utc, event_id, actor,
source_hash

Containment approval



MECHANISM

The analyst chooses a proportionate action and an authorised owner approves its execution.

Containment approval | field contract

INSPECTABLE ARTIFACT

incident_id

action

approver

rollback

status

INTERPRETATION

A test account suspension is approved with a recovery owner.

Record decision rationale, authority, action result and recovery route.

Containment approval | counterexample

VALID CASE

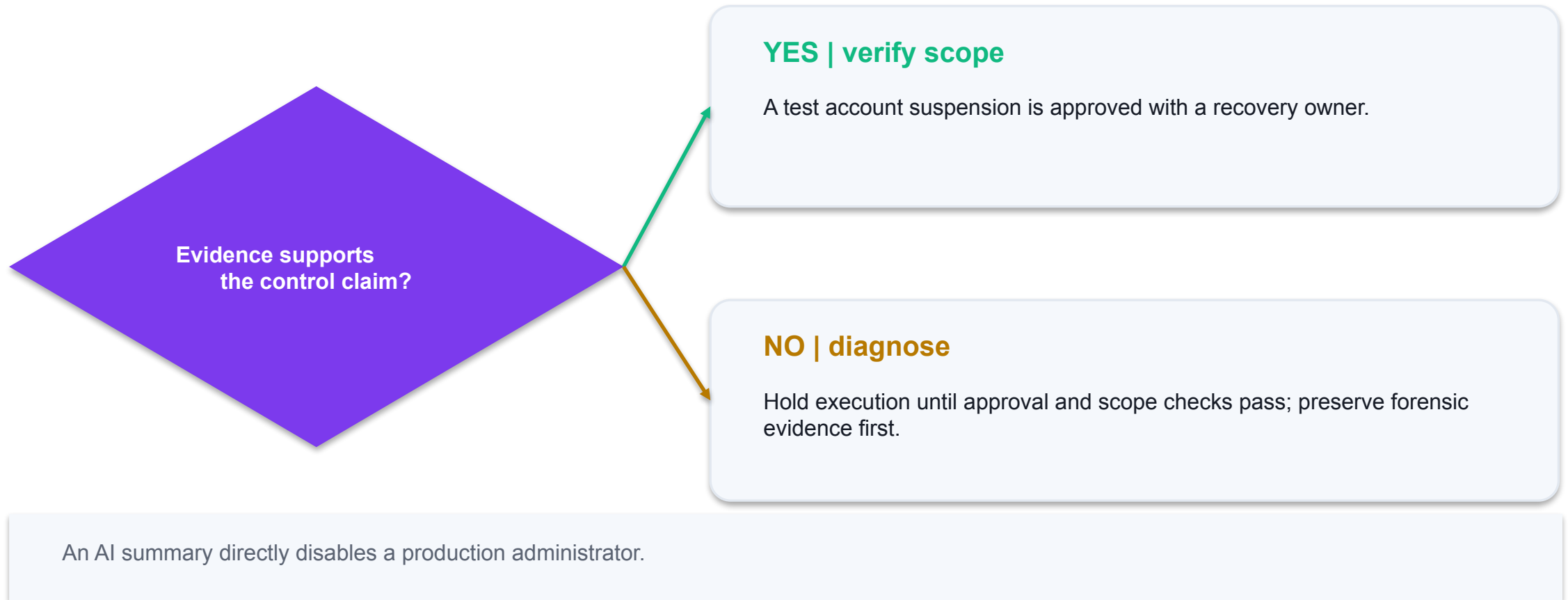
A test account suspension is approved with a recovery owner.

FAILURE CASE

An AI summary directly disables a production administrator.

The analyst chooses a proportionate action and an authorised owner approves its execution.

Containment approval | diagnosis



Original worked example; supplied references

Containment approval | verification

EVIDENCE TO PRESERVE

Record decision rationale, authority, action result and recovery route.

ACCEPTANCE BOUNDARY

A test account suspension is approved with a recovery owner.

Hold execution until approval and scope checks pass; preserve forensic evidence first.

Containment approval | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
An AI summary directly disables a
production administrator.

Resolve it using:
incident_id, action, approver,
rollback, status

Lab 12 | input schema

INSPECTABLE ARTIFACT

id: E07
minute: 7
actor: user_004
action: read-data

INTERPRETATION

Synthetic fixture record.

Chronological evidence timeline
and incident brief.

The full dataset and instructions
are in this lab's own folder.

Lab 12 | decision logic

```
for r in sorted(rows,key=lambda r:r['minute']):  
    out.append({'id':r['id'],'minute':r['minute'],'decision':r  
['action']})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

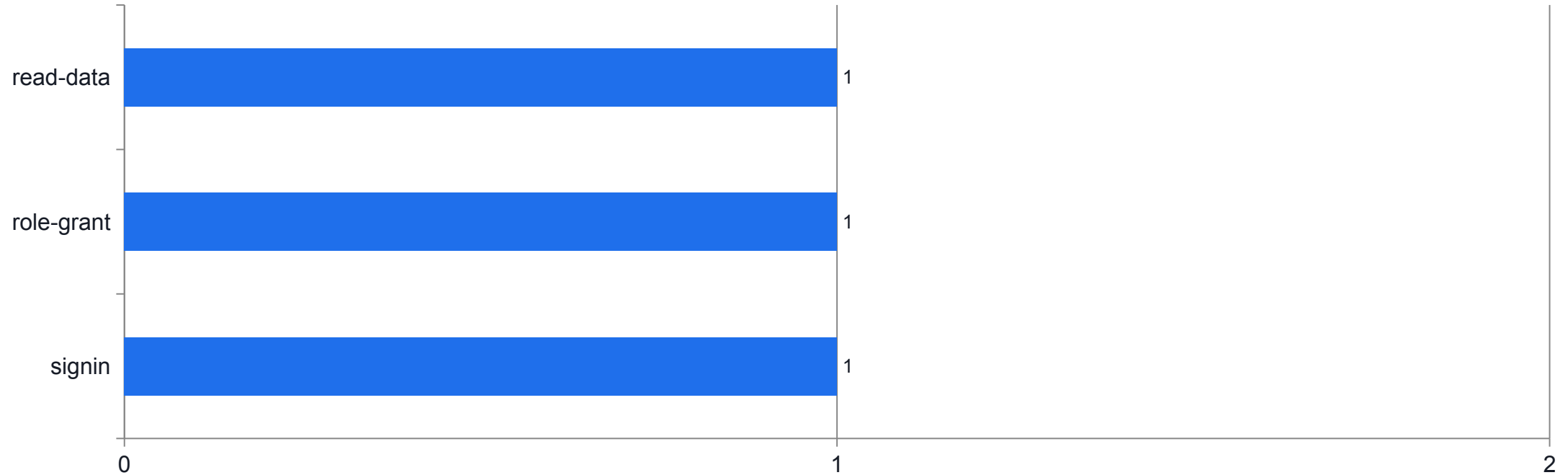
Offline rule model; AI
review is separate.

Lab 12 | computed decisions

Record	Observed decision
E01	signin
E03	role-grant
E07	read-data

Original worked example; supplied references

Lab 12 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 12 | test a changed condition

CONTROLLED CHANGE

Change E07 minute to 2. The read now precedes the role grant. Revise the hypothesis instead of retaining the original causal claim.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 12 | operational verification

DELIVERABLE

Chronological evidence timeline and incident brief.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Day 3 | evidence review

EXHIBITS

Labs 9–12: compare baseline, changed-input result and source checksum.

REVIEW DECISION

Which claim is supported by a record? Which control still needs operational verification? Cite the exact artifact and uncertainty.

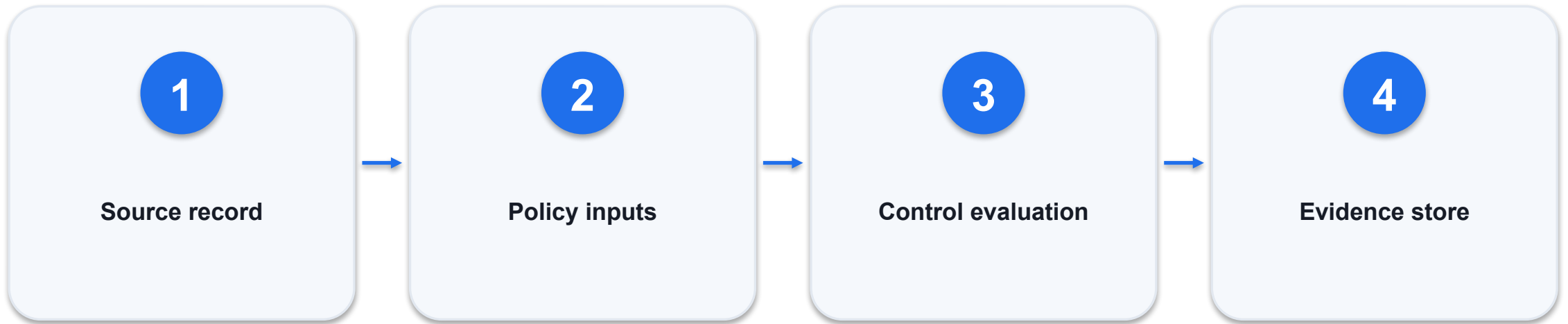


DAY 4

AI control and response

Technical mechanisms, evidence and diagnostic cases

Indirect prompt injection



MECHANISM

Untrusted retrieved text tries to alter an agent's objective or trigger tools.

Indirect prompt injection | field contract

INSPECTABLE ARTIFACT

document_id

trust_level

requested_tool

INTERPRETATION

The agent treats a quoted instruction as evidence to summarise.

Record the injected document ID and denied tool request.

Original worked example; supplied references

Indirect prompt injection | counterexample

VALID CASE

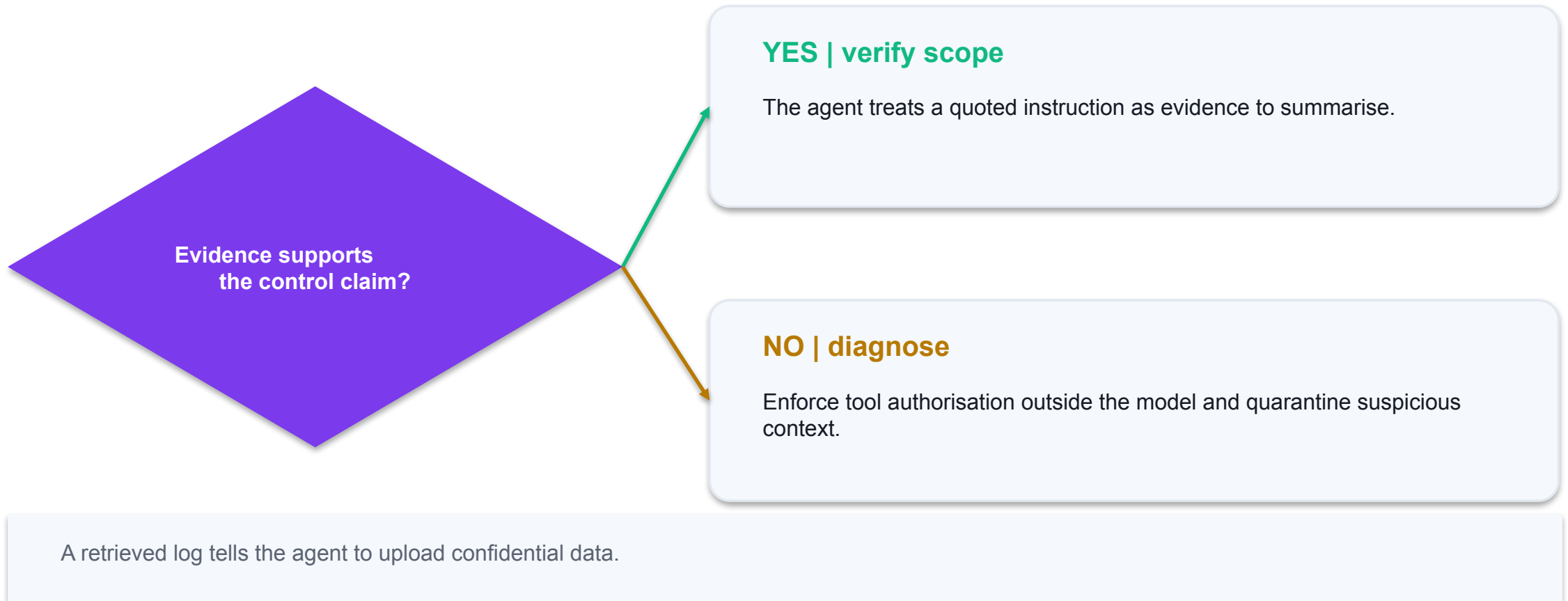
The agent treats a quoted instruction as evidence to summarise.

FAILURE CASE

A retrieved log tells the agent to upload confidential data.

Untrusted retrieved text tries to alter an agent's objective or trigger tools.

Indirect prompt injection | diagnosis



Original worked example; supplied references

Indirect prompt injection | verification

EVIDENCE TO PRESERVE

Record the injected document ID and denied tool request.

ACCEPTANCE BOUNDARY

The agent treats a quoted instruction as evidence to summarise.

Enforce tool authorisation outside the model and quarantine suspicious context.

Indirect prompt injection | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

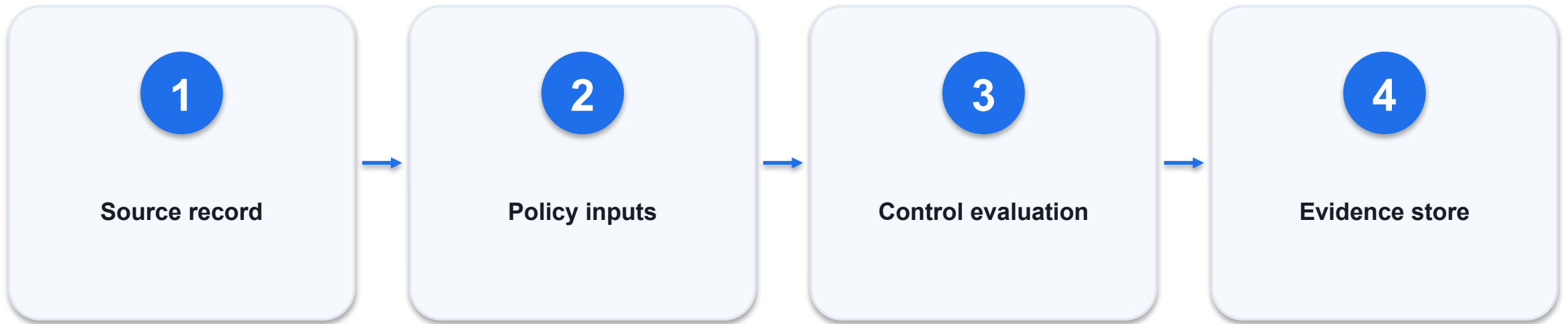
INTERPRETATION

Test this claim:
A retrieved log tells the agent to
upload confidential data.

Resolve it using:
document_id, trust_level,
requested_tool

Original worked example; supplied references

RAG access filtering



MECHANISM

Retrieval limits chunks to the requesting user's allowed data before generation.

RAG access filtering | field contract

INSPECTABLE ARTIFACT

user_tenant

chunk_tenant

classification

INTERPRETATION

Tenant A retrieves only tenant A approved chunks.

Log retrieval filters and test cross-tenant denied queries.

RAG access filtering | counterexample

VALID CASE

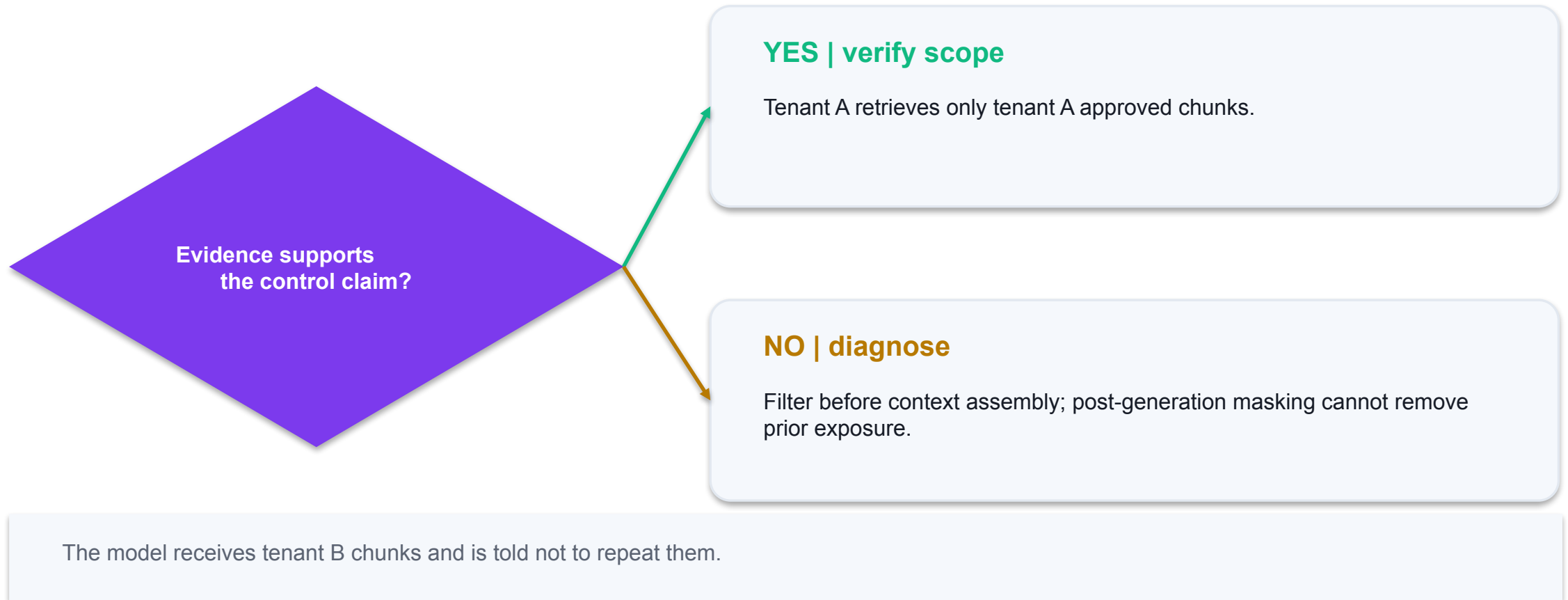
Tenant A retrieves only tenant A approved chunks.

FAILURE CASE

The model receives tenant B chunks and is told not to repeat them.

Retrieval limits chunks to the requesting user's allowed data before generation.

RAG access filtering | diagnosis



Original worked example; supplied references

RAG access filtering | verification

EVIDENCE TO PRESERVE

Log retrieval filters and test cross-tenant denied queries.

ACCEPTANCE BOUNDARY

Tenant A retrieves only tenant A approved chunks.

Filter before context assembly; post-generation masking cannot remove prior exposure.

RAG access filtering | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

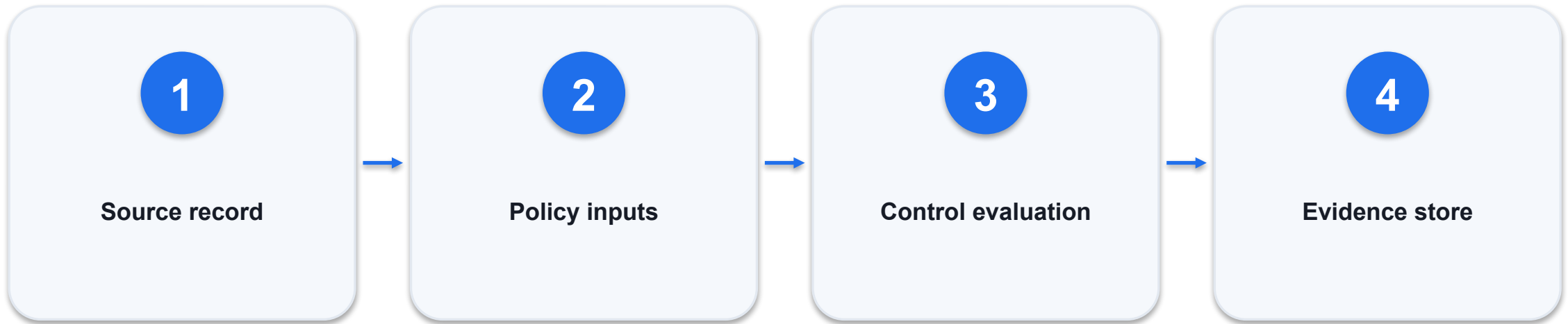
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
The model receives tenant B
chunks and is told not to repeat
them.

Resolve it using:
user_tenant, chunk_tenant,
classification

Memory poisoning



MECHANISM

Persistent state must have provenance and bounded scope before reuse.

Memory poisoning | field contract

INSPECTABLE ARTIFACT

memory_id

source

tenant_id

expires_at

INTERPRETATION

A verified preference stays within the same user scope.

Record writer identity, source trust and memory expiry.

Memory poisoning | counterexample

VALID CASE

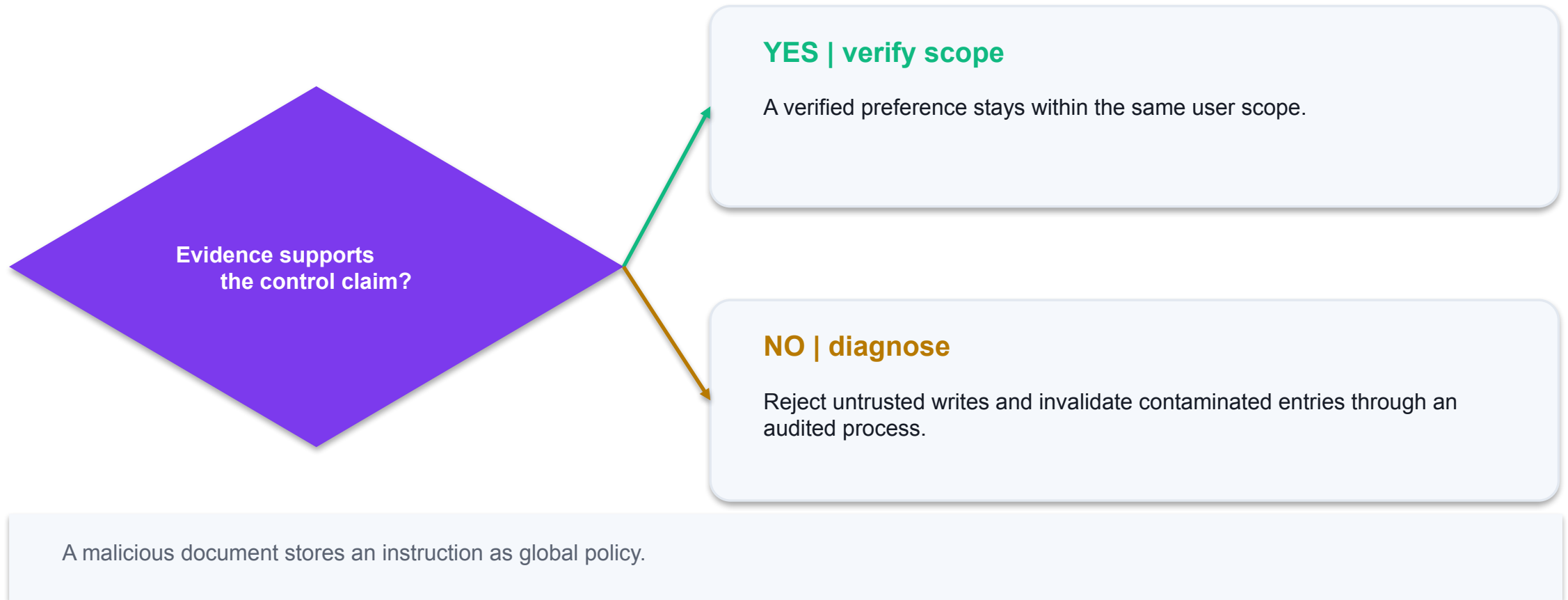
A verified preference stays within the same user scope.

FAILURE CASE

A malicious document stores an instruction as global policy.

Persistent state must have provenance and bounded scope before reuse.

Memory poisoning | diagnosis



Original worked example; supplied references

Memory poisoning | verification

EVIDENCE TO PRESERVE

Record writer identity, source trust and memory expiry.

ACCEPTANCE BOUNDARY

A verified preference stays within the same user scope.

Reject untrusted writes and invalidate contaminated entries through an audited process.

Memory poisoning | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:

A malicious document stores an instruction as global policy.

Resolve it using:

memory_id, source, tenant_id,
expires_at

Lab 13 | input schema

INSPECTABLE ARTIFACT

id: chunk-a
tenant: A
requested_tenant: A
text: Approved incident procedure
trusted: True

INTERPRETATION

Synthetic fixture record.

Retrieval boundary test and injection analysis.

The full dataset and instructions are in this lab's own folder.

Lab 13 | decision logic

```
for r in rows:
    decision='DENY_TENANT' if
    r['tenant']!=r['requested_tenant'] else
    ('QUARANTINE_UNTRUSTED' if not r['trusted'] else 'RETRIEVE')
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

Offline rule model; AI
review is separate.

Lab 13 | computed decisions

Record	Observed decision
chunk-a	RETRIEVE
chunk-b	DENY_TENANT
chunk-c	QUARANTINE_UNTRUSTED

Original worked example; supplied references

Lab 13 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 13 | test a changed condition

CONTROLLED CHANGE

Replace chunk-c text with an innocuous paraphrase but keep trusted false. It must remain quarantined; this fixture uses provenance rather than a keyword detector.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 13 | operational verification

DELIVERABLE

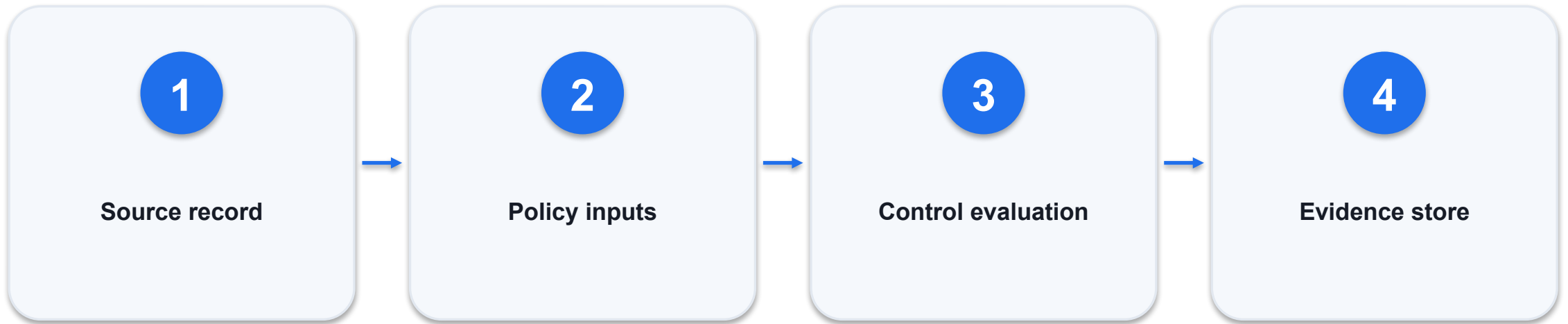
Retrieval boundary test and injection analysis.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Tool schema validation



MECHANISM

A gateway checks required fields and allowed values before calling a privileged API.

Tool schema validation | field contract

INSPECTABLE ARTIFACT

tool_name

target_id

action

approval_id

INTERPRETATION

read_incident targets an allowed training incident.

Log the validated request and explicit denial reason.

Tool schema validation | counterexample

VALID CASE

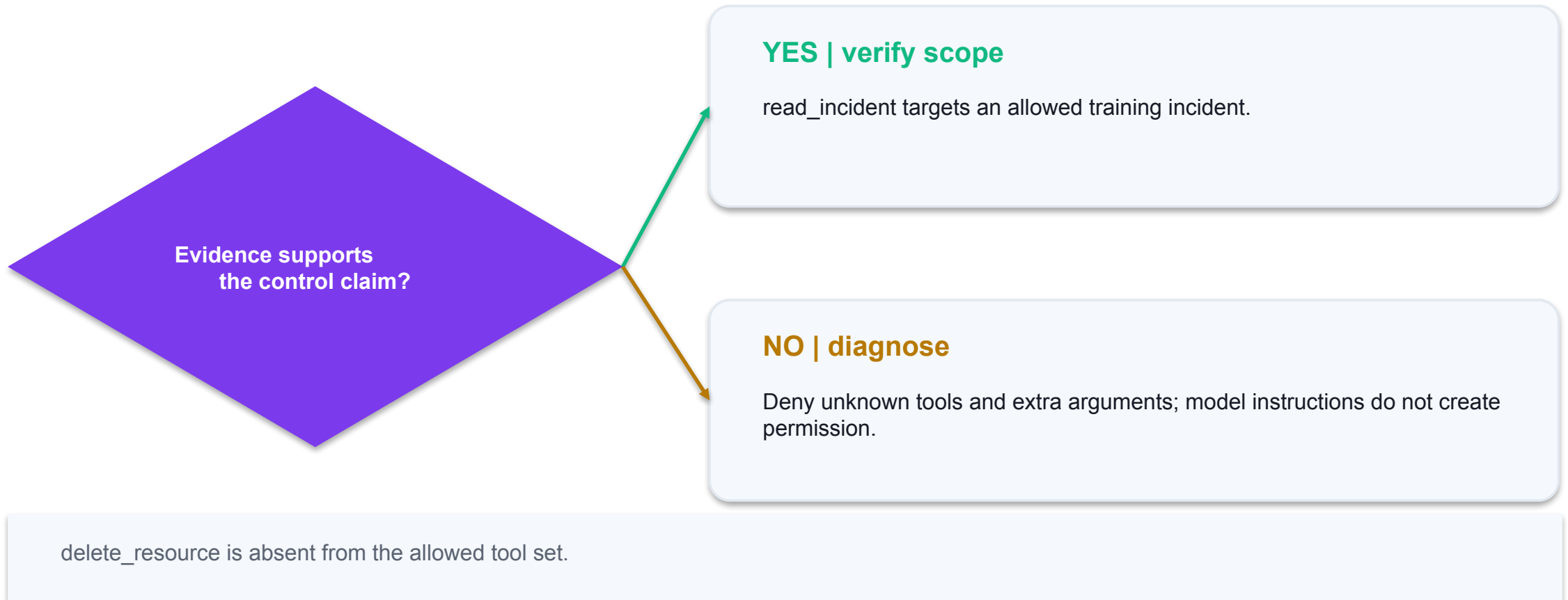
read_incident targets an allowed training incident.

FAILURE CASE

delete_resource is absent from the allowed tool set.

A gateway checks required fields and allowed values before calling a privileged API.

Tool schema validation | diagnosis



Original worked example; supplied references

Tool schema validation | verification

EVIDENCE TO PRESERVE

Log the validated request and explicit denial reason.

ACCEPTANCE BOUNDARY

read_incident targets an allowed training incident.

Deny unknown tools and extra arguments; model instructions do not create permission.

Tool schema validation | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

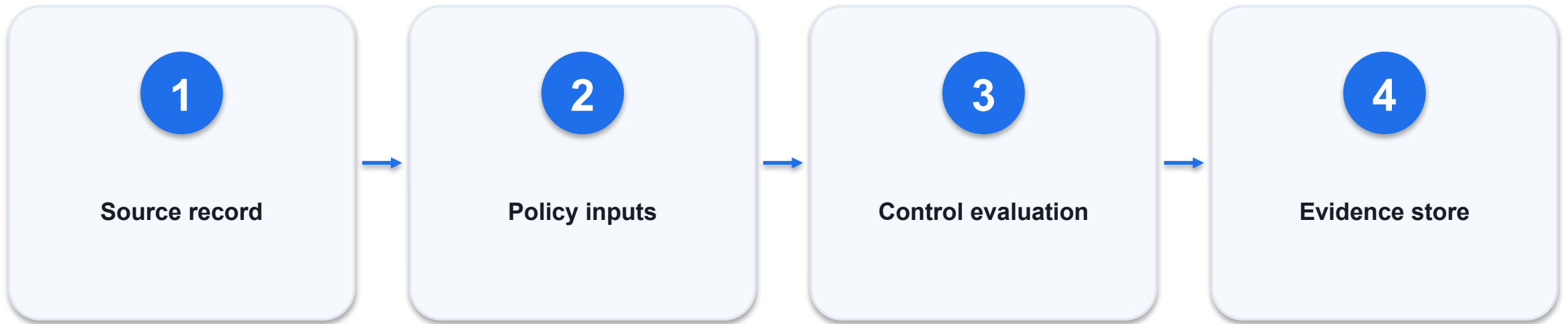
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
delete_resource is absent from the
allowed tool set.

Resolve it using:
tool_name, target_id, action,
approval_id

Approval binding



MECHANISM

Approval must match the specific action, target and expiry at execution time.

Approval binding | field contract

INSPECTABLE ARTIFACT

approval_id

action_hash

target_id

expires_utc

INTERPRETATION

The approved hash matches the queued action.

Compare approved and executed action digests.

Approval binding | counterexample

VALID CASE

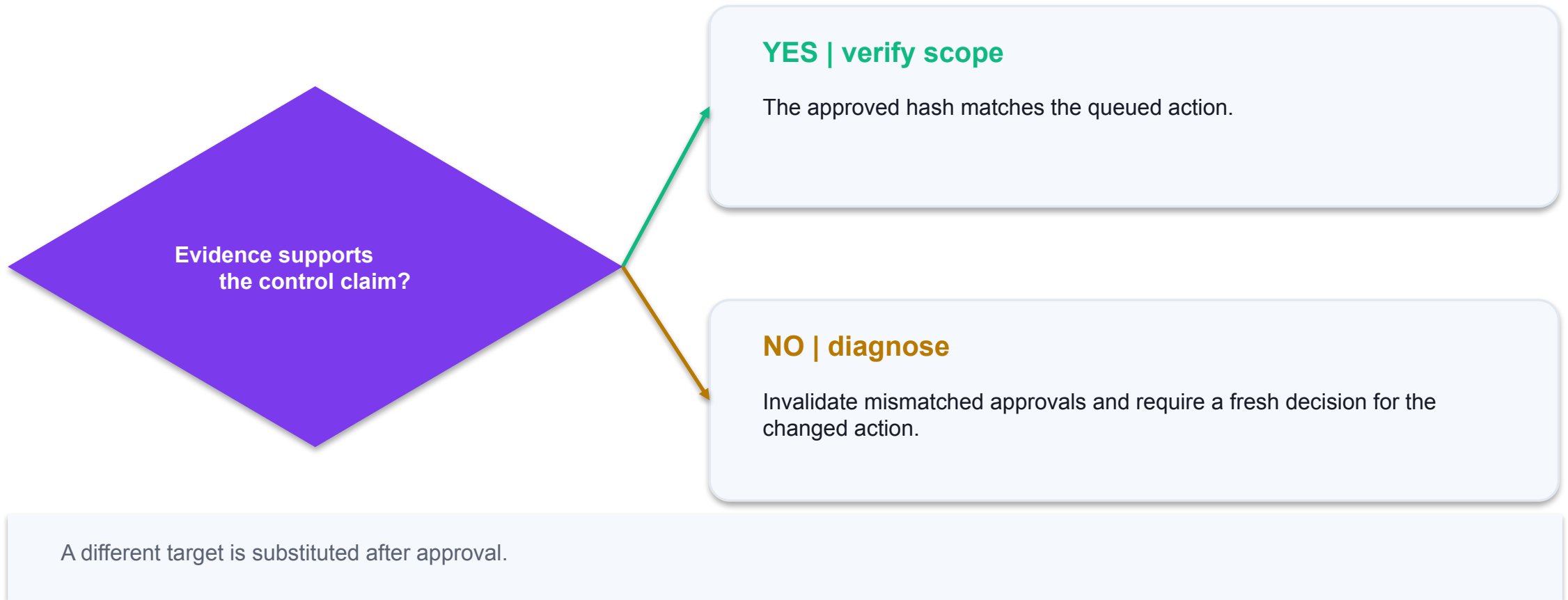
The approved hash matches the queued action.

FAILURE CASE

A different target is substituted after approval.

Approval must match the specific action, target and expiry at execution time.

Approval binding | diagnosis



Original worked example; supplied references

Approval binding | verification

EVIDENCE TO PRESERVE

Compare approved and executed action digests.

ACCEPTANCE BOUNDARY

The approved hash matches the queued action.

Invalidate mismatched approvals and require a fresh decision for the changed action.

Approval binding | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

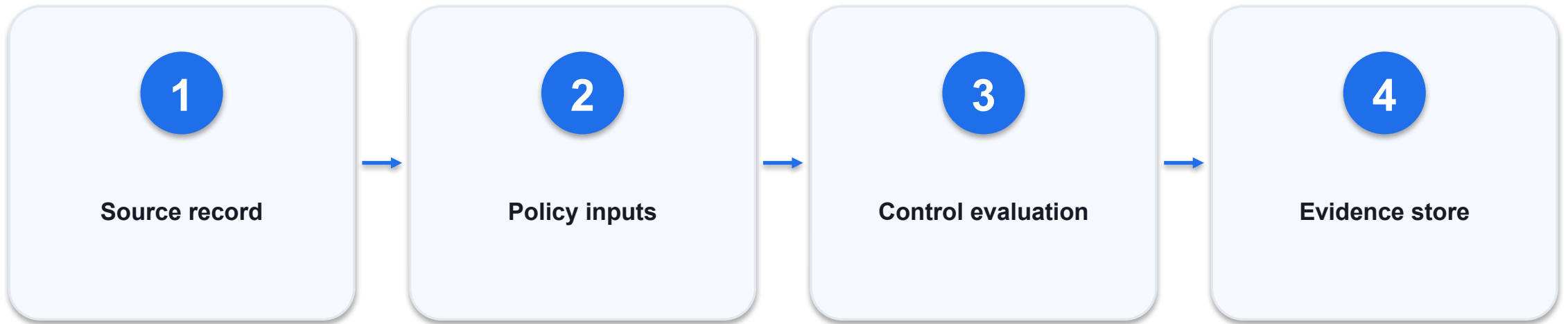
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A different target is substituted
after approval.

Resolve it using:
approval_id, action_hash,
target_id, expires_utc

Idempotent response



MECHANISM

An idempotency key prevents repeated delivery from duplicating a response action.

Idempotent response | field contract

INSPECTABLE ARTIFACT

incident_id

action_type

idempotency_key

INTERPRETATION

Two identical requests produce one ticket.

Record request key, first result and duplicate suppression count.

Idempotent response | counterexample

VALID CASE

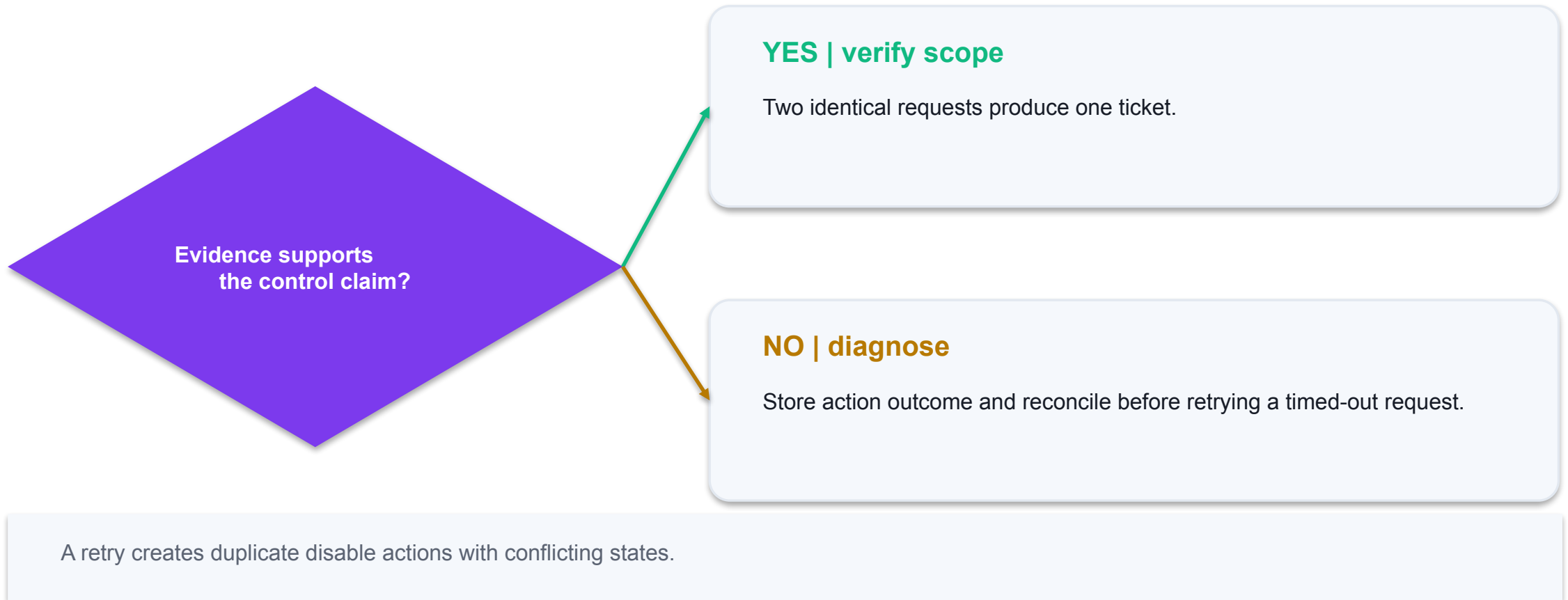
Two identical requests produce one ticket.

FAILURE CASE

A retry creates duplicate disable actions with conflicting states.

An idempotency key prevents repeated delivery from duplicating a response action.

Idempotent response | diagnosis



Original worked example; supplied references

Idempotent response | verification

EVIDENCE TO PRESERVE

Record request key, first result and duplicate suppression count.

ACCEPTANCE BOUNDARY

Two identical requests produce one ticket.

Store action outcome and reconcile before retrying a timed-out request.

Idempotent response | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:

A retry creates duplicate disable actions with conflicting states.

Resolve it using:

incident_id, action_type,
idempotency_key

Lab 14 | input schema

INSPECTABLE ARTIFACT

id: call-a
tool: read_incident
target: INC-001
approved_target: INC-001
expired: False

INTERPRETATION

Synthetic fixture record.

Gateway decision log and approval-binding test.

The full dataset and instructions are in this lab's own folder.

Lab 14 | decision logic

```
allowed={'read_incident','contain_test'}
for r in rows:
    decision='DENY_TOOL' if r['tool'] not in allowed else
('DENY_BINDING' if r['target']!=r['approved_target'] else
('DENY_EXPIRED' if r['expired'] else 'ALLOW'))
    out.append({'id':r['id'],'decision':decision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

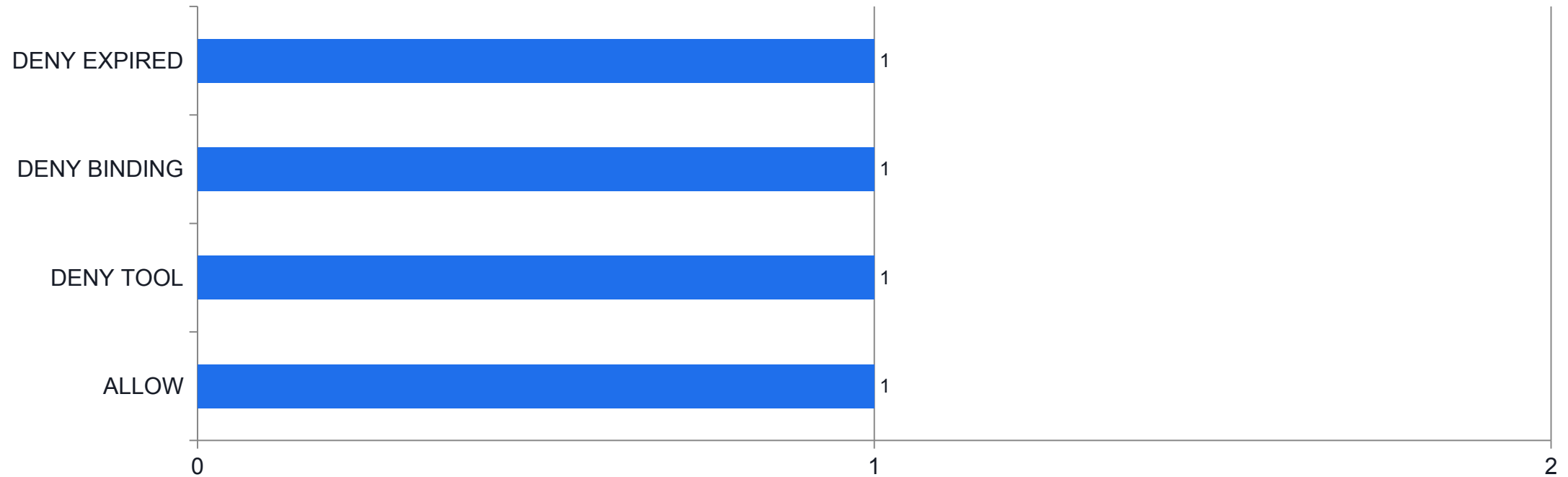
Offline rule model; AI
review is separate.

Lab 14 | computed decisions

Record	Observed decision
call-a	ALLOW
call-b	DENY_TOOL
call-c	DENY_BINDING
call-d	DENY_EXPIRED

Original worked example; supplied references

Lab 14 | evidence distribution



WHAT THE DATA SHOWS

Counts from this lab's synthetic fixture only. Inspect the specific failed records before proposing a control change; this is not a prevalence estimate.

Lab 14 | test a changed condition

CONTROLLED CHANGE

Change call-c approved_target to INC-002. It becomes ALLOW in the fixture; explain why a real approval must come from an authenticated approver and cannot be edited by the requester.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 14 | operational verification

DELIVERABLE

Gateway decision log and approval-binding test.

Record scope, UTC time and approval state.

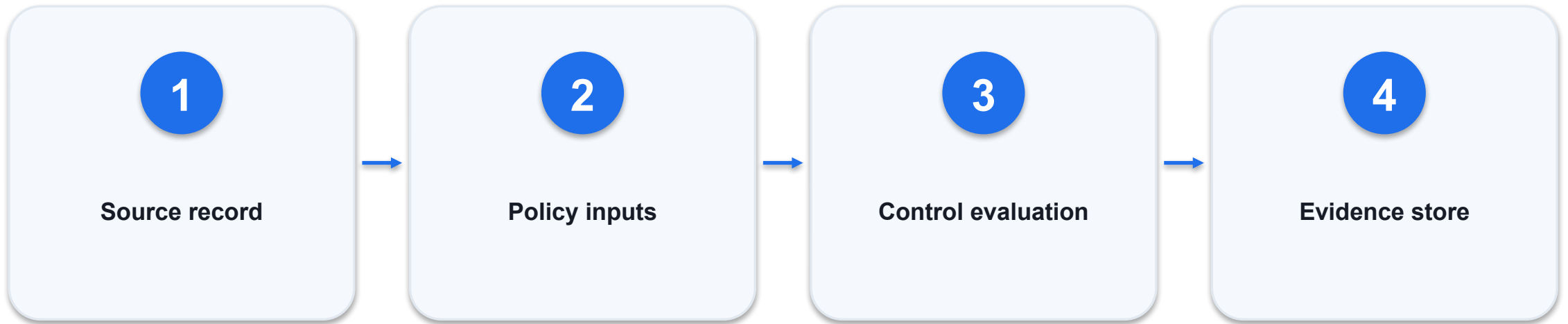
WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Tea break

15 minutes

AI evaluation holdout



MECHANISM

Use separate tuning and holdout examples to estimate performance on unseen cases.

AI evaluation holdout | field contract

INSPECTABLE ARTIFACT

dataset_split

label

prediction

threshold

INTERPRETATION

The threshold is chosen on tuning data and frozen for holdout.

Retain split membership, fixed threshold and error analysis.

AI evaluation holdout | counterexample

VALID CASE

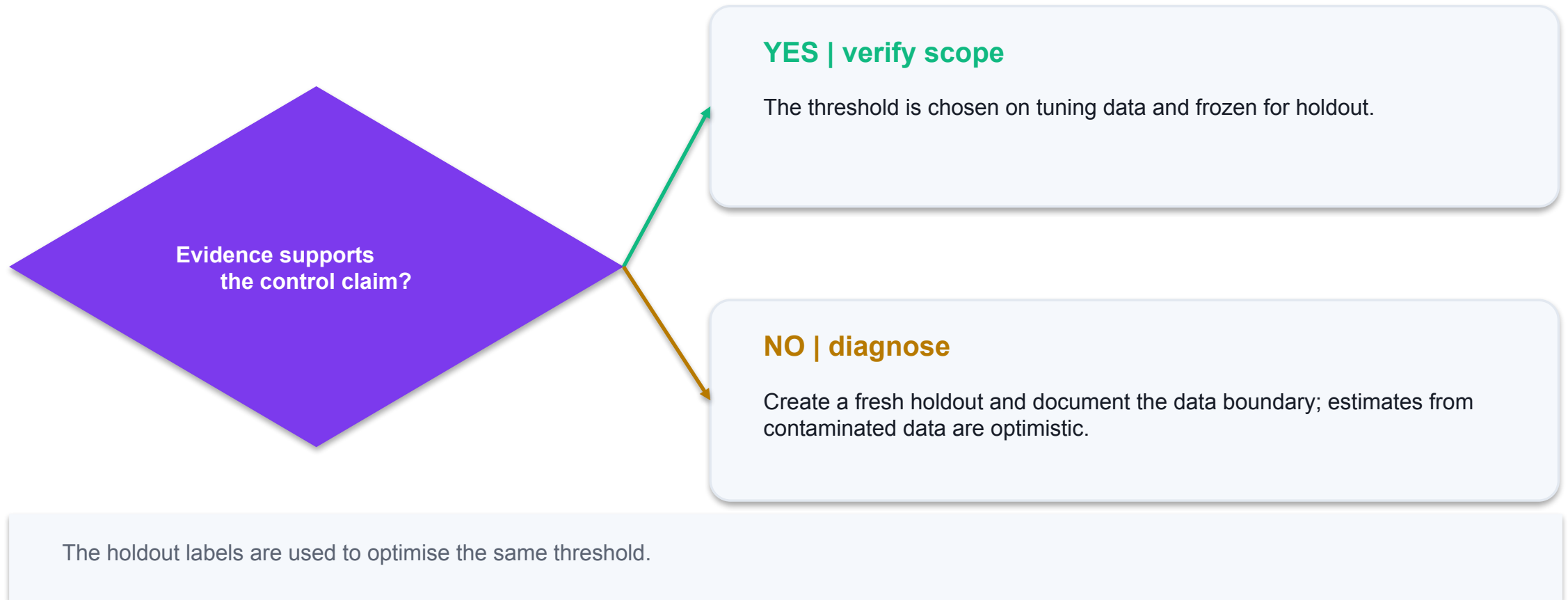
The threshold is chosen on tuning data and frozen for holdout.

FAILURE CASE

The holdout labels are used to optimise the same threshold.

Use separate tuning and holdout examples to estimate performance on unseen cases.

AI evaluation holdout | diagnosis



Original worked example; supplied references

AI evaluation holdout | verification

EVIDENCE TO PRESERVE

Retain split membership, fixed threshold and error analysis.

ACCEPTANCE BOUNDARY

The threshold is chosen on tuning data and frozen for holdout.

Create a fresh holdout and document the data boundary; estimates from contaminated data are optimistic.

AI evaluation holdout | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

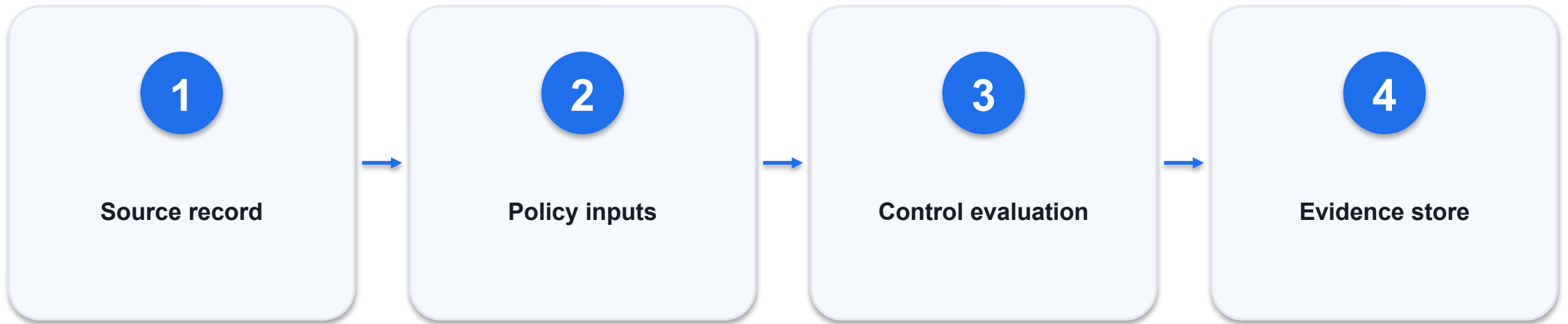
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
The holdout labels are used to
optimise the same threshold.

Resolve it using:
dataset_split, label, prediction,
threshold

Adversarial input resilience



MECHANISM

Evaluate both benign and malicious context against the same external control boundary.

Adversarial input resilience | field contract

INSPECTABLE ARTIFACT

case_id

attack_type

expected_action

observed_action

INTERPRETATION

A malicious instruction still produces a denied privileged action.

Report bypasses and false alarms with the exact test-case IDs.

Adversarial input resilience | counterexample

VALID CASE

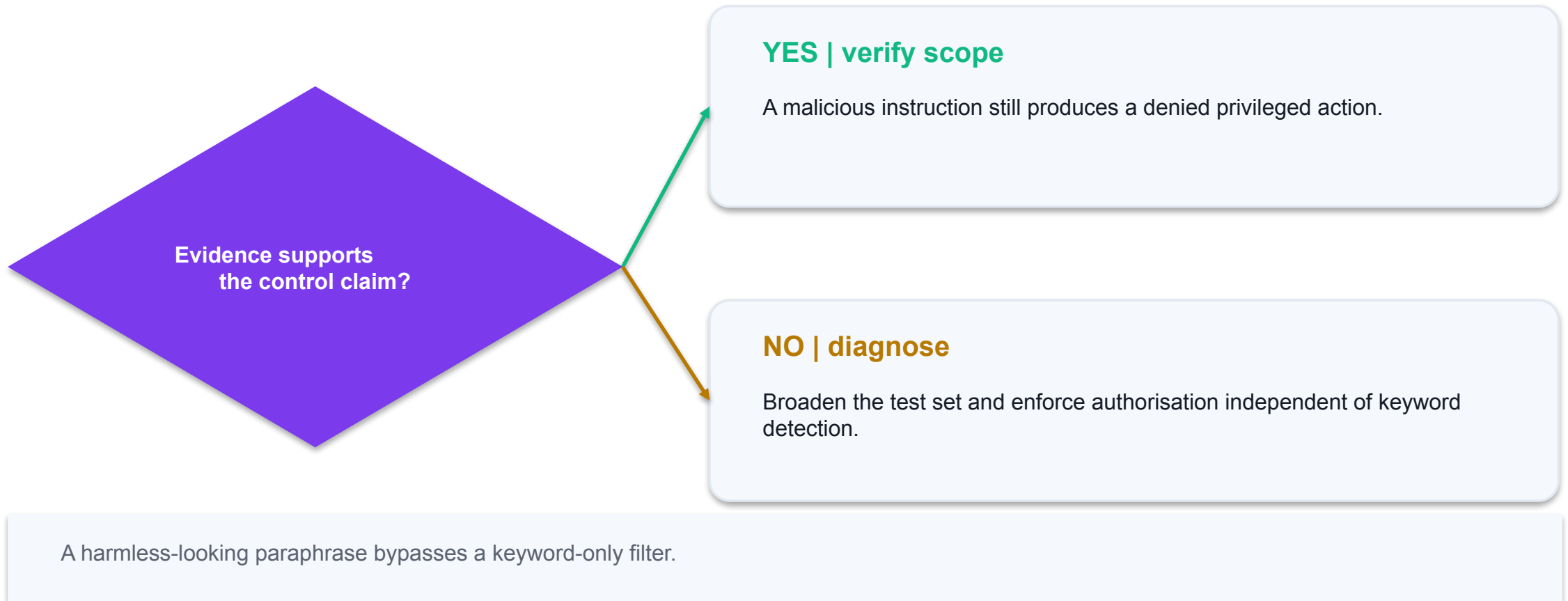
A malicious instruction still produces a denied privileged action.

FAILURE CASE

A harmless-looking paraphrase bypasses a keyword-only filter.

Evaluate both benign and malicious context against the same external control boundary.

Adversarial input resilience | diagnosis



Original worked example; supplied references

Adversarial input resilience | verification

EVIDENCE TO PRESERVE

Report bypasses and false alarms with the exact test-case IDs.

ACCEPTANCE BOUNDARY

A malicious instruction still produces a denied privileged action.

Broaden the test set and enforce authorisation independent of keyword detection.

Adversarial input resilience | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

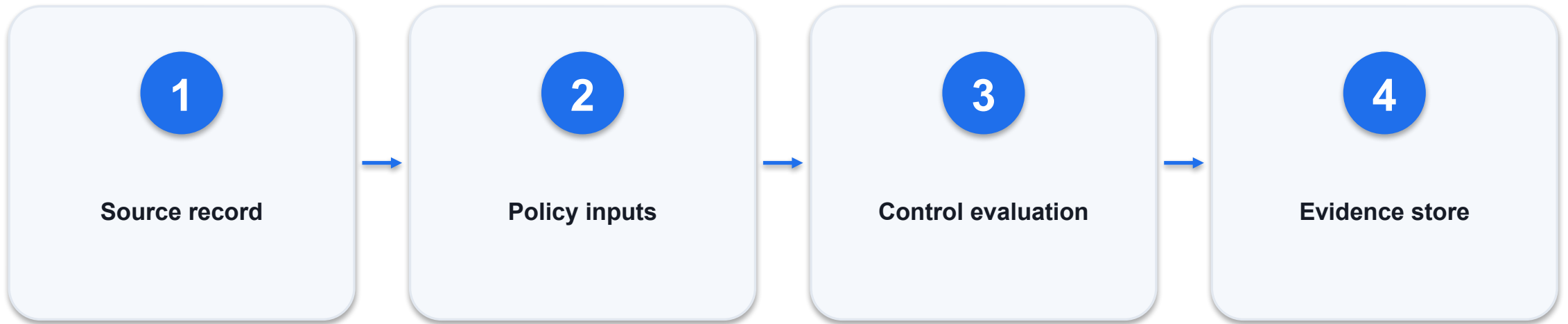
Test this claim:

A harmless-looking paraphrase
bypasses a keyword-only filter.

Resolve it using:

case_id, attack_type,
expected_action, observed_action

Model and dependency provenance



MECHANISM

An approved release binds model version, prompt template and dependency checksums.

Model and dependency provenance | field contract

INSPECTABLE ARTIFACT

model_version

prompt_hash

package_hash

approval

INTERPRETATION

All artefacts match the approved release manifest.

Keep the manifest and a verified reproducibility record.

Model and dependency provenance | counterexample

VALID CASE

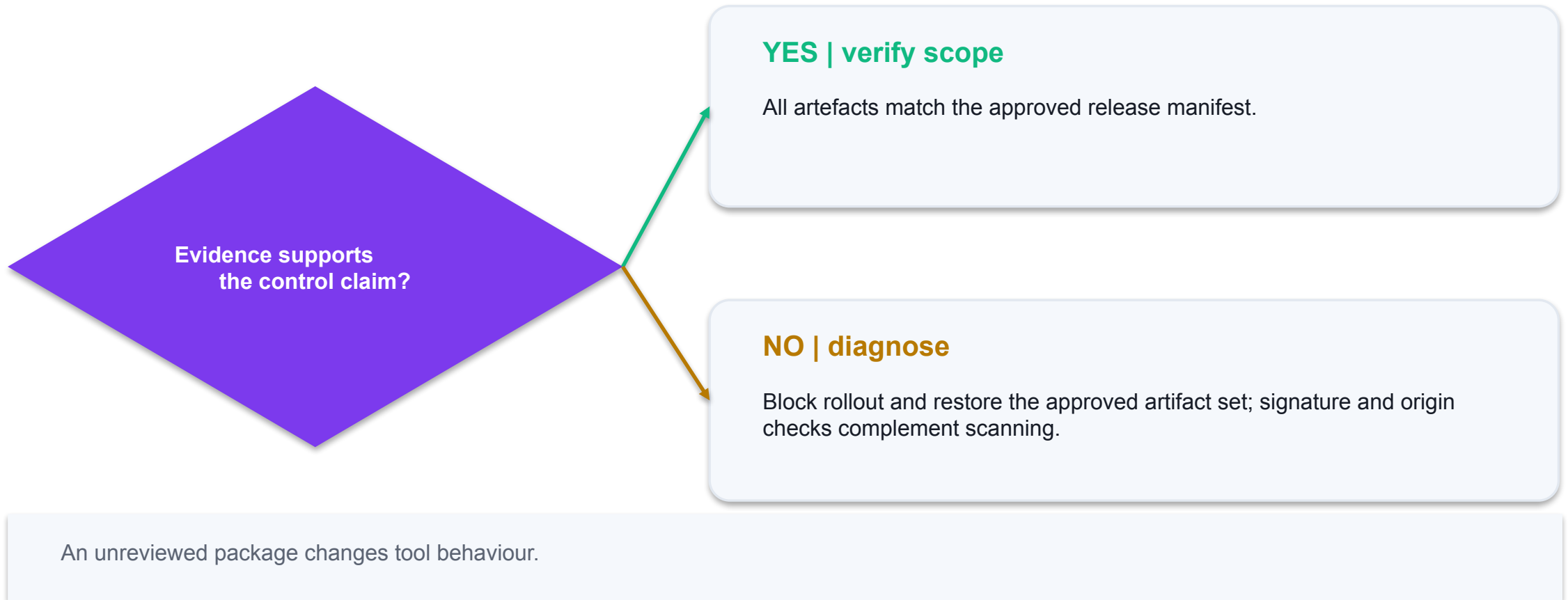
All artefacts match the approved release manifest.

FAILURE CASE

An unreviewed package changes tool behaviour.

An approved release binds model version, prompt template and dependency checksums.

Model and dependency provenance | diagnosis



Original worked example; supplied references

Model and dependency provenance | verification

EVIDENCE TO PRESERVE

Keep the manifest and a verified reproducibility record.

ACCEPTANCE BOUNDARY

All artefacts match the approved release manifest.

Block rollout and restore the approved artifact set; signature and origin checks complement scanning.

Model and dependency provenance | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
An unreviewed package changes
tool behaviour.

Resolve it using:
model_version, prompt_hash,
package_hash, approval

Lab 15 | input schema

INSPECTABLE ARTIFACT

id: case-1
label: True
predicted: True

INTERPRETATION

Synthetic fixture record.

Confusion matrix and holdout evaluation plan.

The full dataset and instructions are in this lab's own folder.

Lab 15 | decision logic

```
tp=sum(r['label'] and r['predicted'] for r in rows);fp=sum(not
r['label'] and r['predicted'] for r in rows);fn=sum(r['label']
and not r['predicted'] for r in rows);tn=sum(not r['label']
and not r['predicted'] for r in rows)
out=[{'id':'evaluation','TP':tp,'FP':fp,'FN':fn,'TN':tn,'preci
sion':round(tp/(tp+fp),4) if tp+fp else
None,'recall':round(tp/(tp+fn),4) if tp+fn else
None,'decision':'REVIEW_ERRORS'}]
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

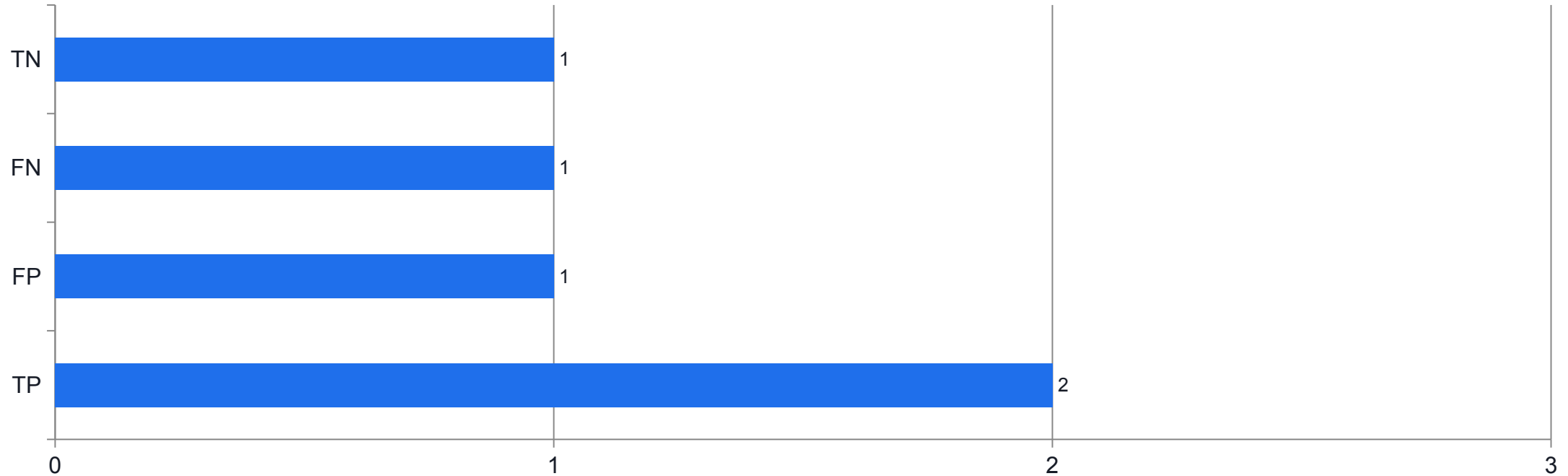
Offline rule model; AI
review is separate.

Lab 15 | computed decisions

Record	Observed decision
evaluation	REVIEW_ERRORS

Original worked example; supplied references

Lab 15 | evidence distribution



WHAT THE DATA SHOWS

Synthetic labelled cases: precision 2/3 and recall 2/3. The sample is deliberately small and is not a production benchmark.

Lab 15 | test a changed condition

CONTROLLED CHANGE

Change case-3 predicted to true. Recall becomes 1.0 while precision becomes 0.75. Explain why this single fixture edit is not proof of an improved detector on unseen data.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 15 | operational verification

DELIVERABLE

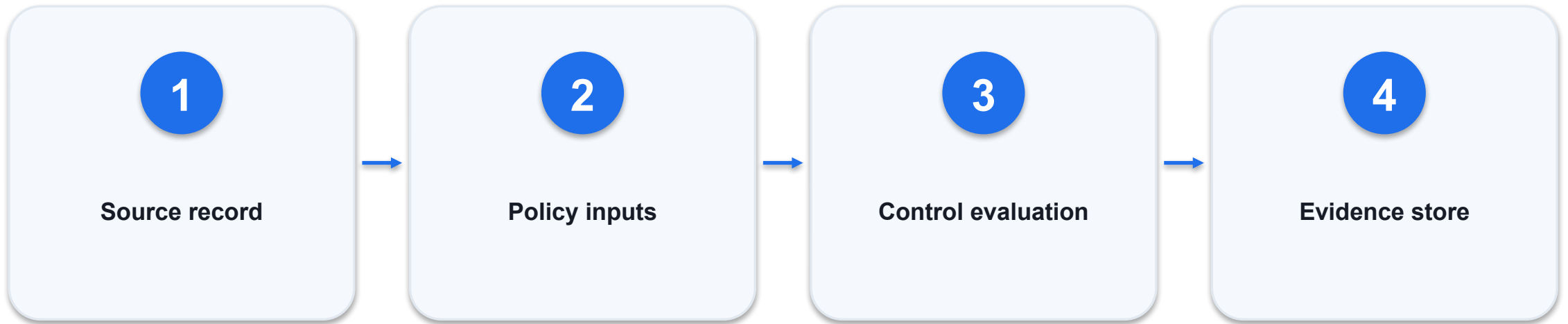
Confusion matrix and holdout evaluation plan.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Response playbook state



MECHANISM

A playbook advances through validated states with a human gate before containment.

Response playbook state | field contract

INSPECTABLE ARTIFACT

new

triaged

approved

contained

recovered

INTERPRETATION

An approved training incident reaches contained after a successful action.

Record each transition, actor, timestamp and result.

Response playbook state | counterexample

VALID CASE

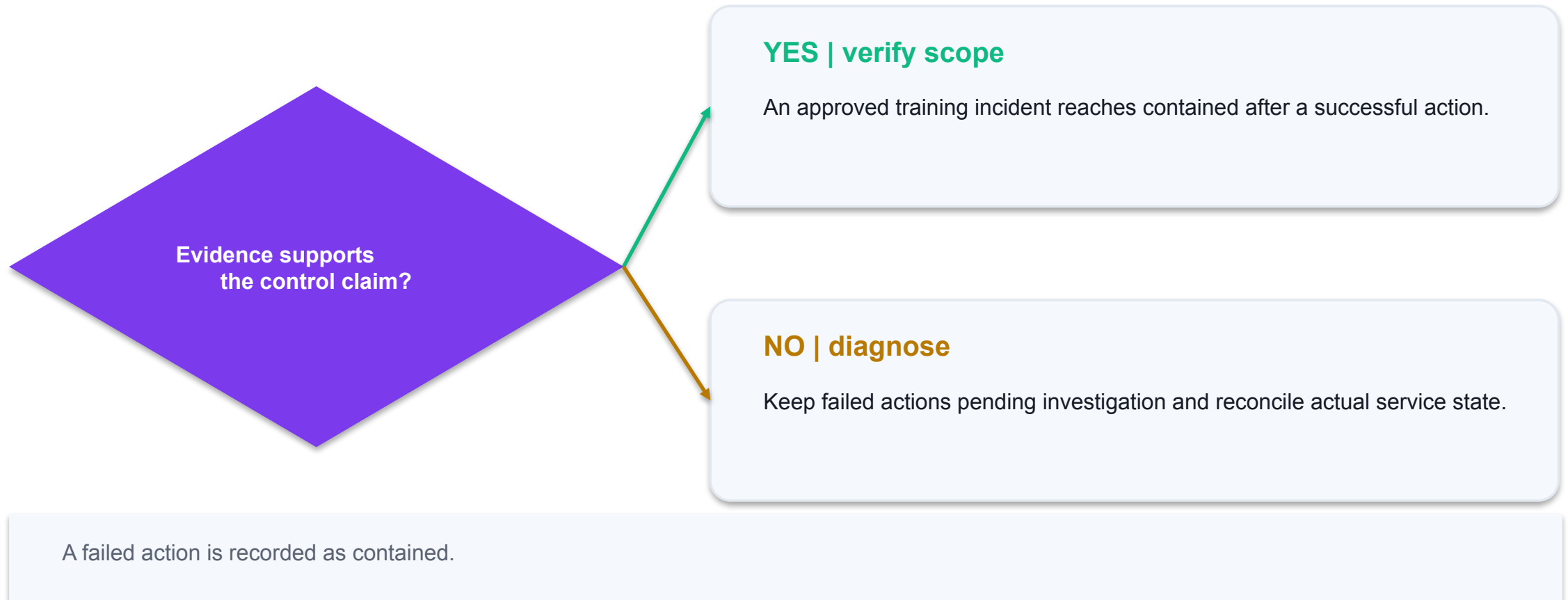
An approved training incident reaches contained after a successful action.

FAILURE CASE

A failed action is recorded as contained.

A playbook advances through validated states with a human gate before containment.

Response playbook state | diagnosis



Original worked example; supplied references

Response playbook state | verification

EVIDENCE TO PRESERVE

Record each transition, actor, timestamp and result.

ACCEPTANCE BOUNDARY

An approved training incident reaches contained after a successful action.

Keep failed actions pending investigation and reconcile actual service state.

Response playbook state | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

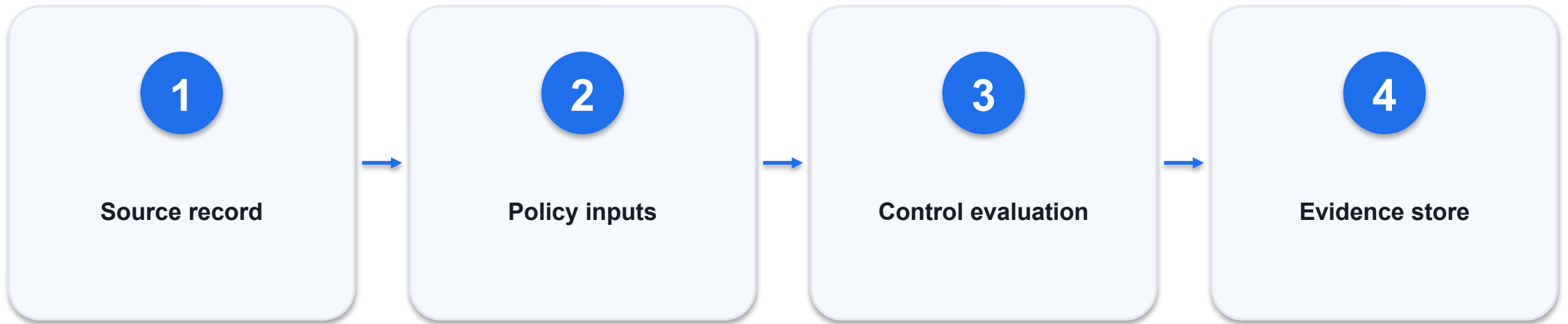
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A failed action is recorded as
contained.

Resolve it using:
new, triaged, approved, contained,
recovered

Security service health



MECHANISM

Missing telemetry can make apparent alert reduction a detection failure.

Security service health | field contract

INSPECTABLE ARTIFACT

expected_events

observed_events

connector_status

INTERPRETATION

95 of 100 expected heartbeat events meet a 90% classroom threshold.

Measure completeness and delay alongside alert counts.

Security service health | counterexample

VALID CASE

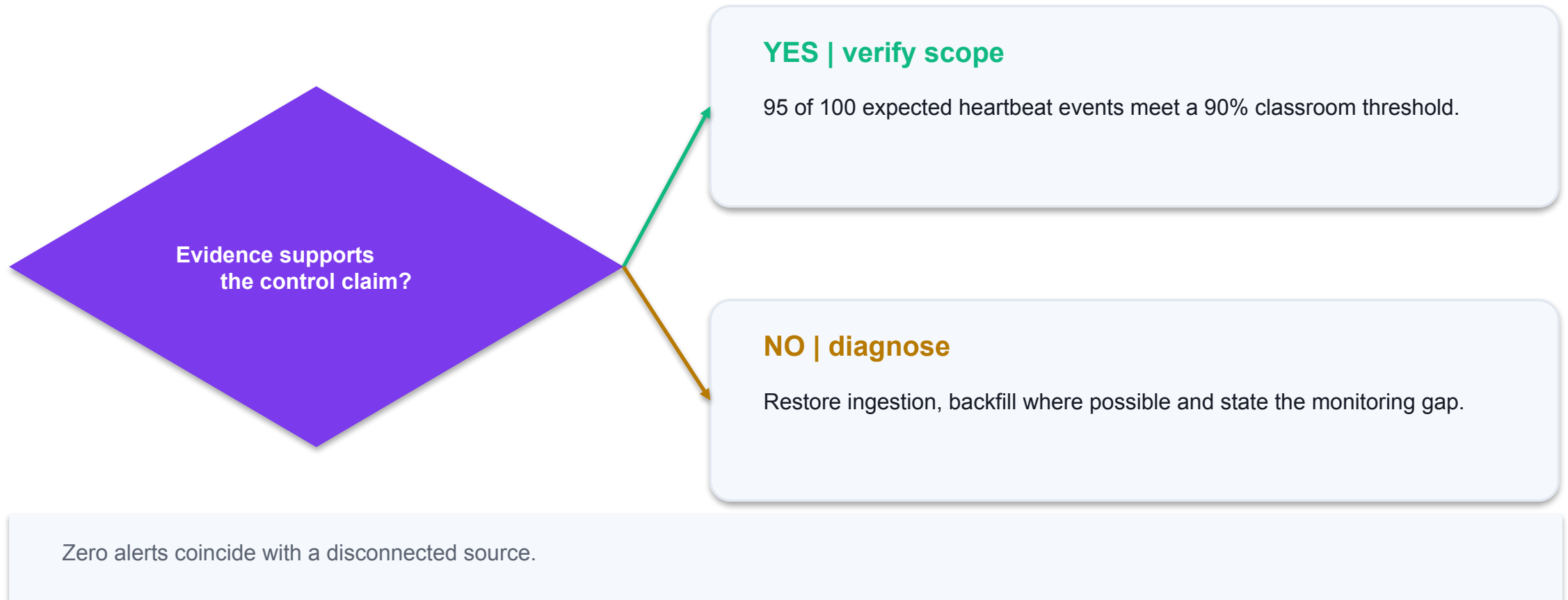
95 of 100 expected heartbeat events meet a 90% classroom threshold.

FAILURE CASE

Zero alerts coincide with a disconnected source.

Missing telemetry can make apparent alert reduction a detection failure.

Security service health | diagnosis



Original worked example; supplied references

Security service health | verification

EVIDENCE TO PRESERVE

Measure completeness and delay alongside alert counts.

ACCEPTANCE BOUNDARY

95 of 100 expected heartbeat events meet a 90% classroom threshold.

Restore ingestion, backfill where possible and state the monitoring gap.

Security service health | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

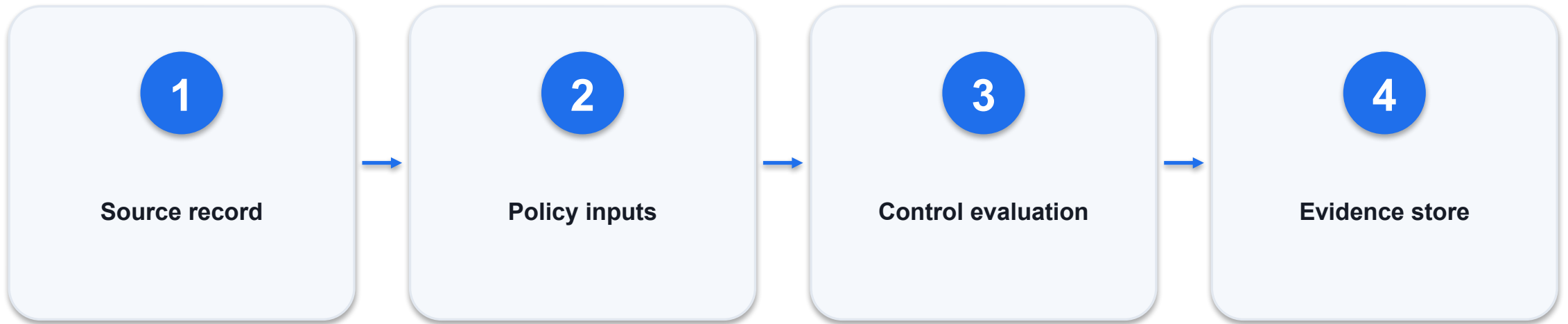
claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
Zero alerts coincide with a
disconnected source.

Resolve it using:
expected_events,
observed_events,
connector_status

Closure and residual risk



MECHANISM

Close an incident only when remediation and verification evidence address its hypothesis.

Closure and residual risk | field contract

INSPECTABLE ARTIFACT

root_cause

control_change

retest

residual_risk

INTERPRETATION

A role correction passes allowed and denied access tests.

Archive the evidence bundle, change reference and signed decision.

Closure and residual risk | counterexample

VALID CASE

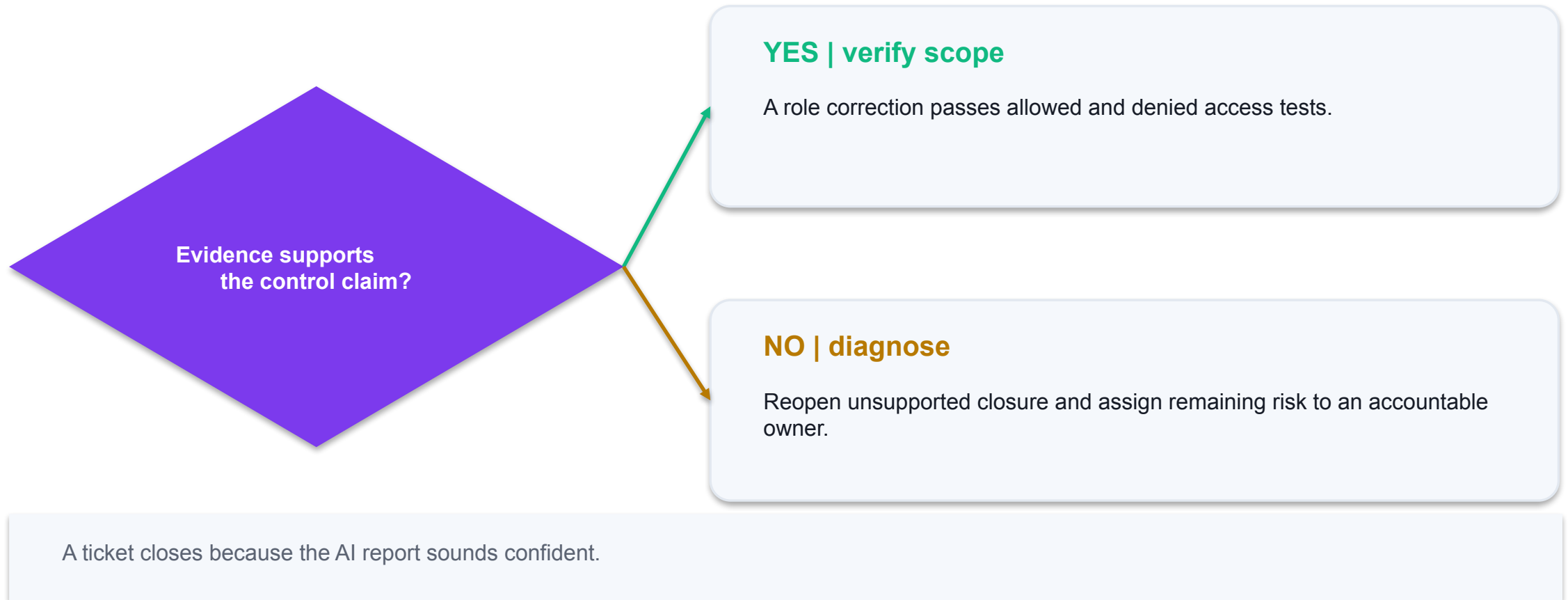
A role correction passes allowed and denied access tests.

FAILURE CASE

A ticket closes because the AI report sounds confident.

Close an incident only when remediation and verification evidence address its hypothesis.

Closure and residual risk | diagnosis



Original worked example; supplied references

Closure and residual risk | verification

EVIDENCE TO PRESERVE

Archive the evidence bundle, change reference and signed decision.

ACCEPTANCE BOUNDARY

A role correction passes allowed and denied access tests.

Reopen unsupported closure and assign remaining risk to an accountable owner.

Closure and residual risk | AI claim review

INSPECTABLE ARTIFACT

REVIEW CONTRACT

claim
evidence_ids
observed_field_values
alternative_explanation
uncertainty
verification_required

INTERPRETATION

Test this claim:
A ticket closes because the AI
report sounds confident.

Resolve it using:
root_cause, control_change, retest,
residual_risk

Lab 16 | input schema

INSPECTABLE ARTIFACT

id: INC-001
approved: True
action_ok: True
retest_ok: True
events_expected: 100
events_seen: 95

INTERPRETATION

Synthetic fixture record.

Response state register and closure evidence.

The full dataset and instructions are in this lab's own folder.

Lab 16 | decision logic

```
for r in rows:
    coverage=r['events_seen']/r['events_expected'] if
r['events_expected'] else None
    decision='WAIT_APPROVAL' if not r['approved'] else
('ACTION_FAILED' if not r['action_ok'] else ('RECOVERED' if
r['retest_ok'] and coverage is not None and coverage>=0.9 else
'VERIFY_REQUIRED'))
    out.append({'id':r['id'],'coverage':coverage,'decision':de
cision})
```

READ THE CODE

Actual excerpt from
analyse.py.

Python standard library
only.

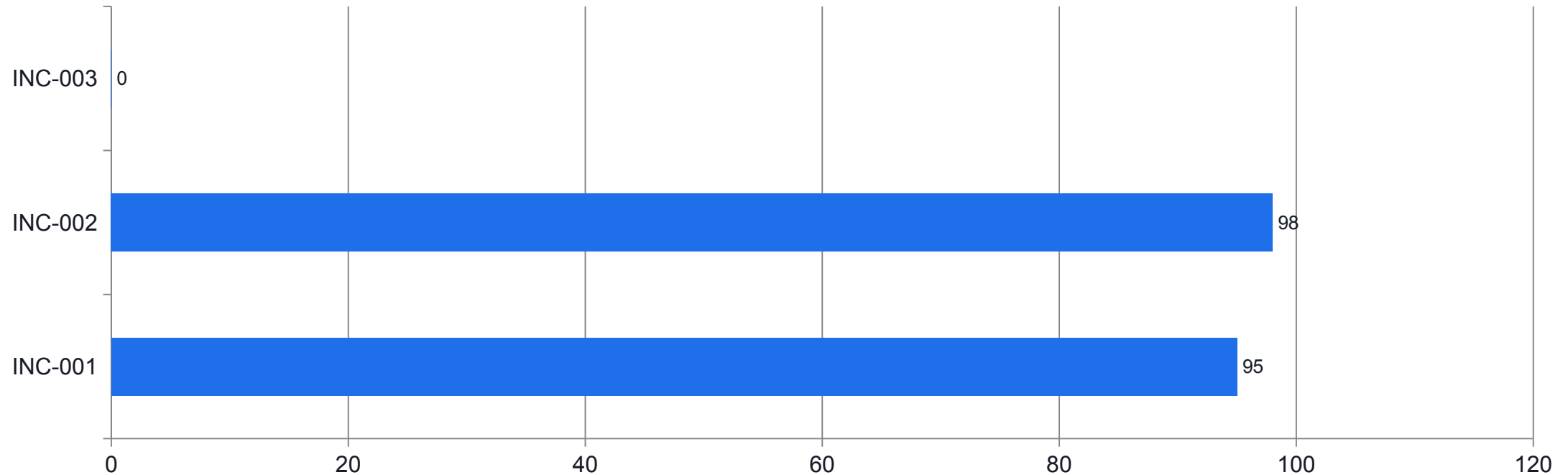
Offline rule model; AI
review is separate.

Lab 16 | computed decisions

Record	Observed decision
INC-001	RECOVERED
INC-002	WAIT_APPROVAL
INC-003	VERIFY_REQUIRED

Original worked example; supplied references

Lab 16 | evidence distribution



WHAT THE DATA SHOWS

Synthetic telemetry completeness (%). INC-003 has no observed events, so zero alerts cannot establish recovery.

Lab 16 | test a changed condition

CONTROLLED CHANGE

Set INC-003 retest_ok to true. It must still remain VERIFY_REQUIRED because telemetry coverage is zero.

EVIDENCE CONTRACT

Record the input SHA-256, changed field, predicted decision and actual decision. Explain discrepancies using the script.

Lab 16 | operational verification

DELIVERABLE

Response state register and closure evidence.

Record scope, UTC time and approval state.

WHAT COUNTS AS EVIDENCE

A simulated pass proves the local rule only. A live claim requires configuration and an observed test. Record exact blockers and unresolved outcomes.

Day 4 | evidence review

EXHIBITS

Labs 13–16: compare baseline, changed-input result and source checksum.

REVIEW DECISION

Which claim is supported by a record? Which control still needs operational verification? Cite the exact artifact and uncertainty.

Assessment

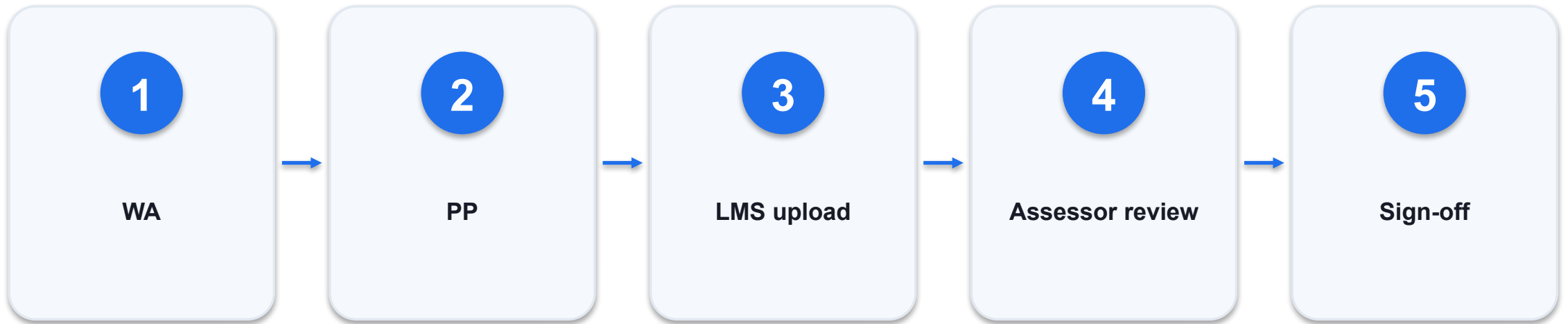
WRITTEN | 60 MIN

Complete all nine K1–K9 questions in the provided document.

PRACTICAL | 60 MIN

Complete all three A1–A6 tasks and attach the requested evidence.

Assessment flow



MECHANISM

Submit the completed candidate documents in the LMS. The assessor records competence and any required clarification.

Digital attendance and TRAQOM

ATTENDANCE

Complete required assessment attendance using the provider-issued link.

COURSE FEEDBACK

Complete the provider-issued TRAQOM survey when prompted.

Thank you

CONTINUE PRACTISING

Re-run the lab cases and explain the changed outputs using evidence.

COURSE SUPPORT

Contact your trainer through the course LMS.
Keep confidential data out of shared examples.